

THALES SIX GTS France
4, Avenue des Louvresses
92622 Gennevilliers Cedex
France
Tel.: +33 (0)1 41 30 30 00
Fax: +33 (0)1 41 30 33 57
www.thalesgroup.com

SECURITY TARGET FOR MISTRAL VS9

MISTRAL VS9 IPSEC GATEWAY SOFTWARE

DUAL USE CONTROLLED

Export controlled and subject to authorization from FRANCE

Entity Identifiant	Document Identifiant	DTC	Revision
0026 – F0057	63535113-lite	306	AF

Ce document est propriété du Groupe THALES et ne peut être communiqué à l'extérieur du Groupe qu'avec l'accord de THALES SIX GTS France. *This document is THALES Group's property and must not be communicated outside the Group without the agreement of THALES SIX GTS France.* © THALES 2019-2024 – Tous droits réservés - © THALES 2019-2024 – copyrights

TABLE OF CONTENT

1. Introduction	9
1.1. Document identification and summary.....	9
1.2. TOE identification.....	9
1.3. Abbreviations and acronyms	10
1.3.1. Administrative acronyms.....	10
1.3.2. Technical acronyms	10
1.3.3. Nomenclature rules	13
1.4. Applicable documents.....	14
1.5. Reference documents.....	15
2. TOE overview	16
2.1. Mistral system overview.....	16
2.1.1. Architecture of the Mistral system.....	16
2.1.2. SS_IPSEC_GW	17
2.1.3. Administration center	18
2.1.4. External network services	18
2.2. TOE description	19
2.2.1. TOE definition	19
2.2.2. TOE boundary.....	19
2.2.3. TOE functionalities.....	20
2.2.4. TOE Interfaces	20
2.2.5. TOE states	22
2.2.6. TOE lifecycle.....	23
2.2.7. TOE delivery	24
2.2.8. TOE update.....	25
3. Conformance claim.....	26
3.1. CC conformance claim	26
3.2. C_PP conformance claim	27

DUAL USE CONTROLLED

Ce document est propriété du Groupe THALES et ne peut être communiqué à l'extérieur du Groupe qu'avec l'accord de THALES SIX GTS France. *This document is THALES Group's property and must not be communicated outside the Group without the agreement of THALES SIX GTS France.* © THALES 2019-2024 – Tous droits réservés - © THALES 2019-2024 – copyrights

3.3.	Package conformance claim.....	27
4.	Security problem definition	28
4.1.	Assets	29
4.1.1.	Assets protected with the TOE (User Data).....	29
4.1.2.	Assets belonging to the TOE (TSF Data)	29
4.2.	Users, System and sub-system	30
4.2.1.	U.ROLE_GW_OPERATOR	30
4.2.2.	U.ROLE_SYS_ADMIN.....	30
4.2.3.	SS_IPSEC_GW	31
4.2.4.	SS_MMC.....	31
4.2.5.	CSS_LMGMT.....	31
4.2.6.	CSS_PKI.....	31
4.2.7.	CSS_OCSP_RESPONDER	31
4.2.8.	CSS_DHCP	31
4.3.	Assumptions	32
4.3.1.	Securing the TOE.....	32
4.3.2.	Administration	33
4.3.3.	Assumptions about management devices	34
4.4.	Organizational security policies (OSP)	36
4.4.1.	Services	36
4.4.2.	Miscellaneous	36
4.5.	Threats.....	38
4.5.1.	T.SECURITY_FUNCTIONALITY_FAILURE	38
4.5.2.	T.UNDETECTED_ACTIVITY	38
4.5.3.	T.UNAUTHORIZED_ADMINISTRATOR_ACCESS	38
4.5.4.	T.UPDATE_COMPROMISE.....	39
4.5.5.	T.USER_DATA_REUSE.....	39
4.5.6.	T.MISUSE	39
4.5.7.	T.TIME_BASE	39

DUAL USE CONTROLLED

4.5.8.	T.RESIDUAL_DATA	39
4.5.9.	T.WEAK_CRYPTOGRAPHY	39
4.5.10.	T.UNTRUSTED_COMMUNICATION_CHANNELS	39
4.5.11.	T.WEAK_AUTHENTICATION_ENDPOINTS	40
4.5.12.	T.PASSWORD_CRACKING	40
4.5.13.	T.SECURITY_FUNCTIONALITY_COMPROMISE	40
4.5.14.	T.TOE_CAPTURE.....	40
5.	Security Objectives.....	41
5.1.	Security objectives for the TOE	41
5.1.1.	Communication protection	41
5.1.2.	Audit.....	41
5.1.3.	TOE management.....	42
5.1.4.	Data protection.....	44
5.1.5.	Software.....	44
5.1.6.	Cryptography	45
5.2.	Security objectives for the TOE environment	45
5.2.1.	The management.....	45
5.2.2.	The TOE.....	47
5.2.3.	The management devices	48
5.2.4.	Software updates	49
5.3.	Rationale for the security objectives.....	50
5.3.1.	Threats.....	50
5.3.2.	Organizational Security Policies (OSP)	57
5.3.3.	Assumptions	59
6.	Extended security requirements	60
6.1.	Security Audit (FAU).....	60
6.1.1.	Protected audit event storage (FAU_STG_EXT).....	60
6.2.	Cryptographic Support (FCS)	62

DUAL USE CONTROLLED

6.2.1.	Random Bit Generation (FCS_RBG_EXT).....	62
6.2.2.	Cryptographic Protocols (FCS_IPSEC_EXT, FCS_TLSC_EXT, FCS_TLSS_EXT).....	63
6.2.3.	Cryptographic Key Lifetime (FCS_CKM_EXT.5)	68
6.3.	Identification and Authentication (FIA).....	69
6.3.1.	Password Management (FIA_PMG_EXT).....	69
6.3.2.	User Identification and Authentication (FIA_UIA_EXT)	70
6.3.3.	User authentication (FIA_UAU_EXT)	71
6.3.4.	Authentication using X.509 certificates (FIA_X509_EXT)	72
6.4.	Protection of the TSF (FPT).....	74
6.4.1.	Protection of TSF Data (FPT_SKP_EXT).....	74
6.4.2.	Protection of Administrator Passwords (FPT_APW_EXT)	75
6.4.3.	TSF Self-Test (FPT_TST_EXT)	76
6.4.4.	Trusted Update (FPT_TUD_EXT).....	77
6.4.5.	Time stamps (FPT_STM_EXT).....	78
6.4.6.	Stored TSF Data Protection (FPT_SDP_EXT).....	78
6.5.	TOE Access (FTA)	80
6.5.1.	TSF-initiated Session Locking (FTA_SSL_EXT)	80
6.6.	Communication (FCO).....	81
6.6.1.	Communication Partner Control (FCO_CPC_EXT).....	81
7.	Security requirements.....	83
7.1.	Security functional requirements	83
7.1.1.	Terms used within SFRs	83
7.1.2.	Audit.....	86
7.1.3.	Cryptography	88
7.1.4.	Communications Protection and Flow Controls.....	91
7.1.5.	Users and Devices.....	101
7.1.6.	TSF Management	103
7.1.7.	Miscellaneous	104

DUAL USE CONTROLLED

7.2.	Security Assurance requirements	106
7.3.	Rationale for the security requirements	107
7.3.1.	Security objectives for the TOE	107
7.3.2.	Rationale for the security assurance requirements	116
7.3.3.	Dependencies	117
8.	TOE Summary specifications	123
8.1.	Security functions.....	123
8.1.1.	F.AUDIT_AND_EVENTS_LOGGING	123
8.1.2.	F.STORAGE_AND_PROTECTION_FOR_LOCAL_DATA.....	125
8.1.3.	F.TRAFFIC_KEYS_AND_CERTIFICATES_MANAGEMENT	126
8.1.4.	F.USERS_CONFIGURATION_AND_MONITORING.....	126
8.1.5.	F.FILTERING_AND_PROTECTION_NETWORK_DATA_FLOWS.....	128
8.1.6.	F.SECURE_BOOT	129
8.1.7.	F.FAILURE_STATE	129
8.1.8.	F.SECURITY_ERASURE.....	130
8.1.9.	F.SELF-TEST	130
8.1.10.	F.HIGH-AVAILABILITY	130
8.2.	SFR and Security Function mapping	131

DUAL USE CONTROLLED

TABLE OF FIGURE

Figure 1: Example of MISTRAL System architecture with admin network16

Figure 2: Example of MISTRAL System architecture without admin network 17

Figure 3: TOE Boundary19

Figure 4: Configuration state diagram23

Figure 5: TOE Lifecycle24

DUAL USE CONTROLLED

TABLE OF TABLE

Table 1: TOE identification	9
Table 2: Administrative acronyms	10
Table 3: Technical acronyms.....	12
Table 4: Applicable documents	14
Table 5: Reference documents	15
Table 6: TSFI list	21
Table 7: Network interfaces supporting TSFI.....	22
Table 8: Configuration state description	22
Table 9: Refined SFR.....	26
Table 10: Extended SFR.....	27
Table 11: Threat coverage	51
Table 12: Organizational Security Policy coverage	57
Table 13: Assumptions coverage.....	59
Table 14: Assurance requirements for EAL4+	107
Table 15: Objectives coverage.....	112
Table 16: SFR dependencies status.....	120
Table 17: Unsatisfied SFR dependencies.....	120
Table 18: SAR dependencies status.....	122
Table 19: SFR and SFT mapping	134

DUAL USE CONTROLLED

Ce document est propriété du Groupe THALES et ne peut être communiqué à l'extérieur du Groupe qu'avec l'accord de THALES SIX GTS France. *This document is THALES Group's property and must not be communicated outside the Group without the agreement of THALES SIX GTS France.* © THALES 2019-2024 – Tous droits réservés - © THALES 2019-2024 – copyrights

1. INTRODUCTION

1.1. DOCUMENT IDENTIFICATION AND SUMMARY

Document reference: 63535113-lite-306

Document version: AF

Evaluation Level: EAL4+ (EAL4 augmented with ALC_FLR.3)

The security target is based on but does not claim conformance to the Security Requirements of the collaborative Protection Profile for Network Devices [c_PP].

1.2. TOE IDENTIFICATION

Hardware	Machine name	OS-Release (software version)	Mistral- compatibility	Build	ID
IP9001	TRC7540-2	9.2.3.5	2	1690368775	d08706967
IP9010	TRC7540-3	9.2.3.5	2	1692711124	d08706967

Table 1: TOE identification

The group composed by the Mistral gateway software embedded in Mistral gateway device, is called SS_IPSEC_GW.

TOE, Mistral gateway, version's format is as follow: V9.x.y.z

x is the system version

y identifies major functional version

z is an optional free field and indicates test version, debug version (if it includes a d) or a version with minor evolutions on a same functional boundary

DUAL USE CONTROLLED

1.3. ABBREVIATIONS AND ACRONYMS

1.3.1. Administrative acronyms

Acronym	Meaning
ANSSI	National Agency for Information System Security
CC	Common Criteria
COTS	Component Off The Shelves
EAL	Evaluation Assurance Level
IT	Information Technology
PP	Protection Profile
SF	Security Function
SFP	Security Function Policy
SFR	Security Function Requirement
SFT	Security Function of the TOE
ST	Security Target
TOE	Target of Evaluation
TSF	TOE Security Functions
TSFI	TSF Interface
TSP	TOE Security Policy

Table 2: Administrative acronyms

1.3.2. Technical acronyms

Acronym	Meaning
AES	Advanced Encryption Standard
AH	Authentication Header
ARP	Address Resolution Protocol
BIOS	Basic Input Output System
CA	Certificate Authority
CARP	Common Address Redundancy Protocol
CBC	Cipher Block Chain
CLI	Command Line Interface
CRL	Certificate Revocation List
DHCP	Dynamic Host Configuration Protocol

DUAL USE CONTROLLED

Acronym	Meaning
DR	Diffusion Restreinte
DRGB	Deterministic Random Bit Generator
DSCP	Differentiated Services Code Point
ECDH (E)	Elliptic Curve Diffie-Hellman (Ephemeral)
ECDSA	Elliptic Curve Digital Signature Algorithm
ECSDSA	Elliptic Curve based Schnorr Digital Signature Algorithm
ESN	Extended Serial Number
ESP	Encapsulating Security Payload
GCM	Galois Counter Mode
GW	MISTRAL IPsec GateWay
HAC	High-Availability Cluster
HMAC	Hash-based Message Authentication Code
IBIT	Initiated Built In Test
ICMP	Internet Control Message Protocol
ICV	Integrity Check Value
IKE	Internet Key Exchange
IP	Internet Protocol
IPsec	Internet Protocol Security
LDAP	Lightweight Directory Access Protocol
LED	Light-Emitting Diode
MAC	Message Authentication Code
MMC	Mistral Management Center
MTU	Maximum Transmission Unit
NAT	Network Address Translation
OCSP	Online Certificate Status Protocol
OID	Object IDentifier
OS	Operating System
PBIT	Power Up Built In Test
PFS	Perfect Forward Secrecy
PRF	Pseudo-Random Function
RFC	Request For Comments
RNG	Random Number Generator
RSA	Rivest–Shamir–Adelman (public-key cryptosystem)
SA	Security Association
SHA	Secure Hash Algorithm
SP	Security Policy

DUAL USE CONTROLLED

Acronym	Meaning
SPI	Security Parameter Index
SSH	Secure Shell
TBD	To Be Defined
TCP	Transmission Control Protocol
TLS	Transport Layer Security
TPM	Trusted Platform Module
UDP	User Datagram Protocol
USB	Universal Serial Bus
VPN	Virtual Private Network

Table 3: Technical acronyms

DUAL USE CONTROLLED

Ce document est propriété du Groupe THALES et ne peut être communiqué à l'extérieur du Groupe qu'avec l'accord de THALES SIX GTS France. *This document is THALES Group's property and must not be communicated outside the Group without the agreement of THALES SIX GTS France.* © THALES 2019-2024 – Tous droits réservés - © THALES 2019-2024 – copyrights

1.3.3. Nomenclature rules

- A.: Assumption prefix,
- F.: Security Function prefix,
- O.: Security Objective prefix,
- OE.: Security Objective for the TOE Environment prefix,
- P.: Organizational Security Policy prefix,
- S_: System object of the solution prefix,
- SS_: Sub-System of a System prefix,
- CS_: Cooperative System prefix,
- CSS_: Sub-System of a Cooperative System prefix,
- T.: Threat prefix,
- ST_: State prefix,
- U.: User prefix,
- OP.: Operation prefix.

DUAL USE CONTROLLED

Ce document est propriété du Groupe THALES et ne peut être communiqué à l'extérieur du Groupe qu'avec l'accord de THALES SIX GTS France. *This document is THALES Group's property and must not be communicated outside the Group without the agreement of THALES SIX GTS France.* © THALES 2019-2024 – Tous droits réservés - © THALES 2019-2024 – copyrights

1.4. APPLICABLE DOCUMENTS

	Title	References	Version
[CC-01]	Common Criteria for Information Technology Security Evaluation: Introduction and general model	CCMB-2017-04-001	3.1 Revision 5 - Part 1 - April 2017.
[CC-02]	Common Criteria for Information Technology Security Evaluation: Security functional components	CCMB-2017-04-002	3.1 Revision 5 - Part 2 - April 2017.
[CC-03]	Common Criteria for Information Technology Security Evaluation: Security assurance components	CCMB-2017-04-003	3.1 Revision 5 - Part 3 - April 2017.
[CEM]	Common Criteria for Information Technology Security Evaluation: Evaluation methodology	CCMB-2017-04-004	3.1 Revision 5 - April 2017.
[DR PROFILE]	CORPUS DOCUMENTAIRE IPSEC DR À DESTINATION DES INDUSTRIELS – VERSION 1.0	https://www.ssi.gouv.fr/entreprise/guide/ipsec-dr/	Mar-2023

Table 4: Applicable documents

DUAL USE CONTROLLED

Ce document est propriété du Groupe THALES et ne peut être communiqué à l'extérieur du Groupe qu'avec l'accord de THALES SIX GTS France. *This document is THALES Group's property and must not be communicated outside the Group without the agreement of THALES SIX GTS France.* © THALES 2019-2024 – Tous droits réservés - © THALES 2019-2024 – copyrights

1.5. REFERENCE DOCUMENTS

	Title	References	Version
[RGS_B]	Rules and recommendations regarding the management of cryptographic mechanisms Annex B2 and B3 of « Référentiel Général de Sécurité »	N/A	2.0
[PG-083]	Rules and recommendations regarding the selection and sizing of cryptographic mechanisms	ANSSI-PG-083	2.04 – 01-Jan-2020
[c_PP]	Collaborative Protection Profile for Network Devices	N/A	2.2e – 23-Mar-2020
[LINUX_ANSSI]	Recommandations de configuration d'un système GNU/Linux	ANSSI/BP-028	1.2 – 22 Fev. 2019
[PARTITIONING_ANSSI]	Recommandations pour la mise en place de cloisonnement système	ANSSI-PG-040	1 – 14 Dec. 2017
[PASSWD_ANSSI]	Recommandations relatives à l'authentification multifacteur et aux mots de passe	ANSSI-PG-078	2.0 – 8 Oct. 2021
[Instal-IP9001]	Guide d'installation rapide Mistral séries 9000-IP9001	65471286-108	-D – Jan. 2022
[MU-IP9001]	Manuel d'utilisation Gateway IPsec MISTRAL IP9001	67147240-108	-K – Sept. 2024
[UM-IP9001]	MISTRAL IP9001 IPsec Gateway-User Manual	67417129-108	-D – Sept. 2024
[Instal-IP9010]	Guide d'installation rapide Mistral séries 9000-IP9010	68720460-108	-A – April 2023
[MU-IP9010]	Manuel d'utilisation Gateway IPsec MISTRAL IP9010	68720459-108	-B – Sept. 2024
[UM-IP9010]	MISTRAL IP9010 IPsec Gateway-User Manual	68727110-108	-B – Sept. 2024
[Instal-MMC]	Manuel d'installation Mistral Management Center	67417122-067	-C – Sept. 2024
[MMC-Install]	MMC Installation Manual	67417130-067	-C – Sept. 2024
[MU-MMC]	Manuel d'utilisation Mistral Management Center	67147242-108	-F – Sept. 2024
[UM-MMC]	User Manual MMC	67417134-108	-C – Sept. 2024
[MU-VM]	Manuel d'utilisation VM MISTRAL	67691343-108	-C – Sept. 2024
[UM-VM]	MISTRAL Virtual IPsec Gateway-User Manual	68727111-108	-B – Sept. 2024

Table 5: Reference documents

DUAL USE CONTROLLED

2. TOE OVERVIEW

2.1. MISTRAL SYSTEM OVERVIEW

2.1.1. Architecture of the Mistral system

Mistral system (S_MISTRAL) is provided by **ROLE_PROVIDER** (THALES) to **ROLE_ORGANISATION** (customer organisation) to protect the dataflow between **ROLE_ORGANISATION** stations for unique equipment as well as for a complex network with multiple site accesses.

Mistral system (S_MISTRAL) comprises:

- IPv4 gateway (**SS_IPSEC_GW**) following IPsec DR profile (IPsec tunnel mode only, ESN etc.),
- Mistral Management Center (**SS_MMC**),
- Factory SEcRet OperatiOnS sub-system (**SS_FACTORY_SEC_OPS**) used by **ROLE_PROVIDER** to protect software before delivery,
- Production sub-system (**SS_PRODUCTION**) used by **ROLE_PROVIDER** to produce and check **SS_IPSEC_GW** before delivery,
- Soft delivery system (**SS_SW_DELIVERY**).

Only **SS_IPSEC_GW** and **SS_MMC** are delivered by **ROLE_PROVIDER** to the **ROLE_ORGANISATION**.

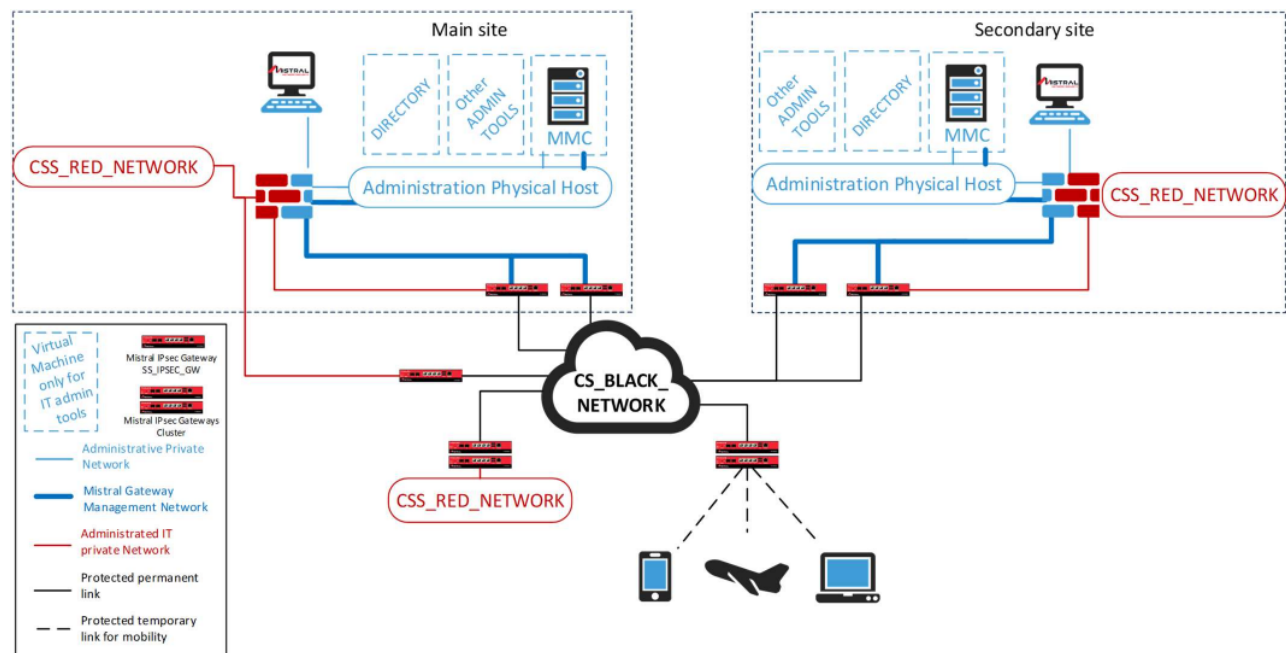


Figure 1: Example of MISTRAL System architecture with admin network

DUAL USE CONTROLLED

Ce document est propriété du Groupe THALES et ne peut être communiqué à l'extérieur du Groupe qu'avec l'accord de THALES SIX GTS France. This document is THALES Group's property and must not be communicated outside the Group without the agreement of THALES SIX GTS France. © THALES 2019-2024 – Tous droits réservés - © THALES 2019-2024 – copyrights

The cooperating systems and sub-systems are:

- Untrusted network (**CS_BLACK_NETWORK**),
- Trusted network (**CSS_RED_NETWORK**),
- Customer facilities (**CS_ORGANIZATION**),
- Sub-system providing the certification authority and certificates (**CSS_PKI**),
- Supervision center (**CSS_SOC**),
- Physical USB support used for data (configuration file, certificates and logs) or firmware update transportation (**CSS_USB_MEDIA**),
- IPsec peers (**CSS_IPSEC_PEER**) i.e. other gateways than **SS_IPSEC_GW** or mobile endpoints which may connect to **SS_IPSEC_GW** using the same protocols and certificates.

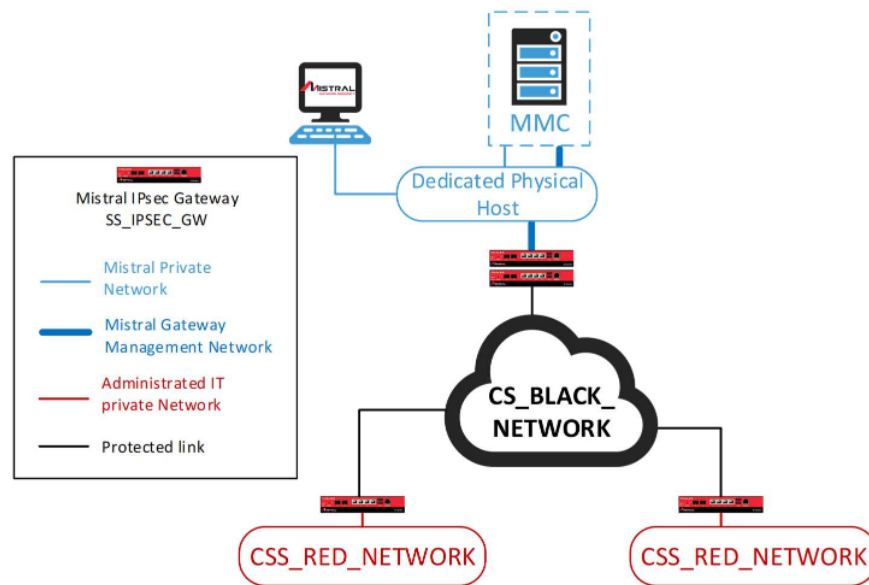


Figure 2: Example of MISTRAL System architecture without admin network

2.1.2. SS IPSEC GW

SS_IPSEC_GW provides data exchanges protection based on VPN (« Virtual Private Network ») technology across untrusted path. It secures data communication links inside network handling data at restricted level of classification (DIFFUSION RESTREINTE, RESTREINT OTAN/NATO RESTRICTED, and RESTREINT UE/EU RESTRICTED).

On each network node, it can be deployed alone or be member of a high availability active-passive cluster.

DUAL USE CONTROLLED

2.1.3. Administration center

The elements of the administration center are used for the SS_IPSEC_GW configuration and certificates management and for monitoring:

- CSS_PKI is the element providing the certificates and certificate revocation lists. ROLE_ORGANISATION may also entrust the key generation to CSS_PKI,
- SS_MMC is the element of Mistral Management Center (MMC). It is composed of software located on a web server in a virtualized or physical environment. SS_MMC must be authenticated by SS_IPSEC_GW and use a secured link (with parameters defined in the SS_IPSEC_GW) in order to remotely configure the SS_IPSEC_GW (see Figure 1: Example of MISTRAL System architecture) with configuration file and commands.

A third element may interact with the MMC for user authentication:

- CSS_DIRECTORY is an LDAP directory providing MMC user accounts and authentication.

Nota: CSS_PKI is an external service required for the system. CSS_DIRECTORY is not mandatory and it is an external service used for user authentication on the MMC only.

2.1.4. External network services

In addition, some external network services may be required when optional functionalities are activated:

- CSS_DHCP is an external DHCP server compliant with RFC 2131 that should be accessible from the red network when the MISTRAL IPsec Gateway is configured with mobility capabilities, and when mobile IPsec endpoints are waiting to dynamically receive their red IP configuration;
- CSS_OCSP_RESPONDER is an external OCSP responder compliant with RFC 6960 that should be accessible from the red network when the MISTRAL IPsec Gateway is configured in OCSP direct mode, i.e. when it is expected that the revocation status of certificates is checked online.

DUAL USE CONTROLLED

2.2. TOE DESCRIPTION

2.2.1. TOE definition

TOE is the software of the SS_IPSEC_GW, a network device providing IP datagram protection based on VPN (« Virtual Private Network ») technology. It secures data communication links.

2.2.2. TOE boundary

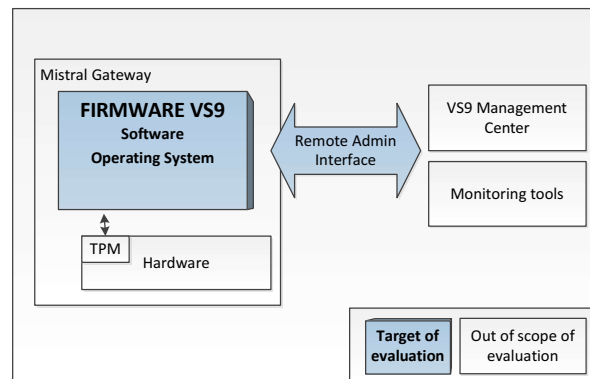


Figure 3: TOE Boundary

The TOE is the **Mistral software** running on the SS_IPSEC_GW **with IPsec DR profile** in IPv4 environment. It is composed of a Linux OS and the Mistral applications.

The Linux OS is hardened and complies with guidance from French administration to secure Linux OS **[LINUX_ANSSI]** and **[PARTITIONING_ANSSI]**.

The TOE may be deployed alone or in a redundant cluster where two instances of the TOE are deployed in an active-passive mode.

All other components of the Mistral system are considered as part of the operational environment.

Hardware equipment is out of scope of the Target of Evaluation described in this Security Target.

The Mistral Management Center device (SS_MMC), its optional adjoined LDAP directory (CSS_DIRECTORY), the Public Key Infrastructure device (CSS_PKI) and other network services (CSS_DHCP and CSS_OCSP_RESPONDER) are outside the TOE. SS_MMC may be any third party management system compliant with the management interfaces and assumptions. CSS_PKI may be any third party public key infrastructure solution compliant with the certificates and keys interfaces and assumptions.

DUAL USE CONTROLLED

2.2.3. TOE functionalities

The TOE's main functionalities are:

Dataflow protection (Control and filtering) from Ethernet interfaces, with Security Policies configuration allowing:

- IPv4 Data flow filtering, at OSI network level 3 and OSI transport level 4,
- IPv4 Data flow protection (against disclosure, modification, insertion and replay) with IPsec ESP Tunnel encapsulation mode, which provides datagram payload data and topology data encryption, integrity and anti-replay following only the cryptographic algorithms described in the IPsec DR profile,
- Data flow discard when no protection policy exists for the flow.

Management flow control and protection:

- Management flow protection (against disclosure, modification, insertion and replay) with TLS.

TOE security management:

- Certificate and Key management,
- Password management,
- Secure sensitive data storage with partition of red and black networks,
- Secure boot,
- Secure erasure,
- Secure software update,
- Self-tests (PBIT at start-up and IBIT on request),
- Supervision,
- Audit generation.

2.2.4. TOE Interfaces

TSFI identifier	Description
IF_GW_LOCAL_MGT	Interface man-machine for command on line (CLI) Local interface on SS_IPSEC_GW serial port
IF_REMOTE_MGT	Remote management Interface Interface between SS_IPSEC_GW and SS_MMC via IF_RED_NETWORK or IF_VPN_ADMIN
IF_IMPORT_EXPORT	Interface of data import / export via CSS_USB_MEDIA Interface used for configuration with INIT_CONF or FULL_CONF files, import of certificates and key containers, and for local data export as archives of EVENT_LOG and certificate signing requests.
IF_GW_VISU	Visual interface Interface allowing to check TOE status, network connection status and DR profile activation

DUAL USE CONTROLLED

TSFI identifier	Description
IF_GW_WIPE_BTN	Secure erasure button interface Physical button triggering secure erasure.
IF_PKI	CSS_PKI interface Interface with CSS_PKI via IF_IMPORT_EXPORT (using commands on IF_GW_LOCAL_MGT) or via IF_REMOTE_MGT for certificate import / export.
IF_GW_LOG_EXPORT	Log files export interface Interface used to export log files via IF_IMPORT_EXPORT using commands on IF_GW_LOCAL_MGT.
IF_LOG_EXPORT	Events transmission interface Interface used to transmit events to SS_MMC via IF_RED_NETWORK or IF_VPN_ADMIN.
IF_DOWNLOAD	Software update interface Interface used to get update software from SS_MMC via IF_RED_NETWORK or IF_VPN_ADMIN.
IF_SW_UPDATE	Software update protection interface Interface used to protect update software with SS_FACTORY_SEC_OPS
IF_VPN	CS_BLACK_NETWORK interface for traffic Virtual Private Network interface with IPsec gateway on IF_BLACK_NETWORK.
IF_VPN_ADMIN	CS_BLACK_NETWORK interface for TOE management Virtual Private Network interface with IPsec gateway on IF_BLACK_NETWORK.
IF_GW_POWER_BTN	Power button interface Physical button triggering power on / off or reboot.
IF_HAC_SYNC	High-Availability Cluster interface Interface optionally used with another TOE for CARP high-availability exchanges when the TOE is deployed and configured in a cluster. This interface rests on IF_RED_NETWORK.
IF_DHCP_SERVER	Dynamic Host Configuration Protocol interface Interface optionally used to request the allocation of red IP addresses on behalf of remote peers from an external DHCP server via IF_RED_NETWORK or IF_VPN_ADMIN, when the TOE is configured to act as a DHCP relay.
IF_OCSP_RESPONDER	Online Certificate Status Protocol interface Interface optionally used to retrieve the revocation status of certificates from an online OCSP responder via IF_RED_NETWORK or IF_VPN_ADMIN.

Table 6: TSFI list

DUAL USE CONTROLLED

Supporting interface identifier	Description
IF_BLACK_NETWORK	CS_BLACK_NETWORK interface Interface for interactions with CS_BLACK_NETWORK concerning user data flow and network services with other MISTRAL sub-systems on untrusted side.
IF_RED_NETWORK	CSS_RED_NETWORK interface Interface for interactions with CSS_RED_NETWORK concerning user data flow and network services with other MISTRAL sub-systems on trusted side.

Table 7: Network interfaces supporting TSFI

2.2.5. TOE states

2.2.5.1. TOE configuration state

State	Description
ST_GW_FACTORY	TOE software is loaded on the hardware with default account parameters. Provider assets are loaded without any customer parameters. The TOE reaches this state after a secure erasure.
ST_GW_PERSONALIZED	The local operator password has been set up, the TOE encryption data have been loaded and the TOE has been customized.
ST_GW_CONFIGURED	Time has been configured and a configuration file has been loaded. TOE is ready to connect SS_MMC (if exists) and to create VPN IPsec with other TOE instances for user traffic depending of the configuration file loaded.

Table 8: Configuration state description

DUAL USE CONTROLLED

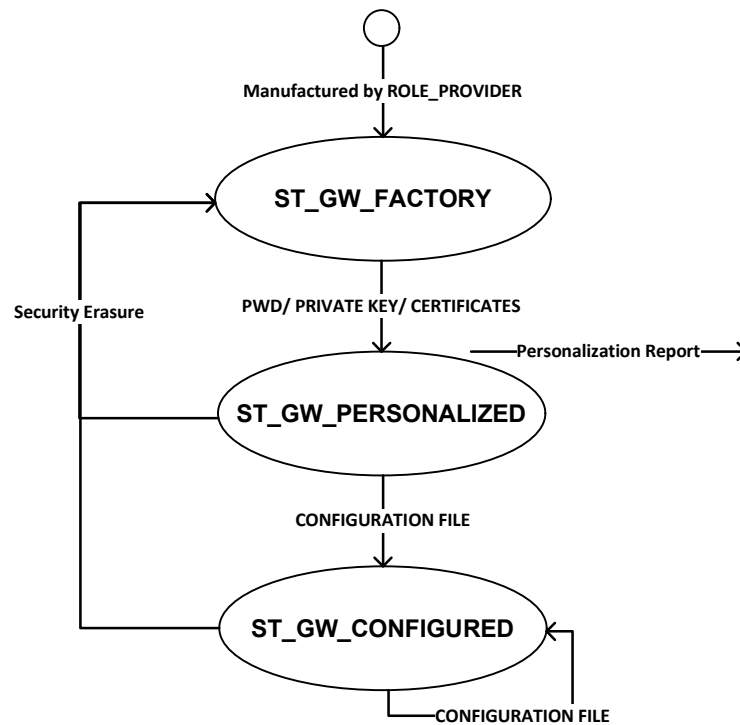


Figure 4: Configuration state diagram

2.2.5.2. TOE functional state

- **ST_FAILURE**: TOE enters this state when a failure is detected. It requires a system fix or be sent back to the provider.
- **ST_OPERATIONAL**: TOE provides its services depending of its configuration state.

2.2.6. TOE lifecycle

The TOE lifecycle is illustrated below:

DUAL USE CONTROLLED

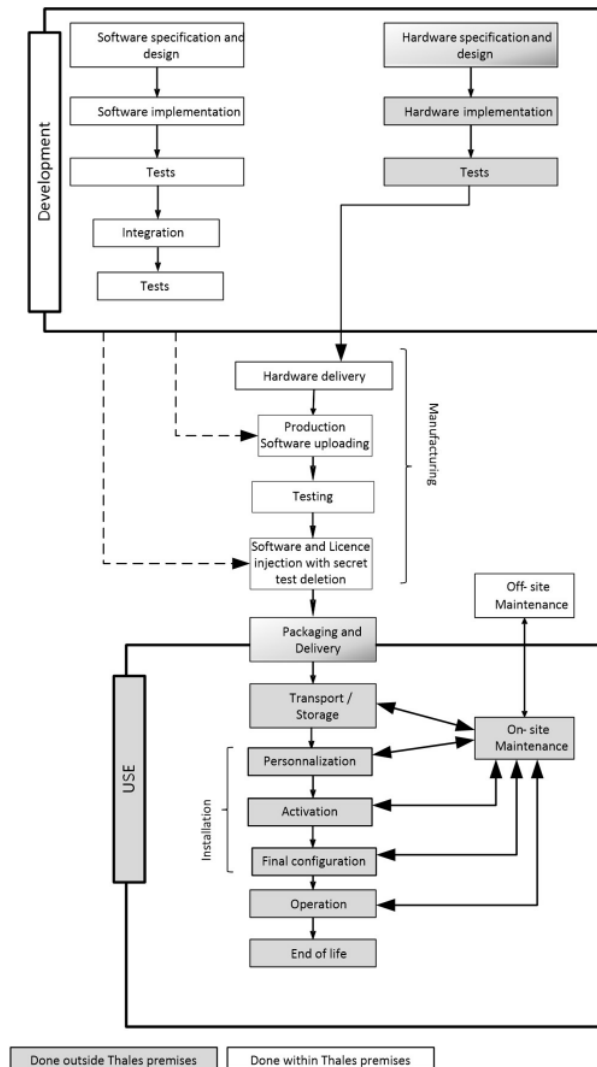


Figure 5: TOE Lifecycle

2.2.7. TOE delivery

The TOE (gateway software) is delivered from Cryptobox with a temporary link created for the delivery.

The delivery includes also the guides [Instal-IP9001], [MU-IP9001], [UM-IP9001], [Instal-IP9010], [MU-IP9010], [UM-IP9010], [Instal-MMC], [MMC-Instal], [MU-MMC] and [UM-MMC] described in § 1.5.

The e-mail with the temporary and dedicated link to the Cryptobox is sent to each concerned customer.

DUAL USE CONTROLLED

2.2.8. TOE update

The TOE update process can be proceeded in two different ways: remotely from the management center (SS_MMC) or locally thanks to an USB removable device (CSS_USB_MEDIA).

Remotely:

- Software provider delivers software update to the client organisation,
- The client organisation deposits the software update on SS_MMC,
- ROLE_SYS_ADMIN (remotely) or ROLE_GW_OPERATOR (locally) requests the TOE to download the software update,
- Then, the TOE downloads firmware update from SS_MMC through VPN.

Locally:

- Software provider delivers software update to the client organisation,
- The client organisation deposits the software update on CSS_USB_MEDIA,
- ROLE_GW_OPERATOR plugs the CSS_USB_MEDIA to the TOE,
- ROLE_GW_OPERATOR requests the TOE to import the software update,
- Then, the TOE imports firmware update from CSS_USB_MEDIA.

In both cases, the TOE then:

- Checks firmware authenticity,
- Decrypts firmware update and
- Checks version number of firmware update.
- ROLE_SYS_ADMIN (remotely) or ROLE_GW_OPERATOR (locally) requests the TOE to activate the software uploaded or imported.
- The TOE:
 - Installs firmware update when the firmware update has been activated,
 - Restarts TOE (self-test are automatically launched),
 - In case of update failure, the previous version can be reactivated.

In case of any error, TOE stops process and continues its nominal activity. SS_MMC is aware about TOE state and its software version, it may launch again the procedure if necessary.

DUAL USE CONTROLLED

3. CONFORMANCE CLAIM

3.1. CC CONFORMANCE CLAIM

This security target is conformant to Common Criteria 3.1 revision 5 of April 2017:

- [CC-02] extended
- [CC-03] conformant

Here is the list of the Security Functional Requirement refined:

Object Name	Comment
FAU_GEN.1	
FAU_GEN.2	Precision about network device
FDP_UCT.1	Precision about use of the SFP
FDP_UIT.1	Precision about use of the SFP
FDP_ITC.2/VPN	VPN SFP enforcing
FDP_ETC.2/VPN	VPN SFP enforcing
FDP_ITC.2/CRYPTOINJECTION	Certificate injection enforcing
FMT_MSA.3	Precision of default value
FIA_UID.2	MMC limitation
FIA_UAU.6	Precision of the user U.ROLE_GW_OPERATOR
FIA_UAU.7	Precision of the user U.ROLE_GW_OPERATOR
FCS_CKM.1	For asymmetric cryptographic keys
FCS_CKM.2	For Key establishment
FCS_COP.1/Hash256	
FCS_COP.1/Hash384	
FCS_COP.1/KeyedHash160	
FCS_COP.1/KeyedHash256	
FCS_COP.1/KeyedHash384	
FTA_SSL.3	For remote session
FTA_SSL.4	Precision of the user U.ROLE_GW_OPERATOR
FTP_ITC.1	
FTP_TRP.1	

Table 9: Refined SFR

DUAL USE CONTROLLED

Ce document est propriété du Groupe THALES et ne peut être communiqué à l'extérieur du Groupe qu'avec l'accord de THALES SIX GTS France. *This document is THALES Group's property and must not be communicated outside the Group without the agreement of THALES SIX GTS France.* © THALES 2019-2024 – Tous droits réservés - © THALES 2019-2024 – copyrights

3.2. C PP CONFORMANCE CLAIM

This security target is based on (but not conformant to) collaborative Protection Profile for Network Devices [c_PP]. Threats, Organizational Security Policies and Security Objective depicted in [c_PP] are all drawn to this ST.

Here is the list of the extended Security Functional Requirement part with the adaptation:

Object Name	Comment
FAU_STG_EXT.1	
FAU_STG_EXT.2/LocSpace	
FCS_RBG_EXT.1	
FCS_CKM_EXT.5/CERTIFICATE	SFR added to cover security objective
FCS_CKM_EXT.5/IKEV2SA	
FCS_CKM_EXT.5/IKEV2CHILDSA	
FIA_X509_EXT.1	
FIA_X509_EXT.2	
FIA_X509_EXT.3	
FCS_IPSEC_EXT.1	
FCS_TLSC_EXT.2	
FCS_TLSS_EXT.2	
FCO_CPC_EXT.1/JOIN	
FCO_CPC_EXT.1/ADMIN	
FIA_PMG_EXT.1	
FIA_UIA_EXT.1	
FIA_UAU_EXT.2	
FTA_SSL_EXT.1	
FPT_SKP_EXT.1	
FPT_TUD_EXT.1	
FPT_APW_EXT.1	
FPT_TST_EXT.1	
FPT_STM_EXT.1	
FPT_SDP_EXT.2	SFR added to cover security objective

Table 10: Extended SFR

Nota: These SFR are inspired from extended SFR proposed in cPP. The numbering used here respects the numbering used for the SFR of this document. For example, FCS_TLSC_EXT.1 is not used here, but the title of SFR FCS_TLSC_EXT.2 remains even if it is the first SFR FCS_TLSC_EXT of the ST.

3.3. PACKAGE CONFORMANCE CLAIM

This security target is conformant to EAL4+ constituted of EAL4 package augmented with ALC_FLR.3.

DUAL USE CONTROLLED

4. SECURITY PROBLEM DEFINITION

The TOE is to be set up between a local network and a remote one, connected to its remote peer on the remote network. It creates a protected channel (IPSec tunnel) for confidentiality, authenticity, integrity and anti-replay between the local and remote networks. The tunnel is used to send (OP.Sending) and receive (OP.Receiving) trusted traffic over an untrusted network. The mutual authentication is performed with X509 certificates previously injected in the TOE (OP.Injection).

The TOE aims to protect all assets which are (typically) placed in the internal network and therefore shall be protected appropriately. The TOE protects the integrity of the software with secure boot and regular self-tests using cryptographic mechanisms. Software delivery is also protected by being ciphered and signed by THALES.

The TOE is intended to be used in a physically protected environment. It is assumed that no unauthorized personnel have physical access to the TOE. Therefore all attacks to the TOE have to be performed over the network connections of the TOE.

The TOE is assumed to operate in an environment where interception of radiation is covered by other environmental measures. The evaluation will therefore not address vulnerabilities caused by emanation from the TOE. Remote administrators and operators of the TOE authenticated with a TLS certificate are considered to be trustworthy.

It is also assumed that administrators are well trained, reducing the risk that they accidentally make security critical administration mistakes.

In order to clarify the nature of the security problem that the TOE is intended to solve, this section describes the following:

- All assets including the protection they required (confidentiality, Integrity or/and Availability),
- All different users,
- Any known or assumed threats to the assets against which specific protection within the TOE or its environment is required,
- Any organizational security policy statements or rules with which the TOE must comply,
- Any assumptions about the security aspects of the environment and/or of the manner in which the TOE is intended to be used.

DUAL USE CONTROLLED

4.1. ASSETS

This section lists sensitive assets. For each of them, it associates a “security needs” attribute indicating what protection the asset needs.

Default values of parameters are specified within the requirement FMT_MSA.3.

4.1.1. Assets protected with the TOE (User Data)

User data are external data protected by the TOE:

- Applicative data are the sensitive data transmitted from a sensitive trusted sub-network to another sensitive trusted sub-network across an untrusted network,
- Red topology information is available from the trusted networks; it consists in IP address of customer, remote administration IP address.

Security needs of such data are: Confidentiality, Authenticity and Integrity.

4.1.2. Assets belonging to the TOE (TSF Data)

TSF data are internal data belonging to the TOE with security needs Confidentiality, Authenticity and Integrity:

- Configuration parameters such as time, gateway range, software version, certificates and cryptographic data
- Master and session cryptographic keys used for VPN IPsec or TLS establishment
- Cryptographic keys, certificates and credentials used for the self-protection of the TOE in all states (in-rest or in-use)
- Security Associations (SAs) and Security Policies (SPs) configured within the TOE

Security Associations are characterized at least by following parameters:

- SPI: unique identifier of the SA
- Protection mode : IPsec_Tunnel using ESP
- Key management mode: negotiated mode (that is use of IKE protocol)
- Certificates and associated Public keys
- Peer IP address: IP address of a remote instance of the TOE
- Lifetime of negotiated keys

Security Policies are characterized at least by following parameters:

- Action
- Source IP address
- Destination IP address
- SA Identifier (link between SP and SA)
- Authorized protocol and ports (for TCP and UDP)

DUAL USE CONTROLLED

- TOE supervision data (TOE state and audit record generated by the TOE).
The format identified is SYSLOG protected with secure protocol (integrity protection) when the events are sent to remote devices
- The applicative software of the TOE
- The operating system of the TOE

TSF data are internal data belonging to the TOE with security needs Confidentiality and Authenticity:

- The users credentials

TSF data are internal data belonging to the TOE with security needs Integrity and Authenticity:

- Self-protection cryptographic keys
- The keys used by the TOE for
 - IPsec private key protection
 - TLS private key protection
- Software and OS

TSF data are internal data belonging to the TOE with security needs Integrity:

- The reliable time base kept within the TOE and used by the TOE.

4.2. USERS, SYSTEM AND SUB-SYSTEM

4.2.1. U.ROLE GW OPERATOR

TOE local operator interacts with the TOE through the CSS_LMG and local interfaces. He can at least:

- Start the TOE,
- Personalize the TOE,
- Manage certificates on the TOE,
- Load the TOE configuration file,
- Check events on the TOE,
- Update the TOE,
- Launch secure erasure.

4.2.2. U.ROLE SYS ADMIN

TOE central administrator interacting with the TOE through the remote management service on SS_MMC.

DUAL USE CONTROLLED

4.2.3. SS IPSEC_GW

Main TOE component composed of Mistral software embedded in Mistral IPsec Gateway appliance.

4.2.4. SS MMC

TOE management center device, it is a device where remote management service is installed and interacts remotely with the TOE.

4.2.5. CSS LMGT

TOE local management device, it interacts with the TOE through the Local Management Interface.

4.2.6. CSS PKI

Public Key Infrastructure device, it is used for certificates generation.

4.2.7. CSS OCSP RESPONDER

External OCSP responder related to CSS_PKI and compliant with RFC 6960 that should be accessible from the red network when the MISTRAL IPsec Gateway is configured in OCSP mode, i.e. when it is expected that the revocation status of certificates is checked online.

4.2.8. CSS DHCP

External DHCP server compliant with RFC 2131 that should be accessible from the red network when the MISTRAL IPsec Gateway is configured with mobility capabilities, and when mobile IPsec endpoints are waiting to dynamically receive their red IP configuration through IKEv2 messages.

DUAL USE CONTROLLED

4.3. ASSUMPTIONS

4.3.1. Securing the TOE

4.3.1.1. A.LIMITED_FUNCTIONALITY

The devices provide networking functionality as their core function and not provide functionality/services that could be deemed as general purpose computing. For example, the devices should not provide computing platform for general purpose applications (unrelated to networking functionality).

4.3.1.2. A.PHYSICAL_PROTECTION

The network device is physically protected in its operational environment and not subject to physical attacks that compromise the security and/or interfere with the device's physical interconnections and correct operation. SS_IPSEC_GW are installed and stored according to the state of the art regarding sensitive security devices and no unauthorized entities are able to interact physically with it. This protection is assumed to be sufficient to protect the device and the data it contains. As a result, there is no requirement on physical tamper protection or other physical attack mitigations. It is not expected to defend the SS_IPSEC_GW against physical access to the device that allows unauthorized entities to extract data, bypass other controls, or otherwise manipulate the device but SS_IPSEC_GW includes a way to detect physical intrusion (seals ...).

4.3.1.3. A.REGULAR_UPDATES

The network device firmware and software is updated by an administrator, remotely or locally, on a regular basis in response to the release of product updates due to known vulnerabilities or software error.

4.3.1.4. A.SENSITIVE_DATA_ERASURE

The sensitive data contained within network device are assumed to be securely erased before any transportation outside protected premises or long storage.

DUAL USE CONTROLLED

4.3.1.5. A.NO_THRU_TRAFFIC_PROTECTION

A standard/generic network device does not provide any assurance regarding the protection of traffic that traverses it. The intent is for the network device to protect data that originates on or is destined to the device itself, to include administrative data and audit data. Traffic that is traversing the network device, destined for another network entity, is not covered by the TOE requirements. This protection will be covered by requirements for particular types of network devices (e.g., firewall).

4.3.1.6. A.PERSISTENT_ASSETS_PROTECTION

The hardware where the TOE is running embed a secure mechanism to protect in confidentiality and integrity persistent no-encrypted assets even when the TOE is off.

4.3.2. Administration

4.3.2.1. A.TRUSTED_ADMINISTRATOR

The **(Refinement) Administrators (U.ROLE_GW_OPERATOR and U.ROLE_SYS_ADMIN)** for the network device are trusted and to act in the best interest of security for the organization. This includes being appropriately trained, following policy, and adhering to guidance documentation. They are trusted to ensure passwords/credentials have sufficient strength and entropy and to lack malicious intent when administering the device. The network device is not expected to be capable of defending against a malicious administrator that actively works to bypass or compromise the security of the device.

4.3.2.2. A.ALARM

Critical security audit data generated and forwarded by the TOE are remotely analyzed and processed after reception when remote administration is activated.

The TOE local operator (U.ROLE_GW_OPERATOR) may analyze and process alarms after their generation.

4.3.2.3. A.POLICIES_CONTINUITY

The system shall make sure that the information security policies of the two networks interconnected through the TOE are consistent between each other.

4.3.2.4. A.ADMINISTRATION_NETWORK

The administration network is a trusted network, dedicated to administration devices and isolated from other networks by boundary devices.

DUAL USE CONTROLLED

4.3.2.5. A.ADMIN_CREDENTIALS_SECURE

The administrator's credentials (refinement: password and private key) used to access the network device are protected by the platform on which they reside.

Organizational security procedures are established and known by local and remote administrators, in order to protect all administrator's credentials, for local and remote management of the TOE.

4.3.2.6. A.BIOS_PASSWORD

A unique password is set in factory to prevent from further modification of the BIOS configuration of the platform embedding the TOE. This password is different for each TOE-platform instance and protected with enforced access control and cryptographic means in order to protect it from disclosure.

This BIOS password is never delivered to end users, remote and local administrators (ROLE_SYS_ADMIN and ROLE_GW_OPERATOR) included.

4.3.3. Assumptions about management devices

4.3.3.1. A.SECURED_MANAGEMENT_DEVICES

Administration devices (the TOE management center device SS_MMC, the TOE local management device CSS_LMGT, the Public Key Infrastructure device CSS_PKI, the device delivering TOE software update, the OSCP responder CSS_OSCP_RESPONDER device, the DHCP server CSS_DHCP device etc) are properly and securely configured, according the sensitivity of assets they handle and generate events on each application access and application configuration operation

These devices are regularly updated. For the SS_MMC in particular, an authorized administrator is in charge to update the software with deliveries provided by ROLE_PROVIDER.

4.3.3.2. A.ACCESS_CONTROL_MANAGEMENT_DEVICES

The access to administration devices (the TOE management center device SS_MMC, the TOE local management device CSS_LMGT, the Public Key Infrastructure device CSS_PKI, the device delivering TOE software update, which belongs to SS_SW_DELIVERY etc) is controlled and that these devices are managed by authorized administrator only.

The overall solution shall allow individual accounting. It can be physical (e.g. physical access restriction to the device hosting the software) and/or logical (e.g. user authentication by the operating system).

4.3.3.3. A.PHYSICAL_ENV_MANAGEMENT_DEVICES

Physical security of the administration devices (the TOE management center device SS_MMC, the TOE local management device CSS_LMGT, the Public Key Infrastructure device CSS_PKI, the device delivering TOE software update, which belongs to SS_SW_DELIVERY etc) is commensurate with the value of the data concerning the TOE they contain and is provided by the environment.

DUAL USE CONTROLLED

4.3.3.4. A.AUDIT

The auditor regularly reviews audit events generated by the TOE.

The memory units storing audit events are managed so that the auditor does not lose events too quickly.

4.3.3.5. A.SS_MMC_TO_TOE

The TOE management center device (SS_MMC) connects TOE:

- through trusted network (red side) or
- through untrusted network (black side) protected with IPsec VPN managed by Mistral system.

4.3.3.6. A.DATA_TRANSPORTATION

Physical devices used to transport sensitive data are manipulated in secure way during their transportation.

4.3.3.7. A.EXTERNAL_KEYS

When cryptographic keys are imported into the TOE, those keys are:

- Generated by cryptographic mechanisms compliant with ANSSI guidance **[PG-083]**,
- Protected during transfer by a secured container, with a password compliant with ANSSI password rules **[PASSWD_ANSSI]**,
- Deleted from the removable device after injection into the TOE.

DUAL USE CONTROLLED

4.4. ORGANIZATIONAL SECURITY POLICIES (OSP)

4.4.1. Services

4.4.1.1. P.PROVIDED_SERVICES

The TOE shall enforce VPN security policies loaded by the TOE administrators (U.ROLE_GW_OPERATOR and U.ROLE_SYS_ADMIN).

It shall provide all related security services necessary to perform protections specified in these policies:

- datagram filtering,
- confidentiality protection of applicative data,
- integrity and authenticity protection of applicative data,
- protection against replay of applicative data,
- confidentiality protection of red topologic data on the untrusted network

4.4.1.2. P.AUDIT

The TOE shall record events concerning security functions and provide the possibility to send the records to remote center. Some of events are considered as alarm when an external action is required.

4.4.1.3. P.SUPERVISION

The TOE shall enable U.ROLE_SYS_ADMIN to review the operational status of the TOE and the VPN connections state.

4.4.2. Miscellaneous

4.4.2.1. P.CRYPTO_RGS

The TOE shall implement cryptographic mechanisms compliant with ANSSI guidance [PG-083].

4.4.2.2. P.ACCESS_BANNER

The TOE shall display an initial banner describing restrictions of use, legal agreements, or any other appropriate information to which users consent by accessing the Mistral application.

4.4.2.3. P.SA_SP_PROTECTION

The TOE shall protect the integrity and confidentiality of the SP and SA configuration while persistently stored.

DUAL USE CONTROLLED

4.4.2.4. P.TOE_PRODUCTION

The TOE shall be produced following the rules described below:

- Development is located in THALES secured premises (at CHOLET, 110, avenue Maréchal LECLERC and GENEVILLIERS 4, Avenue des Louvresses),
- Development is performed on dedicated network,
- Private keys receive a special care in secured premises ,
- Hardware hosting the TOE is tested (bypass),
- Hardware hosting the private keys is authenticated.

DUAL USE CONTROLLED

Ce document est propriété du Groupe THALES et ne peut être communiqué à l'extérieur du Groupe qu'avec l'accord de THALES SIX GTS France. *This document is THALES Group's property and must not be communicated outside the Group without the agreement of THALES SIX GTS France.* © THALES 2019-2024 – Tous droits réservés - © THALES 2019-2024 – copyrights

4.5. THREATS

The various threat agents are:

- Internal:
 - Internal attackers: entities belonging to the trusted network, they are users known to the TOE and its runtime environment. For these attackers, the only way to access the TOE is logical access via `CSS_RED_NETWORK`, no physical access to the TOE is to be considered.
 - Material and software dysfunctions and failures.
- external:
 - External attackers: entities not belonging to the trusted network, they are unauthorized third party and don't belong to the organisation for which the TOE is used. For these attackers, the only way to access the TOE is logical access via `CS_BLACK_NETWORK`, no physical access to the TOE is to be considered.

Administrators and operators are not considered as threat agents.

4.5.1. T.SECURITY FUNCTIONALITY FAILURE

A component of the network device may fail during start-up or during operations causing a compromise or failure in the security functionality of the network device, leaving the device susceptible to attackers.

4.5.2. T.UNDETECTED ACTIVITY

Threat agents may attempt to access, change, and/or modify the security functionality of the network device without administrator awareness. This could result in the attacker finding an avenue (e.g., misconfiguration, flaw in the product) to compromise the device and the administrator would have no knowledge that the device has been compromised.

4.5.3. T.UNAUTHORIZED ADMINISTRATOR ACCESS

Threat agents may attempt to gain administrator access to the network device by nefarious means such as masquerading as an administrator to the device, masquerading as the device to an administrator, replaying an administrative session (in its entirety, or selected portions), or performing man-in-the-middle attacks, which would provide access to the administrative session, or sessions between network devices. Successfully gaining administrator access allows malicious actions that compromise the security functionality of the device and the network on which it resides.

This could lead either to:

- Modification or retrieval of TOE data (that is TSF Data and User Data stored within the TOE)
- Usurpation of the administrator identity in order to perform administration operations on the TOE (in TOE case, administrators are `U.ROLE_GW_OPERATOR` and `U.ROLE_SYS_ADMIN`)

DUAL USE CONTROLLED

- Modification, insertion or deletion of audit data recorded on the TOE or while they are transmitted by the TOE to the TOE management center (SS_MMC).

4.5.4. T.UPDATE COMPROMISE

Threat agents may attempt to provide a compromised update of the software or firmware which undermines the security functionality of the device. Non-validated updates or updates validated using non-secure or weak cryptography leave the update firmware vulnerable to surreptitious alteration.

4.5.5. T.USER DATA REUSE

User data may be inadvertently sent to a destination not intended by the original sender.

4.5.6. T.MISUSE

Misuse of the TOE due to TOE administrator error (bad configuration design ...) the VPN rules are no longer compliant with system MISTRAL security policy.

4.5.7. T.TIME BASE

A malicious party disturbs or tampers with the TOE time base with the aim of falsifying audit data.

4.5.8. T.RESIDUAL DATA

A malicious party acquires knowledge, by direct access to the TOE, of old value of TOE data (keys, VPN security policies...) during a change of operational context (assignment of the TOE in a new premise, maintenance...). The access can be done after TOE theft.

4.5.9. T.WEAK CRYPTOGRAPHY

Threat agents may exploit weak cryptographic algorithms or perform a cryptographic exhaust against the key space. Poorly chosen encryption algorithms, modes, and key sizes will allow attackers to compromise the algorithms, or brute force exhaust the key space and give them unauthorized access allowing them to read, manipulate and/or control the traffic with minimal effort.

4.5.10. T.UNTRUSTED COMMUNICATION CHANNELS

Threat agents may attempt to target network devices that do not use standardized secure tunneling protocols to protect the critical network traffic. Attackers may take advantage of poorly designed protocols or poor key management to successfully perform man-in-the-middle attacks, replay attacks, etc. Successful attacks will result in loss of confidentiality and integrity of the critical network traffic, and potentially could lead to a compromise of the network device itself.

DUAL USE CONTROLLED

4.5.11. T.WEAK_AUTHENTICATION_ENDPOINTS

Threat agents may take advantage of secure protocols that use weak methods to authenticate the endpoints – e.g., shared password that is guessable or transported as plaintext. The consequences are the same as a poorly designed protocol, the attacker could masquerade as the administrator or another device, and the attacker could insert themselves into the network stream and perform a man-in-the-middle attack. The result is the critical network traffic is exposed and there could be a loss of confidentiality and integrity, and potentially the network device itself could be compromised.

4.5.12. T.PASSWORD_CRACKING

Threat agents may be able to take advantage of weak administrative passwords to gain privileged access to the device. Having privileged access to the device provides the attacker unfettered access to the network traffic, and may allow them to take advantage of any trust relationships with other network devices.

4.5.13. T.SECURITY_FUNCTIONALITY_COMPROMISE

Threat agents may compromise credentials and device data enabling continued access to the network device and its critical data. The compromise of credentials include replacing existing credentials with an attacker's credentials, modifying existing credentials, or obtaining the administrator or device credentials for use by the attacker.

4.5.14. T.TOE_CAPTURE

Threat agents may capture the TOE during transportation, compromise sensitive data and insert traps.

DUAL USE CONTROLLED

5. SECURITY OBJECTIVES

5.1. SECURITY OBJECTIVES FOR THE TOE

5.1.1. Communication protection

5.1.1.1. O.PROTECTED_COMMUNICATIONS

The TOE shall provide protected communication channels on

- Administration interface
- Interfaces connected to the untrusted network (to remote instances of the TOE, IPsec peers or IPsec endpoints).

This protection shall prevent (when it is used) disclosure, modification, insertion and replay of IP datagrams (payload and datagram header).

5.1.1.2. O.POL_FILTERING

The TOE shall provide information flow control policies coming in and out its external interfaces, in particular VPN security policies.

The TOE shall authorize only U.ROLE_GW_OPERATOR and U.ROLE_SYS_ADMIN to modify the filtering configuration of the flow control policies.

5.1.1.3. O.POL_DEFAULT

The TOE shall transmit no network flow if the TOE (SS_IPSEC_GW) is not in ST_OPERATIONAL state or if no VPN SP has been explicitly defined for the given IP addresses (source & destination).

5.1.2. Audit

5.1.2.1. O.AUDIT

The TOE shall generate audit data:

- For all security-relevant operations performed by the TOE or concerning protected communication channels
- For all security-relevant operations (including viewing operations on TOE sensitive assets) performed by U.ROLE_GW_OPERATOR or U.ROLE_SYS_ADMIN.

The TOE shall associate to generated audit data:

- A number (an incremental counter), offering a mean to detect audit data loss.
- A severity, offering a mean to discriminate informational, warning and critical audit data.

DUAL USE CONTROLLED

- A data offering the information if it is an alarm or not.

All the data included in the audit are under control and they are not sensitive data.

The TOE shall transmit continuously stored audit data from SS_IPSEC_GW database to the MMC interface.

After generation, the TOE shall send any ALARM-type audit data to the TOE management center device (SS_MMC).

5.1.2.2. O.TIME_BASE

The TOE shall provide a time base upon which the audit records are based.

5.1.2.3. O.AUDIT_PROTECTION

The TOE shall ensure the integrity of recorded audit data while being forwarded to the TOE management center device (SS_MMC).

The TOE shall ensure the authenticity of recorded audit data forwarded to the TOE management center device (SS_MMC).

5.1.2.4. O.SUPERVISION

The TOE shall authorize the local administrator (U.ROLE_GW_OPERATOR on CSS_LMGT) and the TOE management center device (U.ROLE_SYS_ADMIN on SS_MMC) to supervise operational state and VPN connections state.

5.1.2.5. O.SUPERVISION_IMPACT

The TOE shall ensure that the supervision service does not endanger its sensitive assets.

5.1.3. TOE management

5.1.3.1. O.ROLES

The TOE shall implement access control and security policy enforcement for the following roles:

- Operator, which is the role corresponding to U.ROLE_GW_OPERATOR on CSS_LMGT
- TOE management center device, which is the role corresponding to U.ROLE_SYS_ADMIN on SS_MMC

The TOE shall deny any operation outside both of these roles.

5.1.3.2. O.I&A

The TOE shall require the identification of the TOE management center device before granting it with the TOE management center device access rights. The access rights for TOE on SS_MMC are controlled by profile definition on SS_MMC.

DUAL USE CONTROLLED

The authentication mechanism shall be compliant with ANSSI guidance [RGS_B].

The TOE shall require the authentication of the local user before granting him with the operator access rights.

The TOE shall apply a password management policy compliant with ANSSI password rules [PASSWD_ANSSI].

5.1.3.3. O.AUTHENTICATION_FAILURE

The TOE shall temporarily lock the authentication mechanism after too many unsuccessful authentication attempts.

5.1.3.4. O.DISPLAY_BANNER

The TOE shall send to the local interface (CSS_LMGT) from which the user is connected to the TOE an advisory warning regarding use of the TOE, after its successful identification.

5.1.3.5. O.SESSION_LOCK

The TOE shall lock any local user session after a defined period of inactivity of 3 minutes. The TOE shall provide the local user the reason for the session ending.

5.1.3.6. O.MANAGEMENT

The TOE shall allow modification of following data to only authorized entities which are the local operator (U.ROLE_GW_OPERATOR) or/and to TOE management center device (U.ROLE_SYS_ADMIN).

5.1.3.7. O.VIEW_RULES

The TOE shall authorize viewing of following data to the administrator (U.ROLE_GW_OPERATOR) and/or to the TOE management center device administrator (U.ROLE_SYS_ADMIN) only:

- Security associations and policies
- Configuration parameters such as time data
- Supervision data such as audit event logs
- Time

The TOE shall authorize viewing of following data in plain text to no one.

5.1.3.8. O.TOE_REDUNDANCY

When configured to do so, the TOE shall support hot redundancy in order to ensure the service continuity in case of failure.

DUAL USE CONTROLLED

5.1.4. Data protection

5.1.4.1. O.RESIDUAL_INFORMATION_CLEAR

The TOE shall ensure that any data contained in a protected resource is not available when the resource is deallocated or reallocated.

5.1.4.2. O.DATA_ERASURE

The TOE shall provide a secure data erasure mechanism which cause sensitive data (both persistently stored and in volatile memory) to be made unavailable.

5.1.4.3. O.LOCAL_DATA_PROTECTION

The TOE shall protect at least TSF Data and User Data that are persistently stored from disclosure (in regards to their security needs).

The TOE shall allow detecting modification of at least TSF Data and User Data (in regards to their security needs) that are persistently stored.

5.1.4.4. O.SELF_TEST

The TOE shall run a suite of tests at start-up concerning:

- Logs integrity
- Security functionalities for cryptographic primitives.

The TOE shall also provide the capability to the administrators (U.ROLE_SYS_ADMIN and U.ROLE_GW_OPERATOR) to request such tests during TOE running.

The result of a self-test can be OK or NOK. If all self-tests results are OK, then the TOE stays in ST_OPERATIONAL functional state. Otherwise, at the first self-test failure (that is a result is NOK), the TOE shall go in ST_FAILURE functional state.

5.1.5. Software

5.1.5.1. O.SOFTWARE_UPDATES

When a software update is requested, the TOE shall control the version, integrity and authenticity (done through a digital signature) of the software, before accepting and installing it.

DUAL USE CONTROLLED

5.1.5.2. O.BOOT_CONTROL

When the TOE reboots, it shall control the integrity and authenticity (done through a digital signature) of the software, before launching it.

5.1.6. Cryptography

5.1.6.1. O.CERTIFICATE_INJECTION

When certificate is injected via the Local and Remote Management Interface, the TOE shall control its authenticity before accepting and persistently storing it.

5.1.6.2. O.CRYPTO_PERIOD

The TOE shall manage a crypto-period for any cryptographic DATA used to protect communication channels (refer to O.PROTECTED_COMMUNICATIONS).

For IKEv2 protocols negotiated keys, at the end of a key lifetime, the TOE shall renegotiate the IKEv2 authentication.

For IKEv2 protocols authentication with certificates, at the end of the certificate validity, the TOE shall generate an audit data while it continues to proceed the network traffic until the session lifetime ends. In this case new communication channels for SAs using this certificate are refused until a valid certificate can be used.

5.1.6.3. O.CRYPTO_REGULATION

The TOE shall implement cryptographic mechanisms compliant with ANSSI guidance [PG-083].

5.2. SECURITY OBJECTIVES FOR THE TOE ENVIRONMENT

5.2.1. The management

5.2.1.1. OE.TRUSTED_ADMIN

The environment of the TOE shall provide trusted administrators (U.ROLE_SYS_ADMIN and U.ROLE_GW_OPERATOR) to follow and apply all administrator guidance documentation in a trusted manner.

DUAL USE CONTROLLED

5.2.1.2. OE.AUDIT

The environment of the TOE shall regularly analyze audit events generated by the TOE and react accordingly

The environment of the TOE shall manage the memory units storing audit events so that the TOE management center device does not lose events.

5.2.1.3. OE.ALARM

The environment of the TOE shall analyze and process critical security audit data generated and forwarded by the TOE, by administrators (U.ROLE_SYS_ADMIN and U.ROLE_GW_OPERATOR) immediately after reception.

5.2.1.4. OE.POLICIES_CONTINUITY

The environment of the TOE shall make sure that the information security policies of the two networks interconnected through the TOE are consistent between each other.

5.2.1.5. OE.ADMIN_CREDENTIALS_SECURE

The environment of the TOE shall protect the administrator's credentials (**refinement: private key, password**) used to access the network device, with the platform on which they reside.

The environment of the TOE shall define organizational security procedures, in order to protect all administrator's credentials, for local and remote management of the TOE, and make them applied.

5.2.1.6. OE.BIOS_PASSWORD

The environment of the TOE shall set a unique BIOS password in the equipment embedding the TOE in order to prevent from modification of its BIOS configuration. This password shall be protected with enforced access control and cryptographic means in order to protect it from disclosure.

This BIOS password shall never be delivered to end users, even remote and local administrators (ROLE_SYS_ADMIN and ROLE_GW_OPERATOR).

5.2.1.7. OE.SECURE_PERSISTENT_ASSET

The hardware where the TOE is running shall protect in confidentiality and integrity persistent no-encrypted assets even when it is off.

DUAL USE CONTROLLED

5.2.2. The TOE

5.2.2.1. OE.PHYSICAL

The environment of the TOE shall provide physical security, commensurate with the value of the TOE and the data it contains.

5.2.2.2. OE.NO_GENERAL_PURPOSE

There are no general-purpose computing capabilities (e.g., compilers or user applications) available on the TOE, other than those services necessary for the operation, administration and support of the TOE.

5.2.2.3. OE.TOE_INTEGRITY

The TOE environment shall provide the capability to check the integrity of the TOE hardware and software configuration. Seal applied on the hardware hosting the TOE is an output indication of possible intrusion attempt.

5.2.2.4. OE.TIME_TOE

The environment of the TOE shall locally enter right date and time in the TOE and ensure its reliability.

5.2.2.5. OE.TOE_DATA_ERASURE

The TOE environment shall erase TOE sensitive data before any transportation outside protected premises or long storage.

5.2.2.6. OE.TOE_PRODUCTION

THALES shall produce the TOE following the rules described below:

- Development is located in THALES secured premises (at CHOLET, 110, avenue Maréchal LECLERC and GENEVILLIERS 4, Avenue des Louvresses)
- Development is performed on dedicated environment
- Private keys receive a special care in secured premises
- Hardware hosting the TOE is tested (bypass)
- Hardware hosting the private keys is authenticated

5.2.2.7. OE.NO_THRU_TRAFFIC_PROTECTION

The TOE does not provide any protection of traffic that traverses it. It is assumed that protection of this traffic will be covered by other security and assurance measures in the operational environment.

DUAL USE CONTROLLED

5.2.3. The management devices

Management devices are composed of the following item:

- The TOE management center device (SS_MMC)
- The TOE local management device (CSS_LMGT)
- The Public Key Infrastructure device (CSS_PKI)

5.2.3.1. OE.SECURED_MANAGEMENT_DEVICES

The environment of the TOE shall securely configure and use the management devices listed above.

5.2.3.2. OE.ACCESS_CONTROL_MANAGEMENT_DEVICES

The environment of the TOE shall control the access to management devices and software listed above. The overall solution shall allow individual accounting. It can be physical (e.g. physical access restriction to the device) and/or logical (e.g. user authentication by the operating system or by the software itself).

5.2.3.3. OE.PHYSICAL_ENV_MANAGEMENT_DEVICES

The environment of the TOE shall provide physical security to management devices listed above commensurate with the value of the data concerning the TOE it contains.

The environment provides also physical security to all network devices connected to the SS_MMC and communicating with it, commensurate with the value of the data concerning the TOE they contain.

5.2.3.4. OE.AUDIT_RECORD

The environment of the TOE shall store any audit data received from the TOE as long as law required.

5.2.3.5. OE.LMGT_CONNECTION

The environment of the TOE shall provide a trustworthy link between the TOE and the TOE local management device (CSS_LMGT).

5.2.3.6. OE.SS_MMC_TO_TOE

The environment of the TOE shall provide a way to connect with management center device (SS_MMC):

- Directly through a trusted network (red side)
- Remotely through a protected path (VPN).

DUAL USE CONTROLLED

5.2.3.7. OE.DATA_TRANSPORTATION

The environment of the TOE shall manipulate physical devices used to transport sensitive data in secure way.

5.2.3.8. OE.EXTERNAL_KEYS

When traffic cryptographic keys are imported into the TOE, the environment of the TOE shall:

- Generates keys by cryptographic mechanisms compliant with ANSSI guidance **[PG-083]**,
- Protects them during transfer by a secured container, with a password compliant with ANSSI password rules **[PASSWD_ANSSI]**,
- Deletes them from the removable device after injection into the TOE.

5.2.4. Software updates

5.2.4.1. OE.UPDATES

The environment of the TOE shall update the TOE firmware and software on a regular basis in response to the release of product updates due to known vulnerabilities. Access control ensures that only authorized and authenticated administrators (remote U.ROLE_SYS_ADMIN or local U.ROLE_GW_OPERATOR) have access to the update function.

DUAL USE CONTROLLED

5.3. RATIONALE FOR THE SECURITY OBJECTIVES

5.3.1. Threats

	T.TOE_CAPTURE	T.SECURITY_FUNCTIONALITY_COMPROMISE	T.PASSWORD_CRACKING	T.WEAK_AUTHENTICATION_ENDPOINTS	T.UNTRUSTED_COMMUNICATION_CHANNELS	T.WEAK_CRYPTOGRAPHY	T.RESIDUAL_DATA	T.TIME_BASE	T.MISUSE	T.USER_DATA_REUSE	T.UPDATE_COMPROMISE	T.UNAUTHORIZED_ADMINISTRATOR_ACCESS	T.UNDETECTED_ACTIVITY	T.SECURITY_FUNCTIONALITY_FAILURE
O.AUDIT	X											X	X	
O.AUTHENTICATION_FAILURE			X									X		
O.AUDIT_PROTECTION												X		
O.BOOT_CONTROL	X										X			
O.DISPLAY_BANNER												X		
O.CRYPTO_REGULATION						X						X		
O.DATA_ERASURE							X							
O.I&A			X	X					X			X		
O.LOCAL_DATA_PROTECTION		X					X					X		X
O.MANAGEMENT	X								X			X		X
O.POL_DEFAULT					X					X				
O.POL_FILTERING					X					X		X		
O.PROTECTED_COMMUNICATIONS					X				X			X		
O.SELF_TEST	X													X
O.SESSION_LOCK												X		
O.SOFTWARE_UPDATES											X			
O.SUPERVISION									X					
O.SUPERVISION_IMPACT												X		
O.VIEW_RULES									X			X		
O.RESIDUAL_INFORMATION_CLEAR							X			X				
O.ROLES				X					X			X		
O.TIME_BASE								X						

DUAL USE CONTROLLED

	T.TOE_CAPTURE	T.SECURITY_FUNCTIONALITY_COMPROMISE	T.PASSWORD_CRACKING	T.WEAK_AUTHENTICATION_ENDPOINTS	T.UNTRUSTED_COMMUNICATION_CHANNELS	T.WEAK_CRYPTOGRAPHY	T.RESIDUAL_DATA	T.TIME_BASE	T.MISUSE	T.USER_DATA_REUSE	T.UPDATE_COMPROMISE	T.UNAUTHORIZED_ADMINISTRATOR_ACCESS	T.UNDETECTED_ACTIVITY	T.SECURITY_FUNCTIONALITY_FAILURE
O.CERTIFICATE_INJECTION		X												
O.TOE_REDUNDANCY													X	
OE.TRUSTED_ADMIN												X		
OE.ALARM												X		
OE.TOE_INTEGRITY												X	X	
OE.TIME_TOE								X						
OE.TOE_DATA_ERASURE							X							X
OE.LMGT_CONNECTION					X							X		
OE.SS_MMC_TO_TOE					X							X		
OE.SECURED_MANAGEMENT_DEVICES				X					X			X		
OE.ACCESS_CONTROL_MANAGEMENT_DEVICES		X		X								X		X
OE.PHYSICAL_ENV_MANAGEMENT_DEVICES				X								X		
OE.DATA_TRANSPORTATION		X												X
OE.ADMIN_CREDENTIALS_SECURE		X										X		
OE.UPDATES											X			

Table 11: Threat coverage

DUAL USE CONTROLLED

5.3.1.1. T.SECURITY_FUNCTIONALITY_FAILURE

This threat is countered by **O.SELF_TEST** because it ensures that cryptographic operations (base of Security Functions) are checked when the TOE starts. **O.POL_DEFAULT** and **OE.TOE_INTEGRITY**, limit the impacts of TSF failure by ensuring that no traffic can be transmitted during TOE reboot and that none can add or replace a component with a malicious or weak one.

O.TOE_REDUNDANCY completes the coverage of this threat by allowing administrators to optionally set TOE redundancy, where the TOE is able to maintain the cluster status.

5.3.1.2. T.UNDETECTED_ACTIVITY

This threat is covered by **O.AUDIT**, which requires the TOE to generate audit for security-relevant operations performed by the TOE or concerning protected communication channels, and for actions performed by users.

5.3.1.3. T.UNAUTHORIZED_ADMINISTRATOR_ACCESS

Regarding the threat concerning modification, it is countered:

- For accessible TSF Data:
 - by **O.MANAGEMENT** which requires that they can be modified by authorized entities only.
 - when persistently stored, by **O.LOCAL_DATA_PROTECTION** which requires that they are protected against disclosure when they are persistently stored and that any attempt to modify this data shall be detected.
- For event logs data:
 - by **O.AUDIT** and **O.AUDIT_PROTECTION** which ensure that audit data modification (enforced by **O.AUDIT_PROTECTION**) and audit data loss (enforced by **O.AUDIT**) can be detected by the receiver, associated to **OE.LMGT_CONNECTION** (for communications to LMGT), **OE.SS_MMC_TO_TOE** and **O.PROTECTED_COMMUNICATIONS** (for communications to SS_MMC).
- For the other data
 - **O.MANAGEMENT** which requires that they can't be modified by anyone
 - when persistently stored, by **O.LOCAL_DATA_PROTECTION** which requires that they are protected against disclosure when they are persistently stored and that any attempt to modify this data shall be detected.

Regarding the threat concerning disclosure, it is countered:

- For SA and SP configuration, by **O.VIEW_RULES** which requires that VPN security policies and their contexts can be viewed by authorized entities only, which are U.ROLE_SYS_ADMIN and U.ROLE_GW_OPERATOR.
- For accessible TSF Data, by **O.VIEW_RULES** which requires that such data can be viewed by authorized entities only, which are U.ROLE_SYS_ADMIN and U.ROLE_GW_OPERATOR.
- For the other data requiring confidentiality, by **O.VIEW_RULES** which requires that they can't be seen by anyone

All those countermeasures rely upon the Identification & Authentication security objectives which are:

DUAL USE CONTROLLED

- **O.I&A** which requires the management center device and U.ROLE_GW_OPERATOR to be authenticated before performing any management functions. Protection of TOE local management communication is ensured through **OE.LMGT_CONNECTION**. **O.AUTHENTICATION_FAILURE** prevents brute force attacks on the authentication mechanism and **O.SESSION_LOCK** prevents theft of user session.
- **O.I&A** and **O.PROTECTED_COMMUNICATIONS** which require the SS_MMC to be identified before performing any management functions and the communication between SS_MMC and the TOE to be a protected communication channel (ensuring authentication and encryption) implemented between the TOE and another instance of the TOE.
- And **O.ROLES** which requires the TOE to distinguish two roles to implement the Identification & Authentication security objective (**O.I&A**): the U.ROLE_GW_OPERATOR and the TOE management center device.

The following objectives also contribute to the threat coverage:

- **O.SUPERVISION_IMPACT** ensures that the TOE supervision service does not question sensitive assets security.
- **O.AUDIT** ensures that operations (viewing, modification) performed on TOE sensitive assets as well as TOE services uses are logged and that critical security events are generated to indicate TOE operational failures. Therefore, they provide the capability to detect and process errors or attacks after an analysis of audit events and security alarms.
- **OE.TOE_INTEGRITY** ensures the integrity check of the TOE hardware and software configuration.
- **O.CRYPTO_REGULATION** ensures that the TOE implements robust cryptographic mechanisms.
- **O.POL_FILTERING** requires filtering of data flow coming into the TOE network interfaces. It hardens attacks exploiting protocol vulnerabilities.
- **O.DISPLAY_BANNER** requires that the TOE sends to the local interface (CSS_LMGT) from which the user is connected to the TOE an advisory warning regarding a wrong use of the TOE.

5.3.1.4. T.UPDATE_COMPROMISE

This threat is countered by:

- **O.SOFTWARE_UPDATES** counters this threat by providing a cryptographic authentication mechanism during updates.
- **O.BOOT_CONTROL** counters this threat by providing a cryptographic authentication mechanism on TOE boots.
- **OE.UPDATES** contributes to the threat's coverage by requiring that software can only be updated by an authorized and authenticated administrator.
- **O.ROLES** restricts access to the update function to authenticated administrators only.

5.3.1.5. T.USER_DATA_REUSE

This threat is countered by **O.RESIDUAL_INFORMATION_CLEAR** to ensure that no unused user data remains in TOE's volatile memory and so can be sent to an unexpected receiver.

DUAL USE CONTROLLED

It is also countered by **O.POL_FILTERING** which requires the TOE to systematically apply the VPN policies when treating user data flow and **O.POL_DEFAULT** which requires that the TOE must be operational before to start traffic transmission.

5.3.1.6. T.MISUSE

This threat is countered by:

- **O.I&A, O.MANAGEMENT, O.ROLES** and **OE.SECURED_MANAGEMENT_DEVICES** which limit the impact of user to authenticated local or remote users with control access and has the opportunity to reconfigure correctly the TOE in case of security weakness detection.
- **O.PROTECTED_COMMUNICATION** which ensure that communications security can't be degraded,
- **O.SUPERVISION** and **O.VIEW_RULES** which ensure that any issue on VPN connection is detected remotely.

5.3.1.7. T.TIME_BASE

This threat is covered by the security objective **O.TIME_BASE** and **OE.TIME_TOE** which ensure the time base reliability.

5.3.1.8. T.RESIDUAL_DATA

This threat is countered by:

- **O.DATA_ERASURE** which requires the TOE to provide a mechanism to securely erase stored data.
- **O.LOCAL_DATA_PROTECTION** which requires the TOE to protect persistently stored sensitive data.
- **O.RESIDUAL_INFORMATION_CLEAR** contributes to the threat's coverage by requiring that no unused user data remains in TOE's volatile memory.
- **OE.TOE_DATA_ERASURE** contributes to the threat's coverage by requiring a complete or partial secure erasure before any transportation outside protected premises.

5.3.1.9. T.WEAK_CRYPTOGRAPHY

This threat is countered by **O.CRYPTO_REGULATION** which requires the TOE to implement cryptographic mechanisms compliant with ANSSI guidance [RGS_B] and [PG-083].

5.3.1.10. T.UNTRUSTED_COMMUNICATION_CHANNELS

This threat is countered by

- **O.PROTECTED_COMMUNICATION** which requires the TOE to protect communication between itself and a remote instance of the TOE or remote SS_MMC.
- **O.POL_FILTERING** which requires the TOE to systematically apply the VPN policies when treating user data flow.
- **O.POL_DEFAULT** which requires that the TOE must be operational before to start traffic transmission and define a default policy to discard flow that doesn't match with any SP.

DUAL USE CONTROLLED

- **OE.LMGT_CONNECTION** which requires the environment to protect communication between the TOE and the TOE local management device (CSS_LMGT)
- **OE.SS_MMC_TO_TOE** which requires the environment to protect communication between TOE and the SS_MMC

5.3.1.11. T.WEAK_AUTHENTICATION_ENDPOINTS

This threat is countered by

- **O.ROLES** which requires the TOE to implement roles to access to the TOE itself.
- **O.I&A** which requires the TOE to implement authentication mechanism compliant with ANSSI guidance [RGS_B] and [PG-083].

The following security objectives for the TOE environment:

- **OE.SECURED_MANAGEMENT_DEVICES** which requires that management devices are securely configured and used,
- **OE.ACCESS_CONTROL_MANAGEMENT_DEVICES** which requires that the management devices access are physically and logically controlled.
- **OE.PHYSICAL_ENV_MANAGEMENT_DEVICES** which requires that the environment provides also physical security to all network devices connected to the SS_MMC and communicating with it, commensurate with the value of the data concerning the TOE they contain, contributes to the threat's coverage by requiring particular protection on devices connected to the TOE.

5.3.1.12. T.PASSWORD_CRACKING

This threat is countered by **O.I&A** which requires the TOE to implement authentication mechanism compliant with ANSSI guidance [RGS_B] annex B3.

O.AUTHENTICATION_FAILURE contributes to the threat coverage by minimizing the number of attempts before locking temporarily the authentication mechanism.

5.3.1.13. T.SECURITY_FUNCTIONALITY_COMPROMISE

This threat is countered by

- **O.LOCAL_DATA_PROTECTION** which requires the TOE to protect TSF DATA as credentials and to detect modification.
- **O.CERTIFICATE_INJECTION** which requires the TOE to control the integrity and the authenticity of the certificates injected.

OE.ACCESS_CONTROL_MANAGEMENT_DEVICE, **OE.PHYSICAL_ENV_MANAGEMENT_DEVICES** and **OE.DATA_TRANSPORTATION** contribute to the threat coverage by ensuring the credentials protection from the source on administration interface.

The threat coverage is completed by **OE.ADMIN_CREDENTIALS_SECURE** which ensures the administrator credentials protection by the platform.

DUAL USE CONTROLLED

5.3.1.14. T.TOE_CAPTURE

This threat is countered by

- **O.LOCAL_DATA_PROTECTION** which requires the TOE to protect TSF DATA as credentials and to detect modification and **O.MANAGEMENT** which limits the rights and access to TSF DATA.
- **O.AUDIT** and **O.SELF_TEST** which participates to analyze traps injections on the TOE.
- **O.BOOT_CONTROL** participates to counter this threat by providing a cryptographic authentication mechanism on TOE boots avoiding boot with trap.

OE.ACCESS_CONTROL_MANAGEMENT_DEVICE contributes to the threat coverage by ensuring the logical access protection.

OE.TOE_DATA_ERASURE contributes to the threat's coverage by requiring a complete or partial secure erasure before any transportation outside protected premises (avoiding disclosure).

OE.DATA_TRANSPORTATION contributes to the threat's coverage by requiring sensitive data to be transported in secure way

DUAL USE CONTROLLED

5.3.2. Organizational Security Policies (OSP)

	P.CRYPTO_RGS	P.PROVIDED_SERVICES	P.AUDIT	P.SUPERVISION	P.ACCESS_BANNER	P.SA_SP_PROTECTION	P.TOE_PRODUCTION
O.CRYPTO_PERIOD	X						
O.PROTECTED_COMMUNICATIONS		X					
O.POL_DEFAULT		X					
O.POL_FILTERING		X					
O.AUDIT			X				
O.SELF_TEST		X					
O.SUPERVISION				X			
O.DISPLAY_BANNER					X		
O.LOCAL_DATA_PROTECTION						X	
O.CRYPTO_REGULATION	X						
OE.AUDIT_RECORD		X	X				
OE.TOE_INTEGRITY		X					
OE.TOE_PRODUCTION							X

Table 12: Organizational Security Policy coverage

5.3.2.1. P.CRYPTO_RGS

The OSP is entirely covered through the implementation of the security objective **O.CRYPTO_REGULATION**, which uses the same words as the OSP.

O.CRYPTO_PERIOD contributes to the coverage of the OSP by requiring the TOE to manage key lifetimes.

DUAL USE CONTROLLED

5.3.2.2. P.PROVIDED_SERVICES

This OSP is covered by **O.PROTECTED_COMMUNICATIONS** which requires that the TOE provides security services.

It is also covered by

- **O.POL_FILTERING** which requires the TOE to systematically apply the VPN policies when treating user data flow.
- **O.POL_DEFAULT** which requires that the TOE must be operational before to start traffic transmission and define a default policy to discard flow that doesn't match with any SP

This OSP is covered by **O.SELF_TEST** and **OE.TOE_INTEGRITY**, because they ensure that security function including cryptographic operations work and that none can add or replace a component with a malicious or weak one.

5.3.2.3. P.AUDIT

This OSP is entirely covered by **O.AUDIT**, because they ensure that operations concerning VPN links are logged and that security critical events are generated to indicate operational failures. **OE.AUDIT_RECORD** completes the cover assuring that SS_MMC stores the events generated by the TOE.

5.3.2.4. P.SUPERVISION

This OSP is entirely covered through the implementation of the security objective **O.SUPERVISION**, which uses the same words as the OSP.

5.3.2.5. P.ACCESS_BANNERS

This OSP is covered through the implementation of the sending to the local interface of a banner describing restrictions of use, legal agreements, or any other appropriate information just after its connection establishment (**O.DISPLAY_BANNER**).

5.3.2.6. P.SA_SP_PROTECTION

This OSP is covered by **O.LOCAL_DATA_PROTECTION** which requires the TOE to be able to detect modification of TSF Data, in particular of SA and SP configuration.

5.3.2.7. P.TOE_PRODUCTION

This OSP is entirely covered through the implementation of the security objective **OE.TOE_PRODUCTION**, which uses the same words as the OSP.

DUAL USE CONTROLLED

5.3.3. Assumptions

	A.LIMITED_FUNCTIONALITY	A.PHYSICAL_PROTECTION	A.REGULAR_UPDATES	A.NO_THRU_TRAFFIC_PROTECTION	A.TRUSTED_ADMINISTRATOR	A.ALARM	A.POLICIES_CONTINUITY	A.ADMIN_CREDENTIALS_SECURE	A.SECURED_MANAGEMENT_DEVICES	A.ACCESS_CONTROL_MANAGEMENT_DEVICES	A.PHYSICAL_ENV_MANAGEMENT_DEVICES	A.SS_MMC_TO_TOE	A.DATA_TRANSPORTATION	A.EXTERNAL_KEYS	A.BIOS_PASSWORD	A.SENSITIVE_DATA_ERASURE	A.PERSISTENT_ASSETS_PROTECTION
OE.NO_GENERAL_PURPOSE	X																
OE.PHYSICAL		X															
OE.TRUSTED_ADMIN					X												
OE.TOE_INTEGRITY.		X															
OE.ALARM						X											
OE.POLICIES_CONTINUITY							X										
OE.SECURED_MANAGEMENT_DEVICES									X								
OE.ACCESS_CONTROL_MANAGEMENT_DEVICES										X							
OE.PHYSICAL_ENV_MANAGEMENT_DEVICES											X						
OE.NO_THRU_TRAFFIC_PROTECTION				X													
OE.UPDATES			X														
OE.ADMIN_CREDENTIALS_SECURE								X									
OE.AUDIT												X					
OE.SS_MMC_TO_TOE												X					
OE.DATA_TRANSPORTATION													X				
OE.EXTERNAL_KEYS														X			
OE.BIOS_PASSWORD															X		
OE.TOE_DATA_ERASURE																X	
OE.SECURE_PERSISTENT_ASSET																	X

Table 13: Assumptions coverage

All assumptions are covered with Security Objectives for the TOE Environment as described above.

DUAL USE CONTROLLED

6. EXTENDED SECURITY REQUIREMENTS

This chapter contains the definitions for the extended requirements that are used in this document.

6.1. SECURITY AUDIT (FAU)

6.1.1. Protected audit event storage (FAU_STG_EXT)

Family Behaviour

This component defines the requirements for the TSF to be able to securely transmit audit data between the TOE and an external IT entity.

Component levelling

FAU_STG_EXT.1 Protected audit event storage requires the TSF to use a trusted channel implementing a secure protocol.

FAU_STG_EXT.2/LocSpace Counting lost audit data requires the TSF to provide information about audit records affected when the audit log becomes full.

Management: FAU_STG_EXT.1, FAU_STG_EXT.2/LocSpace

The following actions could be considered for the management functions in FMT:

a) The TSF shall have the ability to configure the cryptographic functionality.

Audit: FAU_STG_EXT.1, FAU_STG_EXT.2/LocSpace

The following actions should be auditable if FAU_GEN Security audit data generation is included in the PP/ST:

a) No audit necessary.

DUAL USE CONTROLLED

6.1.1.1. FAU_STG_EXT.1 Protected Audit Event Storage

Hierarchical to: No other components.

Dependencies: FAU_GEN.1 Audit data generation, FTP_ITC.1 Inter-TSF Trusted Channel

FAU_STG_EXT.1.1 The TSF shall be able to transmit the generated audit data to an external IT entity using a trusted channel according to FTP_ITC.

FAU_STG_EXT.1.2 The TSF shall be able to store generated audit data on the TOE itself. [selection:

- TOE shall consist of a single standalone component that stores audit data locally
- The TOE shall be a distributed TOE that stores audit data on the following TOE components: [assignment: identification of TOE components],
- The TOE shall be a distributed TOE with storage of audit data provided externally for the following TOE components: [assignment: list of TOE components that do not store audit data locally and the other TOE components to which they transmit their generated audit data].

FAU_STG_EXT.1.3 The TSF shall [selection: drop new audit data, overwrite previous audit records according to the following rule: [assignment: rule for overwriting previous audit records], [assignment: other action]] when the local storage space for audit data is full.

6.1.1.2. FAU_STG_EXT.2/LocSpace Counting lost audit data

Hierarchical to: No other components.

Dependencies: FAU_GEN.1 Audit data generation, FAU_STG_EXT.1 External Audit Trail Storage,

FAU_STG_EXT.2.1/LocSpace The TSF shall provide information about the number of [selection: dropped, overwritten, [assignment: other information]] audit records in the case where the local storage has been filled and the TSF takes one of the actions defined in FAU_STG_EXT.1.3.

DUAL USE CONTROLLED

6.2. CRYPTOGRAPHIC SUPPORT (FCS)

6.2.1. Random Bit Generation (FCS_RBG_EXT)

Family Behaviour

Components in this family address the requirements for random bit/number generation. This is a new family defined for the FCS class.

Component levelling

FCS_RBG_EXT.1 Random Bit Generation requires random bit generation to be performed in accordance with selected standards and seeded by an entropy source.

Management: FCS_RBG_EXT.1

The following actions could be considered for the management functions in FMT:

a) There are no management activities foreseen

Audit: FCS_RBG_EXT.1

The following actions should be auditable if FAU_GEN Security audit data generation is included in the PP/ST:

a) Minimal: failure of the randomization process

FCS_RBG_EXT.1 - RANDOM BIT GENERATION

Hierarchical to: No other components

Dependencies: No other components

FCS_RBG_EXT.1.1 The TSF shall perform all deterministic random bit generation services in accordance with ISO/IEC 18031:2011 using [selection: Hash_DRBG (any), HMAC_DRBG (any), CTR_DRBG (AES)].

FCS_RBG_EXT.1.2 The deterministic RBG shall be seeded by at least one entropy source that accumulates entropy from [selection: [assignment: number of software-based sources] software-based noise source, [assignment: number of hardware-based sources] hardware-based noise source] with a minimum of [selection: 128 bits, 192 bits, 256 bits] of entropy at least equal to the greatest security strength, according to ISO/IEC 18031:2011 Table C.1 "Security Strength Table for Hash Functions", of the keys and hashes that it will generate.

DUAL USE CONTROLLED

6.2.2. Cryptographic Protocols (FCS_IPSEC_EXT, FCS_TLSC_EXT, FCS_TLSS_EXT)

6.2.2.1. FCS_IPSEC_EXT.1 IPsec Protocol

Family Behaviour

Components in this family address the requirements for protecting communications using IPsec.

Component levelling

FCS_IPSEC_EXT.1 IPsec requires that IPsec be implemented as specified.

Management: FCS_IPSEC_EXT.1

The following actions could be considered for the management functions in FMT:

- a) Maintenance of SA lifetime configuration

Audit: FCS_IPSEC_EXT.1

The following actions should be considered for audit if FAU_GEN Security audit data generation is included in the PP/ST:

- a) Decisions to DISCARD, BYPASS, PROTECT network packets processed by the TOE.
- b) Failure to establish an IPsec SA
- c) IPsec SA establishment
- d) IPsec SA termination
- e) Negotiation “down” from an IKEv2 to IKEv1 exchange.

FCS_IPSEC_EXT.1 - INTERNET PROTOCOL SECURITY (IPSEC) COMMUNICATIONS

Hierarchical to: No other components

Dependencies: FCS_CKM.1 Cryptographic Key Generation, FCS_CKM.2 Cryptographic Key Establishment, FCS_COP.1/DataEncryptionGCM or FCS_COP.1/DataEncryptionCTRCryptographic operation (AES Data encryption/decryption), FCS_COP.1/SigGenECDSA Cryptographic operation (Signature Generation and Verification), FCS_COP.1/SigGenECSDSA Cryptographic operation (Signature Generation and Verification), FCS_COP.1/Hash256 Cryptographic operation (Hash Algorithm), FCS_COP.1/KeyedHash256 Cryptographic operation (Keyed Hash Algorithm), FCS_RBG_EXT.1 Random Bit Generation

FCS_IPSEC_EXT.1.1 The TSF shall implement the IPsec architecture as specified in RFC 4301.

FCS_IPSEC_EXT.1.2 The TSF shall have a nominal, final entry in the SPD that matches anything that is otherwise unmatched, and discards it.

FCS_IPSEC_EXT.1.3 The TSF shall implement [selection: tunnel mode, transport mode].

FCS_IPSEC_EXT.1.4 The TSF shall implement the IPsec protocol ESP as defined by RFC 4303 using the cryptographic algorithms

DUAL USE CONTROLLED

- AES-GCM with 256 bits key and 16 bytes ICV (*specified in RFC 4106*)
 - AES-CTR with 256 bits key
- together with secure Hash Algorithm) AUTH_HMAC_SHA2_256_128 (truncated)

FCS_IPSEC_EXT.1.5 The TSF shall implement the protocol: [selection:

- IKEv1, using Main Mode for Phase 1 exchanges, as defined in RFCs 2407, 2408, 2409, RFC 4109, [selection: no other RFCs for extended sequence numbers, RFC 4304 for extended sequence numbers], and [selection: no other RFCs for hash functions, RFC 4868 for hash functions];
- IKEv2 as defined in RFCs 7296 [selection: with no support for NAT traversal, with mandatory support for NAT traversal as specified in RFC 7296, section 2.23], and [selection: no other RFCs for hash functions, RFC 4868 for hash functions]].

FCS_IPSEC_EXT.1.6 The TSF shall ensure the encrypted payload in the IKEv2 protocol uses the cryptographic algorithms:

- AES-GCM with 256 bits key and 16 bytes ICV (*specified in RFC 5282*)
- AES-CTR with 256 bits key and HMAC-SHA256 with 32 bytes Key and 16 bytes MAC

FCS_IPSEC_EXT.1.7 The TSF shall ensure that [selection:

- IKEv1 Phase 1 SA lifetimes can be configured by an Administrator based on [selection:
 - number of bytes;
 - length of time, where the time values can be configured within [assignment: integer range including 24] hours;];
- IKEv2 SA lifetimes can be configured by an Administrator based on [selection:
 - number of bytes;
 - length of time, where the time values can be configured within [assignment: integer range including 24] hours]].

FCS_IPSEC_EXT.1.8 The TSF shall ensure that [selection:

- IKEv1 Phase 2 SA lifetimes can be configured by an Administrator based on [selection:
 - number of bytes;
 - length of time, where the time values can be configured within [assignment: integer range including 8] hours;];
- IKEv2 Child SA lifetimes can be configured by an Administrator based on [selection:
 - number of bytes;
 - length of time, where the time values can be configured within [assignment: integer range including 8] hours;]].

FCS_IPSEC_EXT.1.9 The TSF shall generate the secret value x used in the IKE Diffie-Hellman key exchange (" x " in $x.G \bmod p$) using the random bit generator specified in FCS_RBG_EXT.1, and having a length of at least [assignment: (one or more) number(s) of bits that is at least twice the security strength of the negotiated Diffie-Hellman group] bits.

FCS_IPSEC_EXT.1.10 The TSF shall generate nonces used in [selection: IKEv1, IKEv2] exchanges of length [selection:

- according to the security strength associated with the negotiated Diffie-Hellman group;

DUAL USE CONTROLLED

- at least 128 bits in size and at least half the output size of the negotiated pseudorandom function (PRF) hash;
- 128 bits in size i.e. half the output size of the negotiated pseudorandom function (PRF) hash].

FCS_IPSEC_EXT.1.11 The TSF shall ensure that IKE protocols implement DH Group(s) [selection: 14 (2048-bit MODP), 19 (secp256r1), 20 (384-bit Random ECP), 24 (2048-bit MODP with 256-bit POS), 28 (BrainpoolP256r1)].

FCS_IPSEC_EXT.1.12 The TSF shall ensure that all IKE protocols perform peer authentication using [selection: RSA, ECDSA, ECSDSA] that use X.509v3 certificates that conform to RFC 4945 and [selection: Pre-shared Keys, no other method].

FCS_IPSEC_EXT.1.13 The TSF shall only establish a trusted channel if the presented identifier in the received certificate matches the configured reference identifier, where the presented and reference identifiers are of the following fields and types: [selection: SAN: IP address, SAN: Fully Qualified Domain Name (FQDN), SAN: user FQDN, CN: IP address, CN: Fully Qualified Domain Name (FQDN), CN: user FQDN, Distinguished Name (DN)] and [selection: no other reference identifier type, [assignment: other supported reference identifier types]].

Nota: FCS_IPSEC_EXT.1.4 and 1.6 are a DR profile adaptation.

6.2.2.2. FCS_TLSC_EXT TLS Client Protocol

Family Behaviour

The component in this family addresses the ability for a client to use TLS to protect data between the client and a server using the TLS protocol.

Component levelling

FCS_TLSC_EXT.2 TLS Client requires that the client side of the TLS implementation include mutual authentication.

Management: FCS_TLSC_EXT.2

The following actions could be considered for the management functions in FMT:

- a) There are no management activities foreseen.

Audit: FCS_TLSC_EXT.2

The following actions should be considered for audit if FAU_GEN Security audit data generation is included in the PP/ST:

- a) Failure of TLS session establishment
b) TLS session establishment
c) TLS session termination

DUAL USE CONTROLLED

FCS_TLSC_EXT.2 - TLS CLIENT PROTOCOL WITH AUTHENTICATION

Hierarchical to: No other components

Dependencies: FCS_CKM.1 Cryptographic Key Generation, FCS_CKM.2 Cryptographic Key Establishment, FCS_COP.1/DataEncryptionGCM Cryptographic operation (AES Data encryption/decryption), FCS_COP.1/SigGenECDSA Cryptographic operation (Signature Generation and Verification), FCS_COP.1/Hash384 Cryptographic operation (Hash Algorithm), FCS_COP.1/KeyedHash384 Cryptographic operation (Keyed Hash Algorithm), FCS_RBG_EXT.1 Random Bit Generation

FCS_TLSC_EXT.2.1 The TSF shall implement [selection: TLS 1.2 (RFC 5246), TLS 1.1 (RFC 4346)] and reject all other TLS and SSL versions. The TLS implementation will support the following cipher suites:

- [assignment: list of optional cipher suites and reference to RFC in which each is defined].

FCS_TLSC_EXT.2.2 The TSF shall verify that the presented identifier matches the reference identifier per RFC 6125 section 6.

FCS_TLSC_EXT.2.3 When establishing a trusted channel, by default the TSF shall not establish a trusted channel if the server certificate is invalid. The TSF shall also [selection:

- Not implement any administrator override mechanism
- require administrator authorization to establish the connection if the TSF fails to [selection: match the reference identifier, validate certificate path, validate expiration date, determine the revocation status] of the presented server certificate].

FCS_TLSC_EXT.2.4 The TSF shall [selection: not present the Supported Elliptic Curves Extension, present the Supported Elliptic Curves Extension with the following NIST curves: [selection: secp256r1, secp384r1, secp521r1, braipool256r1, braipool384r1, braipool521r1] and no other curves] in the Client Hello.

FCS_TLSC_EXT.2.5 The TSF shall support mutual authentication using X.509v3 certificates

DUAL USE CONTROLLED

6.2.2.3. FCS_TLSS_EXT TLS Server Protocol

Family Behaviour

The component in this family addresses the ability for a server to use TLS to protect data between a client and the server using the TLS protocol.

Component levelling

FCS_TLSS_EXT.2: TLS Server requires the mutual authentication be included in the TLS implementation.

Management:FCS_TLSS_EXT.2

The following actions could be considered for the management functions in FMT:

- a) There are no management activities foreseen.

Audit: FCS_TLSS_EXT.2

The following actions should be considered for audit if FAU_GEN Security audit data generation is included in the PP/ST:

- a) Failure of TLS session establishment
- b) TLS session establishment
- c) TLS session termination

FCS_TLSS_EXT.2 - TLS SERVER PROTOCOL WITH MUTUAL AUTHENTICATION

Hierarchical to: No other components

Dependencies: FCS_CKM.1 Cryptographic Key Generation, FCS_CKM.2 Cryptographic Key Establishment FCS_COP.1/DataEncryptionGCM Cryptographic operation (AES Data encryption/decryption), FCS_COP.1/SigGenECDSA Cryptographic operation (Signature Generation and Verification), FCS_COP.1/Hash384 Cryptographic operation (Hash Algorithm), FCS_COP.1/KeyedHash384 Cryptographic operation (Keyed Hash Algorithm), FCS_RBG_EXT.1 Random Bit Generation.

FCS_TLSS_EXT.2.1 The TSF shall implement [selection: TLS 1.2 (RFC 5246), TLS 1.1 (RFC 4346)] and reject all other TLS and SSL versions. The TLS implementation will support the following cipher suites:

- [assignment: list of optional cipher suites and reference to RFC in which each is defined].

FCS_TLSS_EXT.2.2 The TSF shall deny connections from clients requesting SSL 2.0, SSL 3.0, TLS 1.0 and [selection: TLS 1.1, TLS 1.2, none].

FCS_TLSS_EXT.2.3 The TSF shall [selection: perform ECDSA key establishment with key size [selection: 256 bits, 384 bits, 512 bits]; generate EC Diffie-Hellman parameters over NIST curves [selection: secp256r1, secp384r1, secp521r1, brainpool256r1, brainpool384r1, brainpool521r1] and no other curves; generate Diffie-Hellman parameters of size [selection: 256 bits, 384 bits, 512 bits]].

DUAL USE CONTROLLED

FCS_TLSS_EXT.2.4 The TSF shall support mutual authentication of TLS clients using X.509v3 certificates.

FCS_TLSS_EXT.2.5 When establishing a trusted channel, by default the TSF shall not establish a trusted channel if the client certificate is invalid. The TSF shall also [selection:

- Not implement any administrator override mechanism
- require administrator authorization to establish the connection if the TSF fails to [selection: match the reference identifier, validate certificate path, validate expiration date, determine the revocation status] of the presented client certificate].

FCS_TLSS_EXT.2.6 The TSF shall not establish a trusted channel if the distinguished name (DN) or Subject Alternative Name (SAN) contained in a certificate does not match the expected identifier for the client.

6.2.3. Cryptographic Key Lifetime (FCS_CKM_EXT.5)

Family Behaviour

Cf. part 2 [CC].

The family FCS_CKM is extended with the new component FCS_CKM_EXT.5 which provides the capability to the TSF to manage and monitor key lifetime.

Component levelling

FCS_CKM_EXT.5 Cryptographic key lifetime, requires specifying and monitoring cryptographic key lifetime.

Management: FCS_CKM_EXT.5

The following actions could be considered for the management functions in FMT:

- a) Managing key lifetime value.

Audit: FCS_CKM_EXT.5

The following actions should be auditable if FAU_GEN Security audit data generation is included in the PP/ST:

- a) Minimal: expiration of a cryptographic key.
- b) Basic: The object attribute(s), and object value(s) excluding any sensitive information (e.g. secret or private keys).

FCS_CKM_EXT.5 KEY CRYPTOPERIOD

Hierarchical to: No other components.

Dependencies: [FCS_CKM.1 Cryptographic key generation or FDP_ITC.1 Import of User Data without Security Attributes or FDP_ITC.2 Import of User Data With Security Attributes], FCS_CKM.4 Cryptographic key destruction, FPT_STM_EXT.1 Reliable time stamps

FCS_CKM_EXT.5.1 The TSF shall manage [selection: *an expiration date and time, a cryptoperiod, other*] for [assignment: *list of cryptographic keys or certificates*].

DUAL USE CONTROLLED

FCS_CKM_EXT.5.2 The TSF shall calculate the [selection: *key(s) lifetime, validity*] from [selection: *key generation, key first use, other*].

FCS_CKM_EXT.5.3 The TSF shall [assignment: *list of actions*] after the [selection: *key(s), certificate(s)*] has(have) expired.

Rationale

This component was defined because part 2 of [CC] does not contain any SFR which allows specifying a lifetime for cryptographic keys. For the TOE described in this ST it was necessary to provide such capability.

6.3. IDENTIFICATION AND AUTHENTICATION (FIA)

6.3.1. Password Management (FIA PMG EXT)

Family Behaviour

The TOE defines the attributes of passwords used by administrative users to ensure that strong passwords and passphrases can be chosen and maintained.

Component levelling

FIA_PMG_EXT.1 Password management requires the TSF to support passwords with varying composition requirements, minimum lengths, maximum lifetime, and similarity constraints.

Management: FIA_PMG_EXT.1

No management functions.

Audit: FIA_PMG_EXT.1

No specific audit requirements.

FIA_PMG_EXT.1 - PASSWORD MANAGEMENT

Hierarchical to: No other components.

Dependencies: No other components.

FIA_PMG_EXT.1.1 The TSF shall provide the following password management capabilities for administrative passwords:

- Passwords shall be able to be composed of any combination of upper and lower case letters, numbers, and the following special characters: [selection: *“!”*, *“@”*, *“#”*, *“\$”*, *“%”*, *“^”*, *“&”*, *“*”*, *“(“*, *“)”*, [assignment: *other characters*]];
- Minimum password length support passwords of 15 characters or greater.
- Password is composed with at least 1 upper case letter, 1 lower case letter, 1 number and 1 special character;

DUAL USE CONTROLLED

6.3.2. User Identification and Authentication (FIA_UIA_EXT)

Family Behaviour

The TSF allows certain specified actions before the non-TOE entity goes through the identification and authentication process.

Component levelling

FIA_UIA_EXT.1 User Identification and Authentication requires Administrators (including remote Administrators) to be identified and authenticated by the TOE, providing assurance for that end of the communication path. It also ensures that every user is identified and authenticated before the TOE performs any mediated functions

Management: FIA_UIA_EXT.1

The following actions could be considered for the management functions in FMT:

- a) Ability to configure the list of TOE services available before an entity is identified and authenticated

Audit: FIA_UIA_EXT.N

The following actions should be auditable if FAU_GEN Security audit data generation is included in the PP/ST:

- a) All use of the identification and authentication mechanism
- b) Provided user identity, origin of the attempt (e.g. IP address)

FIA_UIA_EXT.1 - USER IDENTIFICATION AND AUTHENTICATION

Hierarchical to: No other components.

Dependencies: FTA_TAB.1 Default TOE Access Banners,

FIA_UIA_EXT.1.1 The TSF shall allow the following actions prior to requiring the non-TOE entity to initiate the authentication process:

- [selection: no other actions, automated generation of cryptographic keys, [assignment: list of services, actions performed by the TSF in response to non-TOE requests]].

FIA_UIA_EXT.1.2 The TSF shall require each administrative user to be successfully identified and authenticated before allowing any other TSF-mediated actions on behalf of that administrative user.

DUAL USE CONTROLLED

6.3.3. User authentication (FIA_UAU_EXT)

Family Behaviour

Provides for a locally based administrative user authentication mechanism

Component levelling

FIA_UAU_EXT.2 The password-based authentication mechanism provides administrative users a locally based authentication mechanism.

Management: FIA_UAU_EXT.2

The following actions could be considered for the management functions in FMT:

a) None

Audit: FIA_UAU_EXT.2

The following actions should be auditable if FAU_GEN Security audit data generation is included in the PP/ST:

a) Minimal: All use of the authentication mechanism

FIA_UAU_EXT.2 - PASSWORD-BASED AUTHENTICATION MECHANISM

Hierarchical to: No other components.

Dependencies: No other components.

FIA_UAU_EXT.2.1 The TSF shall provide a local password-based authentication mechanism, [selection: [assignment: other authentication mechanism(s)], no other authentication mechanism] to perform local administrative user authentication.

DUAL USE CONTROLLED

6.3.4. Authentication using X.509 certificates (FIA_X509_EXT)

Family Behaviour

This family defines the behaviour, management, and use of X.509 certificates for functions to be performed by the TSF. Components in this family require validation of certificates according to a specified set of rules, use of certificates for authentication for protocols and integrity verification, and the generation of certificate requests.

Component levelling

FIA_X509_EXT.1 X509 Certificate Validation, requires the TSF to check and validate certificates in accordance with the RFCs and rules specified in the component.

FIA_X509_EXT.2 X509 Certificate Authentication, requires the TSF to use certificates to authenticate peers in protocols that support certificates, as well as for integrity verification and potentially other functions that require certificates.

FIA_X509_EXT.3 X509 Certificate Requests, requires the TSF to be able to generate Certificate Request Messages and validate responses.

Management: FIA_X509_EXT.1, FIA_X509_EXT.2, FIA_X509_EXT.3

The following actions could be considered for the management functions in FMT:

- a) Remove imported X.509v3 certificates
- b) Approve import and removal of X.509v3 certificates
- c) Initiate certificate requests

Audit: FIA_X509_EXT.1, FIA_X509_EXT.2, FIA_X509_EXT.3

The following actions should be auditable if FAU_GEN Security audit data generation is included in the PP/ST:

- a) Minimal: No specific audit requirements are specified.

FIA_X509_EXT.1 - X.509 CERTIFICATE VALIDATION

Hierarchical to: No other components

Dependencies: FIA_X509_EXT.2 X.509 Certificate Authentication,

FIA_X509_EXT.1.1 The TSF shall validate certificates in accordance with the following rules:

- RFC 5280 certificate validation and certification path validation supporting a minimum path length of three certificates.
- The certification path must terminate with a trusted CA certificate designated as a trust anchor.
- The TSF shall validate a certification path by ensuring that all CA certificates in the certification path contain the basicConstraints extension with the CA flag set to TRUE.

DUAL USE CONTROLLED

- The TSF shall validate the revocation status of the certificate using [selection: the Online Certificate Status Protocol (OCSP) as specified in RFC 6960, a Certificate Revocation List (CRL) as specified in RFC 5280 Section 6.3, Certificate Revocation List (CRL) as specified in RFC 5759 Section 5, no revocation method]
- The TSF shall validate the extendedKeyUsage field according to the following rules: [assignment: rules that govern contents of the extendedKeyUsage field that need to be verified].
- The TSF shall validate the Certificates presented for IPsec Authentication shall have the algorithm id ECDSA-SHA256 with :
 - Secp256r1 as curve associated or
 - Brainpool256r1 as curve associated

FIA_X509_EXT.1.2 The TSF shall only treat a certificate as a CA certificate if the basicConstraints extension is present and the CA flag is set to TRUE.

FIA_X509_EXT.2 - X.509 CERTIFICATE AUTHENTICATION

Hierarchical to: No other components

Dependencies: FIA_X509_EXT.1 X.509 Certificate Validation

FIA_X509_EXT.2.1 The TSF shall use X.509v3 certificates as defined by RFC 5280 to support authentication for [selection: DTLS, HTTPS, IPsec, TLS, SSH, [assignment: other protocols], no protocols], and [selection: code signing for system software updates, code signing for integrity verification, [assignment: other uses], no additional uses].

FIA_X509_EXT.3 - X.509 CERTIFICATE REQUESTS

Hierarchical to: No other components

Dependencies: FCS_CKM.1 Cryptographic Key Generation, FIA_X509_EXT.1 X.509 Certificate Validation

FIA_X509_EXT.3.1 The TSF shall generate a Certificate Request as specified by RFC 2986 and be able to provide the following information in the request: public key and [selection: device-specific information, Common Name, Organization, Organizational Unit, Country, [assignment: other information]].

FIA_X509_EXT.3.2 The TSF shall validate the chain of certificates from the Root CA upon receiving the CA Certificate Response.

DUAL USE CONTROLLED

6.4. PROTECTION OF THE TSF (FPT)

6.4.1. Protection of TSF Data (FPT_SKP_EXT)

Family Behaviour

Components in this family address the requirements for managing and protecting TSF data, such as cryptographic keys. This is a new family modelled after the FPT_PTD Class.

Component levelling

FPT_SKP_EXT.1 Protection of TSF Data (for reading all symmetric keys), requires preventing symmetric keys from being read by any user or subject. It is the only component of this family.

Management: FPT_SKP_EXT.1

The following actions could be considered for the management functions in FMT:

a) There are no management activities foreseen.

Audit: FPT_SKP_EXT.1

The following actions should be auditable if FAU_GEN Security audit data generation is included in the PP/ST:

a) There are no auditable events foreseen.

FPT_SKP_EXT.1 PROTECTION OF TSF DATA (FOR READING OF ALL SYMMETRIC KEYS)

Hierarchical to: No other components.

Dependencies: No other components.

FPT_SKP_EXT.1.1 The TSF shall prevent reading of all pre-shared keys, symmetric keys, and private keys that is [assignment: list of keys].

DUAL USE CONTROLLED

6.4.2. Protection of Administrator Passwords (FPT_APW_EXT)

Family Behaviour

Components in this family ensure that the TSF will protect plaintext credential data such as passwords from unauthorized disclosure.

Component levelling

FPT_APW_EXT.1 Protection of Administrator passwords requires that the TSF prevent plaintext credential data from being read by any user or subject.

Management: FPT_APW_EXT.1

The following actions could be considered for the management functions in FMT:

a) No management functions.

Audit: FPT_APW_EXT.1

The following actions should be auditable if FAU_GEN Security audit data generation is included in the PP/ST:

a) No audit necessary.

FPT_APW_EXT.1 PROTECTION OF ADMINISTRATOR PASSWORDS

Hierarchical to: No other components

Dependencies: No other components.

FPT_APW_EXT.1.1 The TSF shall store passwords in non-plaintext form.

FPT_APW_EXT.1.2 The TSF shall prevent the reading of plaintext passwords.

DUAL USE CONTROLLED

6.4.3. TSF Self-Test (FPT_TST_EXT)

Family Behaviour

Components in this family address the requirements for self-testing the TSF for selected correct operation.

Component levelling

FPT_TST_EXT.1 TSF Self-Test requires a suite of self-tests to be run during initial start-up in order to demonstrate correct operation of the TSF.

Management: FPT_TST_EXT.1

The following actions could be considered for the management functions in FMT:

- a) No management functions.

Audit: FPT_TST_EXT.1

The following actions should be considered for audit if FAU_GEN Security audit data generation is included in the PP/ST:

- a) Indication that TSF self-test was completed
- b) Failure of self-test

FPT_TST_EXT.1 TSF TESTING

Hierarchical to: No other components.

Dependencies: No other components.

FPT_TST_EXT.1.1 The TSF shall run a suite of the following self-tests [selection: during initial start-up (on power on), periodically during normal operation, at the request of the authorised user, at the conditions [assignment: conditions under which self-tests should occur]] to demonstrate the correct operation of the TSF: [assignment: list of self-tests run by the TSF].

DUAL USE CONTROLLED

6.4.4. Trusted Update (FPT_TUD_EXT)

Family Behaviour

Components in this family address the requirements for updating the TOE firmware and/or software.

Component levelling

FPT_TUD_EXT.1 Trusted Update requires management tools be provided to update the TOE firmware and software, including the ability to verify the updates prior to installation.

Management: FPT_TUD_EXT.1

The following actions could be considered for the management functions in FMT:

- a) Ability to update the TOE and to verify the updates
- b) Ability to update the TOE and to verify the updates using the digital signature capability (FCS_COP.1/SigGenECDSA) and [selection: no other functions, [assignment: other cryptographic functions (or other functions) used to support the update capability]]
- c) Ability to update the TOE, and to verify the updates using [selection: digital signature, published hash, no other mechanism] capability prior to installing those updates

Audit: FPT_TUD_EXT.1

The following actions should be auditable if FAU_GEN Security audit data generation is included in the PP/ST:

- a) Initiation of the update process.
- b) Any failure to verify the integrity of the update

FPT_TUD_EXT.1 TRUSTED UPDATE

Hierarchical to: No other components

Dependencies: FCS_COP.1/SigGenRSA Cryptographic operation (for Cryptographic Signature and Verification), or FCS_COP.1/Hash256 Cryptographic operation (for cryptographic hashing)

FPT_TUD_EXT.1.1 The TSF shall provide [assignment: Administrators] the ability to query the currently executing version of the TOE firmware/software and [selection: the most recently installed version of the TOE firmware/software; no other TOE firmware/software version].

FPT_TUD_EXT.1.2 The TSF shall provide [assignment: Administrators] the ability to manually initiate updates to TOE firmware/software and [selection: support automatic checking for updates, support automatic updates, no other update mechanism].

FPT_TUD_EXT.1.3 The TSF shall provide means to authenticate firmware/software updates to the TOE using a [selection: digital signature mechanism, published hash] prior to installing those updates.

DUAL USE CONTROLLED

6.4.5. Time stamps (FPT_STM_EXT)

Family Behaviour

Components in this family extend FPT_STM requirements by describing the source of time used in timestamps.

Component levelling

FPT_STM_EXT.1 Reliable Time Stamps is hierarchic to FPT_STM.1: it requires that the TSF provide reliable time stamps for TSF and identifies the source of the time used in those timestamps.

Management: FPT_STM_EXT.1

The following actions could be considered for the management functions in FMT:

- a) Management of the time
- b) Administrator setting of the time.

Audit: FTA_SSL_EXT.1

The following actions should be auditable if FAU_GEN Security audit data generation is included in the PP/ST:

- a) Discontinuous changes to the time.

FPT_STM_EXT.1 RELIABLE TIME STAMPS

Hierarchical to: No other components

Dependencies: No other components.

FPT_STM_EXT.1.1 The TSF shall be able to provide reliable time stamps for its own use.

FPT_STM_EXT.1.2 The TSF shall [selection: allow the Security Administrator to set the time, synchronise time with an NTP server].

6.4.6. Stored TSF Data Protection (FPT_SDP_EXT)

Family Behaviour

This family FPT_SDP_EXT (Stored TSF Data Protection) extends the functional class FPT with the capability to protect TSF data in confidentiality and/or integrity while data are stored within containers controlled by the TSF.

Component levelling

FPT_SDP_EXT.2 Stored TSF Data protection capability and action, adds the additional capability to the first component by allowing for actions to be taken as a result of an error detection.

DUAL USE CONTROLLED

Management: FPT_SDP_EXT.2

There are no management activities foreseen.

Audit: FPT_SDP_EXT.2

The following actions should be auditable if FAU_GEN Security audit data generation is included in the PP/ST:

- a) Minimal: Success or failure of integrity check of TSF data.

FPT_SDP_EXT.2 STORED TSF DATA PROTECTION CAPABILITY AND ACTION

Hierarchical to: No other components

Dependencies: No dependencies.

FPT_SDP_EXT.2.1 The TSF shall protect [assignment: list of TSF data] stored in containers controlled by the TSF from [selection: disclosure, none] and shall detect [selection: integrity errors, none] on those data.

FPT_SDP_EXT.2.2 the TSF shall [assignment: action to be taken], upon detection of a data integrity error.

Rationale

This family was defined because part 2 of [CC] does not contain any SFR which requires protection of TSF data stored within the TOE.

DUAL USE CONTROLLED

6.5. TOE Access (FTA)

6.5.1. TSF-initiated Session Locking (FTA_SSL_EXT)

Family Behaviour

Components in this family address the requirements for TSF-initiated and user-initiated locking, unlocking, and termination of interactive sessions.

The extended FTA_SSL_EXT family is based on the FTA_SSL family.

Component levelling

FTA_SSL_EXT.1 TSF-initiated session locking, requires system initiated locking of an interactive session after a specified period of inactivity. It is the only component of this family.

Management: FTA_SSL_EXT.1

The following actions could be considered for the management functions in FMT:

c) Specification of the time of user inactivity after which lock-out occurs for an individual user.

Audit: FTA_SSL_EXT.1

The following actions should be auditable if FAU_GEN Security audit data generation is included in the PP/ST:

b) Any attempts at unlocking an interactive session.

FTA_SSL_EXT.1 TSF-INITIATED SESSION LOCKING

Hierarchical to: No other components

Dependencies: FIA_UIA_EXT.1 User Identification and Authentication

FTA_SSL_EXT.1.1 The TSF shall, for local interactive sessions, [selection:

- lock the session - disable any activity of the Administrator's data access/display devices other than unlocking the session, and requiring that the Administrator reauthenticate to the TSF prior to unlocking the session;
- terminate the session]

after three (3) minutes of user inactivity.

DUAL USE CONTROLLED

6.6. COMMUNICATION (FCO)

6.6.1. Communication Partner Control (FCO CPC EXT)

Family Behaviour

This family is used to define high-level constraints on the ways that partner IT entities communicate. For example, there may be constraints on when communication channels can be used, how they are established, and links to SFRs expressing lower-level security properties of the channels.

Component levelling

FCO_CPC_EXT.1 Component Registration Channel Definition, requires the TSF to support a registration channel for joining together components of a distributed TOE, and to ensure that the availability of this channel is under the control of an Administrator. It also requires statement of the type of channel used (allowing specification of further lower-level security requirements by reference to other SFRs).

Management: FCO_CPC_EXT.1

No separate management functions are required. Note that elements of the SFR already specify certain constraints on communication in order to ensure that the process of forming a distributed TOE is a controlled activity.

Audit: FCO_CPC_EXT.1

The following actions should be auditable if FCO_CPC_EXT.1 is included in the PP/ST:

- a) Enabling communications between a pair of components as in FCO_CPC_EXT.1.1 (including identities of the endpoints).
- b) Disabling communications between a pair of components as in FCO_CPC_EXT.1.3 (including identity of the endpoint that is disabled).

If the required types of channel in FCO_CPC_EXT.1.2 are specified by using other SFRs then the use of the registration channel may be sufficiently covered by the audit requirements on those SFRs: otherwise a separate audit requirement to audit the use of the channel should be identified for FCO_CPC_EXT.1.

FCO_CPC_EXT.1 COMPONENT REGISTRATION CHANNEL DEFINITION

Hierarchical to: No other components.

Dependencies: No other components.

FCO_CPC_EXT.1.1 The TSF shall require a Security Administrator to enable communications between any pair of TOE components before such communication can take place.

FCO_CPC_EXT.1.2 The TSF shall implement a registration process in which components establish and use a communications channel that uses [assignment: list of different types of channel given in the form of a selection] for at least [assignment: type of data for which the channel must be used].

DUAL USE CONTROLLED

FCO_CPC_EXT.1.3 The TSF shall enable a Security Administrator to disable communications between any pair of TOE components.

DUAL USE CONTROLLED

Ce document est propriété du Groupe THALES et ne peut être communiqué à l'extérieur du Groupe qu'avec l'accord de THALES SIX GTS France. *This document is THALES Group's property and must not be communicated outside the Group without the agreement of THALES SIX GTS France.* © THALES 2019-2024 – Tous droits réservés - © THALES 2019-2024 – copyrights

7. SECURITY REQUIREMENTS

7.1. SECURITY FUNCTIONAL REQUIREMENTS

7.1.1. Terms used within SFRs

7.1.1.1. External Entities

Almost any subjects used within SFRs are defined previously in section “Security Problem Definition”.

TOE is able to work with IPv4 only. All IP references in this document refer to IPv4.

External subjects that are not defined in that section are:

- Remote (instance of the) TOE: a remote instance of the TOE with which the TOE communicates;
- IPsec peer: a remote network node that may be a remote instance of the TOE or another IPsec Gateway implementing the IPsec protocol as required by the TOE on interface IF_VPN;
- IPsec endpoint: a remote network endpoint or terminal (laptop, smartphone, etc.) that embeds a VPN IPsec client implementing the IPsec protocol as required by the TOE on interface IF_VPN;
- Network Device: any network device connected to the network which is neither the TOE nor a remote TOE, nor an IPsec peer, nor an IPsec endpoint.

The following internal subjects are also used within SFRs:

- Encrypted Data Interface: TOE interface with the untrusted side (Interface named IF_BLACK_NETWORK)
- Plain Text Data Interface: TOE interface with the trusted side (Interface named IF_RED_NETWORK)
- IP source and destination port: Properties of a network flow between a source endpoint and a destination endpoint
- USB interface: TOE interface for USB devices (Interface named IF_IMPORT_EXPORT)
- Remote management interface: TOE interface for remote management (Interface named IF_REMOTE_MGT)

DUAL USE CONTROLLED

7.1.1.2. Security Attributes

Security attributes used within the SFRs are:

For IPv4 datagrams:

- Datagram protocol type,
- Datagram protocol version,
- Datagram topologic data (i.e. source and destination IPv4 addresses and ports),
- DSCP value,
- Datagram IPsec protection mode.

For the TOE plaintext and cipher interfaces:

- TOE IP addresses.

For cryptographic keys:

- Key lifetime (for symmetric keys only),
- Key value.

For certificate:

- Serial number,
- Issuer,
- Subject,
- Validity,
- Digital signature,
- Public key.

For high-availability cluster:

- Cluster identifier,
- Cluster password,
- Priority in cluster,
- Role in cluster.

DUAL USE CONTROLLED

7.1.1.3. Security Functional Policy

7.1.1.3.1. VPN SFP

The protection offered by IPsec is based on requirements defined by a Security Policy Database (SPD) established and maintained by a user or system administrator. IP packets are selected for one processing action based on IP and next layer header information ("Selectors"), matched against entries in the SPD. Each IP packet is either PROTECTED using IPsec security services or DISCARDED, based on the applicable SPD policies identified by the Selectors.

SS_IPSEC_GW allows only SP with unidirectional flows referencing one or several IPsec SA previously defined

IPsec SP are identified with ipsec_sp_id.

IPsec SP support following selectors:

- Local Address: IP address with a mask,
- Remote Address: IP address with a mask,
- Next Layer Protocol: IP protocol number (TCP, UDP etc.) or wildcard,
- Local Port: Range of ports TCP/UDP or wildcard,
- Remote Port : Range of ports TCP/UDP or wildcard,
- DSCP value: DSCP Value or Range of DSCP values.

IPsec protection is done with:

- Tunnel mode,
- IKEv2,
- ESP over UDP.

TOE shall implement VPN SFP using TLS for remote administration security. Authentication is based on mutual authentication with X509 certificates.

7.1.1.3.2. Access control SFP

The TOE will implement the access control policy access control SFP.

The TSF shall enforce identification and authentication of remote administrators and operators before giving any administrative access to the TOE (i.e. giving any access to TSF data).

The SFP includes data control on data injection.

DUAL USE CONTROLLED

7.1.1.4. SFR presentation

For SFR presentation:

- Assignment are identified as normal text in square brackets
 - o [text]
- Selections are identified as italic text in square brackets
 - o [text]
- Assignment operation inside a selection operation is identified as bold italic text in square brackets
 - o [text, **text**, text]
- Refinement is identified as underlined text for when new text has been inserted into the security functional requirement and strikethrough text when text has been deleted
 - o Original_text, ~~removed_text~~
- Iterations are identified using a slash ("/")
 - o E.g. FCS_COP.1/DataEncryption

7.1.2. Audit

FAU_GEN.1 (REFINED) – AUDIT DATA GENERATION

FAU_GEN.1.1 The TSF shall be able to generate an audit record of the following auditable events:

- a) Start-up and shutdown of the audit functions;
- b) All auditable events for the [*not specified*] level of audit; and
- c) [All administrative actions comprising:
 - Administrative login and logout (name of user account shall be logged if individual user accounts are required for Administrators).
 - Changes to TSF data related to configuration changes (in addition to the information that a change occurred it shall be logged what has been changed).
 - Generating of cryptographic keys (in addition to the action itself a unique key name or key reference shall be logged).
 - Certificate and CRL import or deletion
 - Passwords modification (name of related user account shall be logged).
 - Unsuccessful login attempts
 - Software download and activation
 - Time change
- d) Specifically defined auditable events listed in the table below (by default event is NORMAL-severity, otherwise its severity is mentioned).]

FAU_GEN.1.2 The TSF shall record within each audit record at least the following information:

- a) Date and time of the event, type of event, subject identity (if applicable), and the outcome (success or failure) of the event; and
- b) For each audit event type, based on the auditable event definitions of the functional components included in the cPP/ST Information specified in a defined table,

DUAL USE CONTROLLED

FAU_GEN.2 (REFINED) - USER IDENTITY ASSOCIATION

FAU_GEN.2.1 For audit events resulting from actions of identified users and network devices, the TSF shall be able to associate each auditable event with the identity of the user or the network device that caused the event.

FAU_STG_EXT.1 (EXTENDED) - PROTECTED AUDIT EVENT STORAGE

FAU_STG_EXT.1.1 The TSF shall be able to transmit the generated audit data to an external IT entity using a trusted channel according to FTP_ITC.1.

FAU_STG_EXT.1.2 The TSF shall be able to store generated audit data on the TOE itself.
[TOE shall consist of a single standalone component that stores audit data locally].

FAU_STG_EXT.1.3 The TSF shall [overwrite previous audit records according to the following rule: **replace the audit records backup with the backup of the new audit records file using a rotation mechanism**] when the local storage space for audit data is full.

FAU_STG_EXT.2/LocSpace (EXTENDED) - COUNTING LOST AUDIT DATA

FAU_STG_EXT.2.1/LocSpace The TSF shall provide information about the number of [overwritten] audit records in the case where the local storage has been filled and the TSF takes one of the actions defined in FAU_STG_EXT.1.3.

FAU_STG.3/LocSpace - ACTION IN CASE OF POSSIBLE AUDIT DATA LOSS

FAU_STG.3.1/LocSpace The TSF shall [generate a warning] if the audit trail exceeds [the local audit trail storage capacity].

FPT_STM_EXT.1 (EXTENDED) - RELIABLE TIME STAMPS

FPT_STM_EXT.1.1 The TSF shall be able to provide reliable time stamps for its own use.

FPT_STM_EXT.1.2 The TSF shall [allow the Security Administrator to set the time].

DUAL USE CONTROLLED

7.1.3. Cryptography

7.1.3.1. Key management

FCS_RBG_EXT.1 (EXTENDED) - RANDOM BIT GENERATION

FCS_RBG_EXT.1.1 The TSF shall perform all deterministic random bit generation services in accordance with ISO/IEC 18031:2011 using [CTR_DRBG (AES)];

FCS_RBG_EXT.1.2 The deterministic RBG shall be seeded by at least one entropy source that accumulates entropy from [2] software-based noise source, [2] hardware-based noise source with a minimum of [256 bits] of entropy at least equal to the greatest security strength according to ISO/IEC 18031:2011 Table C.1 "Security Strength Table for Hash Functions", of the keys and hashes that it will generate.

FCS_CKM.1 (REFINED) - CRYPTOGRAPHIC KEY GENERATION

FCS_CKM.1.1 The TSF shall generate asymmetric cryptographic keys in accordance with a specified cryptographic key generation algorithm [ECC schemes using curve secp256r1 or brainpoolP256r1] that meet the following: [French National Cybersecurity Agency DR profile].

FCS_CKM.2 (REFINED) – CRYPTOGRAPHIC KEY ~~DISTRIBUTION~~ NEGOTIATION

FCS_CKM.2.1 The TSF shall perform distribute cryptographic key negotiation in accordance with a specified cryptographic key negotiation method [ECC schemes using curve secp256r1 or brainpoolP256r1] that meets [French National Cybersecurity Agency DR profile].

FCS_CKM.4 - CRYPTOGRAPHIC KEY DESTRUCTION

FCS_CKM.4.1 The TSF shall destroy cryptographic keys in accordance with a specified cryptographic key destruction method [the destruction shall be executed by an overwrite consisting of zeroes] that meets the following: [no standard].

FCS_CKM_EXT.5/CERTIFICATE (EXTENDED) - CERTIFICATE CRYPTO-PERIOD

FCS_CKM_EXT.5.1/Certificate The TSF shall manage [*the validity*] for [the authentication certificates].

FCS_CKM_EXT.5.2/Certificate The TSF shall calculate the [*validity*] from [*certificate first use*].

FCS_CKM_EXT.5.3/Certificate The TSF shall [generate an audit data while it continues to proceed the network traffic until the session lifetime ends] after the [*certificates*] have expired.

FCS_CKM_EXT.5/IKEV2SA (EXTENDED) - IKEV2 IKE SA KEY CRYPTO-PERIOD

FCS_CKM_EXT.5.1/ikeV2SA The TSF shall manage [*a crypto-period*] for [IKEv2 SAs keys].

DUAL USE CONTROLLED

FCS_CKM_EXT.5.2/ikeV2SA The TSF shall calculate the [key lifetime] from [keys generation].

FCS_CKM_EXT.5.3/ikeV2SA The TSF shall [renew the keys by establishing a new IKEv2 SA (i.e. re-authentication)] after the [key] has expired.

FCS_CKM_EXT.5/ikeV2childSA (EXTENDED) - IKEv2 CHILD SAs KEY CRYPTO-PERIOD

FCS_CKM_EXT.5.1/ikeV2childSA The TSF shall manage [a crypto-period] for [IKEv2 Child SAs keys].

FCS_CKM_EXT.5.2/ikeV2childSA The TSF shall calculate the [key lifetime] from [keys generation].

FCS_CKM_EXT.5.3/ikeV2childSA The TSF shall [renew the keys by establishing a new IKEv2 Child SA (i.e. re-authentication)] after the [key] has expired.

7.1.3.2. Cryptographic Operations

FCS_COP.1/DATAENCRYPTIONGCM - CRYPTOGRAPHIC OPERATION (AES DATA ENCRYPTION/DECRYPTION)

FCS_COP.1.1/DataEncryptionGCM The TSF shall perform [encryption/decryption] in accordance with a specified cryptographic algorithm [AES used in GCM mode] and cryptographic key sizes [256 bits], that meet the following: [AES as specified in ISO 18033-3, GCM as specified in ISO 19772].

FCS_COP.1/DATAENCRYPTIONCTR - CRYPTOGRAPHIC OPERATION (AES DATA ENCRYPTION/DECRYPTION)

FCS_COP.1.1/DataEncryptionCTR The TSF shall perform [encryption/decryption] in accordance with a specified cryptographic algorithm [AES used in CTR mode] and cryptographic key sizes [256 bits] that meet the following: [AES as specified in ISO 18033-3, CTR as specified in ISO 10116].

FCS_COP.1/DATAENCRYPTIONCBC - CRYPTOGRAPHIC OPERATION (AES DATA ENCRYPTION/DECRYPTION)

FCS_COP.1.1/DataEncryptionCBC The TSF shall perform [encryption/decryption] in accordance with a specified cryptographic algorithm [AES used in CBC mode] and cryptographic key sizes [256 bits], that meet the following: [AES as specified in ISO 18033-3, CBC as specified in ISO 10116].

FCS_COP.1/DATAENCRYPTIONXTS - CRYPTOGRAPHIC OPERATION (AES DATA ENCRYPTION/DECRYPTION)

FCS_COP.1.1/DataEncryptionXTS The TSF shall perform [encryption/decryption] in accordance with a specified cryptographic algorithm [AES used in XTS mode] and cryptographic key sizes [256 bits] that meet the following: [AES as specified in ISO 18033-3, XTS as specified in IEEE P1619/DM].

DUAL USE CONTROLLED

FCS_COP.1/SIGNGENRSA - CRYPTOGRAPHIC OPERATION (SIGNATURE GENERATION AND VERIFICATION)

FCS_COP.1.1/SignGenRSA The TSF shall perform [cryptographic signature services (generation and verification)] in accordance with a specified cryptographic algorithm: [RSA Digital Signature Algorithm] and cryptographic key sizes [4096 bits] that meet the following: [FIPS PUB 186-4, "Digital Signature Standard (DSS)", Section 5.5, using PKCS #1 v2.1 Signature Schemes RSASSA-PSS and/or RSASSA-PKCS1v1_5; ISO/IEC 9796-2, Digital signature scheme 2 or Digital Signature scheme 3].

FCS_COP.1/SIGNGENECDSA - CRYPTOGRAPHIC OPERATION (SIGNATURE GENERATION AND VERIFICATION)

FCS_COP.1.1/SignGenECDSA The TSF shall perform [cryptographic signature services (generation and verification)] in accordance with a specified cryptographic algorithm: [Elliptic Curve Digital Signature Algorithm] and cryptographic key sizes [256 bits] that meet the following: [ECDSA schemes defined for French National Cybersecurity Agency DR profile and no other curves].

FCS_COP.1/SIGNGENECSDSA - CRYPTOGRAPHIC OPERATION (SIGNATURE GENERATION AND VERIFICATION)

FCS_COP.1.1/SignGenECSDSA The TSF shall perform [cryptographic signature services (generation and verification)] in accordance with a specified cryptographic algorithm: [Elliptic Curve based Schnorr Digital Signature Algorithm] and cryptographic key sizes [256 bits] that meet the following: [ECSDSA schemes defined for French National Cybersecurity Agency DR profile and no other curves].

FCS_COP.1/HASH256 (REFINED) - CRYPTOGRAPHIC OPERATION (HASH ALGORITHM)

FCS_COP.1.1/Hash256 The TSF shall perform [cryptographic hashing services] in accordance with a specified cryptographic algorithm [SHA-256] and cryptographic-key message digest sizes [256 bits] that meet the following: [ISO/IEC 10118-3:2004].

FCS_COP.1/HASH384 (REFINED) - CRYPTOGRAPHIC OPERATION (HASH ALGORITHM)

FCS_COP.1.1/Hash384 The TSF shall perform [cryptographic hashing services] in accordance with a specified cryptographic algorithm [SHA-384] and cryptographic-key message digest sizes [384 bits] that meet the following: [ISO/IEC 10118-3:2004].

FCS_COP.1/KEYEDHASH160 (REFINED) - CRYPTOGRAPHIC OPERATION (KEYED HASH ALGORITHM)

FCS_COP.1.1/KeyedHash160 The TSF shall perform [keyed-hash message authentication] in accordance with a specified cryptographic algorithm [HMAC-SHA-1], and cryptographic key sizes [160 bits] used in HMAC and message digest sizes [160 bits] that meet the following: [ISO/IEC 9797-2:2011, Section 7 "MAC Algorithm 2"].

DUAL USE CONTROLLED

FCS_COP.1/KEYEDHASH256 (REFINED) - CRYPTOGRAPHIC OPERATION (KEYED HASH ALGORITHM)

FCS_COP.1.1/KeyedHash256 The TSF shall perform [keyed-hash message authentication] in accordance with a specified cryptographic algorithm [HMAC-SHA-256], and cryptographic key sizes [256 bits] used in HMAC and message digest sizes [256 bits] that meet the following: [ISO/IEC 9797-2:2011, Section 7 “MAC Algorithm 2”].

FCS_COP.1/KEYEDHASH384 (REFINED) - CRYPTOGRAPHIC OPERATION (KEYED HASH ALGORITHM)

FCS_COP.1.1/KeyedHash384 The TSF shall perform [keyed-hash message authentication] in accordance with a specified cryptographic algorithm [HMAC-SHA-384], and cryptographic key sizes [384 bits] used in HMAC and message digest sizes [384 bits] that meet the following: [ISO/IEC 9797-2:2011, Section 7 “MAC Algorithm 2”].

FCS_COP.1/DATADECRYPTIONP12 - CRYPTOGRAPHIC OPERATION (PKCS#12 DECRYPTION)

FCS_COP.1.1/DataDecryptionP12 The TSF shall perform [decryption of PKCS#12 containers imported by a U.ROLE_GW_OPERATOR from a removable device] in accordance with a specified cryptographic algorithm [AES in CBC mode] and cryptographic key sizes [256 bits], that meet the following: [AES-256-CBC as specified in ISO 18033-3 based on a password entered by U.ROLE_GW_OPERATOR, with PBKDF2 for key derivation].

7.1.4. Communications Protection and Flow Controls

7.1.4.1. Authentication

FIA_X509_EXT.1 (EXTENDED) - X509 CERTIFICATION VALIDATION

FIA_X509_EXT.1.1 The TSF shall validate certificates in accordance with the following rules:

- RFC 5280 certificate validation and certificate path validation supporting a minimum path length of three certificates.
- The certificate path must terminate with a trusted CA certificate designated as a trust anchor.
- The TSF shall validate a certification path by ensuring that all CA certificates in the certification path contain the basicConstraints extension and that the CA flag set to TRUE.
- The TSF shall validate the revocation status of the certificate using *[the Online Certificate Status Protocol (OCSP) as specified in RFC 6960 or a Certificate Revocation List (CRL) as specified in RFC 5759 section 5]*.
- The TSF shall validate the extendedKeyUsage field according to the following rules:
 - [
 - Certificates used for trusted updates and executable code integrity verification shall have the Code Signing purpose (id-kp 3 with OID 1.3.6.1.5.5.7.3.3) in the extendedKeyUsage field.

DUAL USE CONTROLLED

- Server certificates presented for TLS shall have the Server Authentication purpose (id-kp 1 with OID 1.3.6.1.5.5.7.3.1) in the extendedKeyUsage field.
- Client certificates presented for TLS shall have the Client Authentication purpose (id-kp 2 with OID 1.3.6.1.5.5.7.3.2) in the extendedKeyUsage field.]
- The TSF shall validate the Certificates presented for IPsec Authentication have the algorithm id ECDSA-SHA256 with :
 - Secp256r1 as curve associated or
 - Brainpool256r1 as curve associated

FIA_X509_EXT.1.2 The TSF shall only treat a certificate as a CA certificate if the basicConstraints extension is present and the CA flag is set to TRUE.

FIA_X509_EXT.2 (EXTENDED) - X.509 CERTIFICATE AUTHENTICATION

FIA_X509_EXT.2.1 The TSF shall use X.509v3 certificates as defined by RFC 5280 to support authentication for [IPsec, TLS] and [no additional use].

FIA_X509_EXT.3 (EXTENDED) - X.509 CERTIFICATE REQUESTS

FIA_X509_EXT.3.1 The TSF shall generate a Certificate Request as specified by RFC 2986 and be able to provide the following information in the request: public key and [CN, **OrganizationUnit, OrganizationName and CountryName**].

FIA_X509_EXT.3.2 The TSF shall validate the chain of certificates from the trusted CA upon receiving the CA Certificate Response.

7.1.4.2. Communication Protection

7.1.4.2.1. Inter-TOE Communications Protection

7.1.4.2.1.1 IPsec communication

FTP_ITC.1 (REFINED) - INTER-TSF TRUSTED CHANNEL

FTP_ITC.1.1 The TSF shall be capable of using [TLS or IPsec] to provide a trusted communication channel between itself and another IT product authorized IT entities supporting the following capabilities: audit server (TLS) and a remote instance of the TOE (IPsec) that is logically distinct from other communication channels and provides assured identification of its end points and protection of the channel data from modification or disclosure and detection of modification of the channel data.

FTP_ITC.1.2 The TSF shall permit [the TSF or the authorized IT entities] to initiate communication via the trusted channel.

FTP_ITC.1.3 The TSF shall initiate communication via the trusted channel for [VPN service (communication with a remote instance of the TOE using IPsec and audit server using TLS)].

DUAL USE CONTROLLED

FDP_UCT.1 (REFINED) - INTER-TSF BASIC DATA EXCHANGE CONFIDENTIALITY

FDP_UCT.1.1 The TSF shall enforce the [access control SFP and VPN SFP(s)] to [transmit and receive] user data in a manner protected from unauthorized disclosure between itself and a remote instance of the TOE.

FDP_UIT.1 (REFINED) - INTER-TSF DATA EXCHANGE INTEGRITY

FDP_UIT.1.1 The TSF shall enforce the [VPN SFP] to [transmit and receive] user data in a manner protected from [modification, insertion and replay] errors between itself and a remote instance of the TOE.

FDP_UIT.1.2 The TSF shall be able to determine on receipt of user data, whether [modification, insertion and replay] has occurred.

FCS_IPSEC_EXT.1 (EXTENDED) – INTERNET PROTOCOL SECURITY (IPSEC) COMMUNICATIONS

FCS_IPSEC_EXT.1.1 The TSF shall implement the IPsec architecture as defined by RFC 4301

FCS_IPSEC_EXT.1.2 The TSF shall have a nominal, final entry in the SPD that matches anything that is otherwise unmatched, and discards it.

FCS_IPSEC_EXT.1.3 The TSF shall implement [tunnel mode].

FCS_IPSEC_EXT.1.4 The TSF shall implement the IPsec protocol ESP as defined by RFC 4303 using the cryptographic algorithms

- AES-GCM with 256 bits key and 16 bytes ICV (specified in RFC 4106)
- AES-CTR with 256 bits key

together with secure Hash Algorithm) AUTH_HMAC_SHA2_256_128 (truncated)

FCS_IPSEC_EXT.1.5 The TSF shall implement the protocol: [IKEv2 as defined in RFC 7296 with mandatory support for NAT traversal as specified in RFC 7296, section 2.23, and RFC 4868 for hash functions].

FCS_IPSEC_EXT.1.6 The TSF shall ensure the encrypted payload in the IKEv2 protocol uses the cryptographic algorithms:

- AES-GCM with 256 bits key and 16 bytes ICV (specified in RFC 5282)
- AES-CTR with 256 bits key and HMAC-SHA256 with 32 bytes Key and 16 bytes MAC

FCS_IPSEC_EXT.1.7 The TSF shall ensure that [IKEv2 SA lifetimes can be configured by an Administrator based on length of time, where the time values can be configured within 72 hours].

FCS_IPSEC_EXT.1.8 The TSF shall ensure that [IKEv2 Child SA lifetimes can be configured by an Administrator based on length of time, where the time values can be configured within 72 hours].

FCS_IPSEC_EXT.1.9 The TSF shall generate the secret value x used in the IKE Diffie-Hellman key exchange (“x” in $x.G \bmod p$) using the random bit generator specified in FCS_RBG_EXT.1, and having a length of at least [256] bits.

FCS_IPSEC_EXT.1.10 The TSF shall generate nonces used in [IKEv2] exchanges of length [128 bits in size i.e. half the output size of the negotiated pseudorandom function (PRF) hash].

DUAL USE CONTROLLED

- FCS_IPSEC_EXT.1.11** The TSF shall ensure that all IKE protocols implement DH Groups [28 (*BrainpoolP256r1*) and 19 (*secp256r1*)].
- FCS_IPSEC_EXT.1.12** The TSF shall ensure that all IKE protocols perform peer authentication using [*ECDSA* or *ECSDSA*] that use X.509v3 certificates that conform to RFC 4945 and [*no other method*].
- FCS_IPSEC_EXT.1.13** The TSF shall only establish a trusted channel if the presented identifier in the received certificate matches the configured reference identifier, where the presented and reference identifiers are of the following fields and types: [*Distinguished Name (DN)*, **Country Name** and **Organisation Name**].

7.1.4.2.1.2 Cluster communication

The TOE may be part of a cluster of two distributed TOEs in active-passive mode, where it acts as Master or Slave. The cluster is configured by the Administrator, and maintained by each of the TOE through a CARP channel on trusted red side.

FTP_TRP.1/JOIN (REFINED) - TRUSTED PATH

- FTP_TRP.1.1/JOIN** The TSF shall be capable of using CARP to provide a communication path between itself and a joining component users that is logically distinct from other communication paths and provides assured identification of its end points and protection of the communicated data from modification.
- FTP_TRP.1.2/JOIN** The TSF shall permit the joining component to initiate communication via the trusted path.
- FTP_TRP.1.3/JOIN** The TSF shall require the use of the trusted path for joining components to the TSF under environmental constraints identified in user manual.

FCO_CPC_EXT.1/JOIN (EXTENDED) - COMMUNICATION PARTNER CONTROL

- FCO_CPC_EXT.1.1/JOIN** The TSF shall require a Security Administrator to enable communications between any pair of TOE components before such communication can take place.
- FCO_CPC_EXT.1.2/JOIN** The TSF shall implement a registration process in which components establish and use a communications channel that uses: [CARP channel]
- For at least: [
- Cluster identifier
 - Cluster password
 - Priority in cluster
 - Role in cluster]
- FCO_CPC_EXT.1.3/JOIN** The TSF shall enable a Security Administrator to disable communications between any pair of TOE components.

DUAL USE CONTROLLED

7.1.4.2.2. Management Center Communication Protection

The management center of the TOE is performed through a secured communication link based on TLS.

FTP_TRP.1/ADMIN (REFINED) - TRUSTED PATH

- FTP_TRP.1.1/ADMIN** The TSF shall be capable of using TLS to provide a communication path between itself and authorized remote administrators users that is logically distinct from other communication paths and provides assured identification of its end points and protection of the communicated data from [disclosure] and provides detection of modification of the channel data.
- FTP_TRP.1.2/ADMIN** The TSF shall permit remote Administrators to initiate communication via the trusted path.
- FTP_TRP.1.3/ADMIN** The TSF shall require the use of the trusted path for initial administrator authentication and all remote administration actions.

FCS_TLSC_EXT.2 (EXTENDED) - TLS Client Protocol with Authentication

- FCS_TLSC_EXT.2.1** The TSF shall implement *[TLS 1.2 (RFC 5246)]* and reject all other TLS and SSL versions. The TLS implementation will support the following cipher **suites**:
[TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384 (RFC5289)]
- FCS_TLSC_EXT.2.2** The TSF shall verify that the presented identifier matches the reference identifier per RFC 6125 section 6.
- FCS_TLSC_EXT.2.3** When establishing a trusted channel, by default the TSF shall not establish a trusted channel if the server certificate is invalid. The TSF shall also *[Not implement any administrator override mechanism]*
- FCS_TLSC_EXT.2.4** The TSF shall *[present the Supported Elliptic Curves Extension with the following NIST curves: secp256r1 or brainpool256r1 and no other curves]* in the Client Hello.
- FCS_TLSC_EXT.2.5** The TSF shall support mutual authentication using X.509v3 certificates

FCS_TLSS_EXT.2 (EXTENDED) - TLS Server Protocol with mutual authentication

- FCS_TLSS_EXT.2.1** The TSF shall implement *[TLS 1.2 (RFC 5246)]* and reject all other TLS and SSL versions. The TLS implementation will support the following cipher suites:
[TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384 (RFC5289)]
- FCS_TLSS_EXT.2.2** The TSF shall deny connections from clients requesting SSL2.0, SSL 3.0, TLS 1.0, and *[TLS 1.1]*.
- FCS_TLSS_EXT.2.3** The TSF shall *[perform ECDSA key establishment with key size 256 bits]*, generate EC Diffie-Hellman parameters over NIST curves *[secp256r1 or brainpool256r1 and no other curves]*.
- FCS_TLSS_EXT.2.4** The TSF shall support mutual authentication of TLS clients using X.509v3 certificates.
- FCS_TLSS_EXT.2.5** When establishing a trusted channel, by default the TSF shall not establish a trusted channel if the client certificate is invalid. The TSF shall also *[not implement any administrator override mechanism]*

DUAL USE CONTROLLED

FCS_TLSS_EXT.2.6 The TSF shall not establish a trusted channel if the distinguished name (DN) or Subject Alternative Name (SAN) contained in a certificate does not match the expected identifier for the client.

7.1.4.3. Flows Controls

7.1.4.3.1. Communication partner control

FCO_CPC_EXT.1/ADMIN (EXTENDED) - COMMUNICATION PARTNER CONTROL

FCO_CPC_EXT.1.1/ADMIN The TSF shall require a Security Administrator to enable communications between any pair of TOE components before such communication can take place.

FCO_CPC_EXT.1.2/ADMIN The TSF shall implement a registration process in which components establish and use a communications channel that uses: [TLS channel]

For at least: [

- Configuration data including network topology
- Update firmware
- Firmware activation]

FCO_CPC_EXT.1.3/ADMIN The TSF shall enable a Security Administrator to disable communications between any pair of TOE components.

7.1.4.3.2. VPN Policy flow control

FDP_ITC.2/VPN (REFINED) - VPN IMPORT OF USER DATA WITH SECURITY ATTRIBUTES

FDP_ITC.2.1/VPN The TSF shall enforce [the VPN SFP] when importing user data to send to a remote private network or IPsec frame, controlled under the SFP, from outside of the TOE.

FDP_ITC.2.2/VPN The TSF shall use the ~~security-attributes~~ IP protocol and topologic data associated with the imported ~~user-data~~ IP frame.

FDP_ITC.2.3/VPN The TSF shall ensure that the protocol used provides for the unambiguous association between the security attribute and the ~~user-data~~ IP frame received.

FDP_ITC.2.4/VPN The TSF shall ensure that interpretation of the ~~security-attributes~~ IP protocol and topologic data of the imported ~~user-data~~ IP frame is as intended by the source of the ~~user-data~~ IP frame.

FDP_ITC.2.5/VPN The TSF shall enforce the following rules when importing ~~user-data~~ IP frame controlled under the SFP from outside the TOE: [no additional import control rules].

FDP_ETC.2/VPN (REFINED)- VPN EXPORT OF USER DATA WITH SECURITY ATTRIBUTES

FDP_ETC.2.1/VPN The TSF shall enforce the [VPN SFP] when exporting ~~user-data~~ IP frame controlled under the SFP, outside of the TOE.

DUAL USE CONTROLLED

- FDP_ETC.2.2/VPN** The TSF shall export the ~~user data~~ IP datagrams payload and topologic data with the ~~user data's~~ IP datagrams protocol and topologic data associated security attributes.
- FDP_ETC.2.3/VPN** The TSF shall ensure that the ~~security attributes~~ IP datagrams protocol and topologic data, when exported outside the TOE, are unambiguously associated with the exported ~~user data~~ IP datagrams payload and topologic data.
- FDP_ETC.2.4/VPN** The TSF shall enforce the following rules when ~~user data~~ IP datagrams and topologic data are exported from the TOE: [no additional exportation control rules].

FDP_IFC.1/VPN - VPN SUBSET INFORMATION FLOW CONTROL

- FDP_IFC.1.1/VPN** The TSF shall enforce the [VPN SFP with IPsec] on: [
- Subjects:
 - Encrypted Data Interface
 - Plain Text Data Interface
 - IP source and destination ports
 - Information:
 - IP frame
 - Operations:
 - OP.Receiving: Processing of information coming from the Subject according data flow selectors.
 - OP.Sending: Emission of information to the Subject according data flow selectors.
-]

FDP_IFF.1/VPN - VPN SIMPLE SECURITY ATTRIBUTES

- FDP_IFF.1.1/VPN** The TSF shall enforce the [VPN SFP with TLS] based on the following types of subject and information security attributes: [
- Subjects:
 - Encrypted Data Interface
 - Plain Text Data Interface
 - Information:
 - TOE administration flow.
-]
- FDP_IFF.1.2/VPN** The TSF shall permit an information flow between a controlled subject and controlled information via a controlled operation if the following rules hold
- [For the operation OP.Receiving (from Encrypted Data Interface):
 - If the IP datagram contains a SPI
 - The TSF can find an associated SA using the SPI within the IP datagram

DUAL USE CONTROLLED

- The IPsec protection mode contained within the IP datagram is the same as the one specified within the SA
- The IP frame has not been inserted maliciously in the traffic (refer to FDP_UIT.1)
- The IP frame has not been modified (refer to FDP_UIT.1)
- The IP datagram has not been replayed (refer to FDP_UIT.1)
- The TSF can find an associated SP
- For the operation OP.Receiving (from Plaintext Data Interface):
 - The TSF can find an associated SP using the source and destination IP addresses of the IP datagram, and protocol and dscp if used
- For the operation OP.Sending (to Encrypted Data Interface):
 - The datagram has been properly protected according to the SA referred by the associated SA and SP
- For the operation OP.Sending (to Plaintext Data Interface):
 - The datagram has been properly checked and unprotected according to the associated SA and SP]

FDP_IFF.1.3/VPN The TSF shall enforce [none].

FDP_IFF.1.4/VPN The TSF shall explicitly authorize an information flow based on the following rules: [that explicitly authorize information flows].

FDP_IFF.1.5/VPN The TSF shall explicitly deny an information flow based on the following rules [

- When no VPN SP has been explicitly defined for the given IP datagram (no match with the given source and destination IP addresses, port and protocols, dscp value).
- When the given VPN SP specifies that sending IP packets to the destination address and ports (specific to a subnetwork) or protocol is forbidden,
- When an error occurs during the application or verification of security protections
- When datagram is not IP datagram
- When the TOE is not in its final operational state]

7.1.4.3.3. Import of Certificates and Keys

FDP_ITC.2/CRYPTOINJECTION (REFINED)- CERTIFICATE IMPORT OF USER DATA WITH SECURITY ATTRIBUTES

FDP_ITC.2.1/CryptoInjection The TSF shall enforce the [access control SFP] when importing user-data certificate and keys, controlled under the SFP, from outside of the TOE.

FDP_ITC.2.2/CryptoInjection The TSF shall use the security attributes associated with the imported user-data certificate and keys.

FDP_ITC.2.3/CryptoInjection The TSF shall ensure that the protocol used provides for the unambiguous association between the security attributes and the user-data certificate and keys received.

DUAL USE CONTROLLED

FDP_ITC.2.4/CryptoInjection The TSF shall ensure that interpretation of the security attributes of the imported ~~user-data~~ certificate and keys is as intended by the source of the ~~user-data~~ certificate and keys.

FDP_ITC.2.5/CryptoInjection The TSF shall enforce the following rules when importing ~~user-data~~ the certificate and keys controlled under the SFP from outside the TOE: [no additional control rules].

FDP_IFC.1/CRYPTOINJECTION - SECURITY DATA INJECTION SUBSET INFORMATION FLOW CONTROL

FDP_IFC.1.1/CryptoInjection The TSF shall enforce the [access control SFP] on [:

- Subjects:
 - USB Interface
 - Remote management interface (only for Certificates)
- Information:
 - Certificates
 - Key container, optionally
- Operations:
 - OP.Injection: Processing of information coming from the Subject]

FDP_IFF.1/CRYPTOINJECTION - SECURITY DATA INJECTION SIMPLE SECURITY ATTRIBUTES

FDP_IFF.1.1/CryptoInjection The TSF shall enforce the [access control SFP] based on the following types of subject and information security attributes: [

- Subjects and their security attributes:
 - USB Interface
 - Remote management interface
- Information and their security attributes:
 - Certificates: Serial number, signature, issuer, validity, subject, subject public key info, unique identifiers issuer & subjects, key usage
 - If key container: container password]

FDP_IFF.1.2/CryptoInjection The TSF shall permit an information flow between a controlled subject and controlled information via a controlled operation if the following rules hold: [

For the operation OP.Injection (from Encrypted Data Interface):

- The certificate and the corresponding security attributes are consistent

For the operation OP.Injection (from Plaintext Data Interface):

- The certificate and the corresponding security attributes are consistent

For the operation OP.Injection (from USB Interface):

- U.ROLE_GW_OPERATOR is successfully authenticated for local injection

DUAL USE CONTROLLED

- The certificate and the corresponding security attributes are consistent
- If key container: the password is required and correct

]

FDP_IFF.1.3/CryptoInjection The TSF shall enforce [none].

FDP_IFF.1.4/CryptoInjection The TSF shall explicitly authorize an information flow based on the following rules: [none].

FDP_IFF.1.5/CryptoInjection The TSF shall explicitly deny an information flow based on the following rules: [none].

FPT_TDC.1/CRYPTOINJECTION - INTER-TSF BASIC TSF DATA CONSISTENCY

FPT_TDC.1.1/CryptoInjection The TSF shall provide the capability to consistently interpret [certificate, CRL or key container] when shared between the TSF and another trusted IT product.

FPT_TDC.1.2/CryptoInjection The TSF shall use [common certificates, CRLs and key container standards] when interpreting the TSF data from another trusted IT product.

FPT_TDC.1/VPN - INTER-TSF BASIC TSF DATA CONSISTENCY

FPT_TDC.1.1/VPN The TSF shall provide the capability to consistently interpret [the IKE parameters] when shared between the TSF and another trusted IT product.

FPT_TDC.1.2/VPN The TSF shall use [X509 certification validation rules] when interpreting the TSF data from another trusted IT product.

7.1.4.3.4. TSF Data Default Values

FMT_MSA.3 (REFINED) - STATIC ATTRIBUTE INITIALIZATION

FMT_MSA.3.1 The TSF shall enforce the [VPN SFP] to provide [*restrictive*] default values for security attributes that are used to enforce the SFP that is:

- Protection mode: IPSec Tunnel
- Key management mode: IKEv2
- Lifetime of IKE SAs keys: 86400 seconds (24 hours)
- Lifetime of IKE Child SAs keys: 14400 seconds (4 hours)
- Perfect Secrecy (PFS) mode (for IKE protocol): activated
- List of authorized TOE Management Center Devices (SS MMC) IP addresses: 0.0.0.0 / none
- Connection mode: Initiator-responder

FMT_MSA.3.2 The TSF shall allow [U.ROLE_GW_OPERATOR and U.ROLE_SYS_ADMIN] to specify alternative initial values to override the default values when an object or information is created.

DUAL USE CONTROLLED

7.1.5. Users and Devices

7.1.5.1. Roles

FMT_SMR.2 – RESTRICTION ON SECURITY ROLES

FMT_SMR.2.1 The TSF shall maintain the role: [

- Authorised local Administrator (corresponding to a human user U.ROLE_GW_OPERATOR))
- Authorised TOE Management Center Device (corresponding to U.ROLE_SYS_ADMIN)]

FMT_SMR.2.2 The TSF shall be able to associate users with roles.

FMT_SMR.2.3 The TSF shall ensure that the conditions [the operator role shall be able to administer the TOE locally and the Administrator role shall be able to administer the TOE remotely] are satisfied

7.1.5.2. Identification and Authentication

7.1.5.2.1. TOE Management Center Device

FIA_UID.2 (REFINED) – SS_MMC IDENTIFICATION BEFORE ANY ACTION

FIA_UID.2.1 The TSF shall require each user TOE Management Center Device to be successfully identified before allowing any other TSF-mediated actions on behalf of that user TOE Management Center Device.

7.1.5.2.2. Users

FIA_UIA_EXT.1 (EXTENDED) - USER IDENTIFICATION AND AUTHENTICATION

FIA_UIA_EXT.1.1 The TSF shall allow the following actions prior to requiring the non-TOE entity to initiate the authentication process: [

- *automated generation of cryptographic keys*
- **TOE Start-up**
- **TOE Shutdown**
- **Secure erasure**
- **Enter logging password of the local account]**

FIA_UIA_EXT.1.2 The TSF shall require each administrative user to be successfully identified and authenticated before allowing any other TSF-mediated actions on behalf of that administrative user.

DUAL USE CONTROLLED

FIA_UAU_EXT.2 (EXTENDED) - PASSWORD-BASED AUTHENTICATION MECHANISM

FIA_UAU_EXT.2.1 The TSF shall provide a local password-based authentication mechanism and *[no other authentication mechanism]* to perform local administrative user authentication.

FIA_UAU.6 (REFINED) - RE-AUTHENTICATING

FIA_UAU.6.1 The TSF shall re-authenticate the user U.ROLE GW_OPERATOR under the conditions [when he changes his password or when the initial session is expired].

FIA_UAU.7 (REFINED) - PROTECTED AUTHENTICATION FEEDBACK

FIA_UAU.7.1 The TSF shall provide only [obscured feedback] to the user U.ROLE GW_OPERATOR while the authentication is in progress at the local console.

FIA_AFL.1 - AUTHENTICATION FAILURE MANAGEMENT

FIA_AFL.1.1 The TSF shall detect when *[an Administrator configurable positive integer within at most ten (10)]* unsuccessful successive authentication attempts occur related to [Administrators attempting to authenticate remotely].

FIA_AFL.1.2 When the defined number of unsuccessful authentication attempts has been *[met]*, the TSF shall: [prevent the offending Administrator from successfully authenticating until a defined time period has elapsed (at least 60 sec.)].

FIA_PMG_EXT.1 (EXTENDED) - PASSWORD MANAGEMENT

FIA_PMG_EXT.1.1 The TSF shall provide a password management capabilities for administrative password.

7.1.5.3. Access control

FDP_ACC.1 – SUBSET ACCESS CONTROL

FDP_ACC.1.1 The TSF shall enforce the [access control policy] on [BIOS access is controlled by a BIOS password, local management interface is controlled by a local administrator password].

FDP_ACF.1 – SECURITY ATTRIBUTE BASED ACCESS CONTROL

FDP_ACF.1.1 The TSF shall enforce the [access control policy] to objects based on the following: [BIOS password is required to modify BIOS parameters, local administrator password is required to enter the local management interface].

FDP_ACF.1.2 The TSF shall enforce the following rules to determine if an operation among controlled subjects and controlled objects is allowed: [none].

FDP_ACF.1.3 The TSF shall explicitly authorise access of subjects to objects based on the following additional rules: [none].

DUAL USE CONTROLLED

FDP_ACF.1.4 The TSF shall explicitly deny access of subjects to objects based on the following additional rules: [none].

7.1.5.4. Sessions management

FTA_SSL_EXT.1 (EXTENDED) - TSF-INITIATED SESSION LOCKING

FTA_SSL_EXT.1.1 The TSF shall, for local interactive session [*terminate the session*] after three (3) minutes of user inactivity.

FTA_SSL.3 (REFINED) - TSF-INITIATED TERMINATION

FTA_SSL.3.1 The TSF shall terminate a remote interactive session after a [Security Administrator time interval of session inactivity].

FTA_SSL.4 (REFINED) - USER-INITIATED TERMINATION

FTA_SSL.4.1 The TSF shall allow user U.ROLE_GW_OPERATOR or remote Administrator -initiated termination of the user U.ROLE_GW_OPERATOR's or Administrator's own interactive session.

FTA_TAB.1 - DEFAULT TOE ACCESS BANNERS

FTA_TAB.1.1 Before establishing a user session, the TSF shall display an advisory warning message regarding unauthorized use of the TOE.

7.1.6. TSF Management

FMT_SMF.1 - SPECIFICATION OF MANAGEMENT FUNCTIONS

FMT_SMF.1.1 The TSF shall be capable of performing the following management functions: [

- Ability to administer the TOE locally and remotely
- Ability to update the TOE, and to verify the updates using digital signature capability prior to installing those updates
- Ability to start and stop services
- Ability to configure the cryptographic functionality]

FMT_MOF.1/AUTOUPDATE - MANAGEMENT OF SECURITY FUNCTIONS BEHAVIOUR

FMT_MOF.1.1/AutoUpdate The TSF shall restrict the ability to [*enable*] the functions [automatic update] to [Administrators (U.ROLE_SYS_ADMIN and U.ROLE_GW_OPERATOR)].

DUAL USE CONTROLLED

FMT_MOF.1/FUNCTIONS - MANAGEMENT OF SECURITY FUNCTIONS BEHAVIOUR

FMT_MOF.1.1/Functions The TSF shall restrict the ability to [*modify*] the functions [transmission of audit data to an external IT entity] to [Administrators (U.ROLE_SYS_ADMIN and U.ROLE_GW_OPERATOR)].

FPT_SKP_EXT.1 (EXTENDED) - PROTECTION OF TSF DATA (FOR READING OF SENSITIVE KEYS)

FPT_SKP_EXT.1.1 The TSF shall prevent reading of all pre-shared keys, symmetric keys and private keys. T

FMT_MTD.1 - MANAGEMENT OF TSF DATA (CONFIGURATION MODIFICATION)

FMT_MTD.1.1 The TSF shall restrict the ability to [*query and modify*] the [TSF data as described in § 5.1.3.7 (query) and § 5.1.3.6 (modify)] to [the authorized identified roles].

FPT_TUD_EXT.1 (EXTENDED) - TRUSTED UPDATE

FPT_TUD_EXT.1.1 The TSF shall provide [U.ROLE_GW_OPERATOR and TOE Management Center Device] the ability to query the currently executing version of the TOE firmware/software and [*the most recently installed version of the TOE firmware/software*].

FPT_TUD_EXT.1.2 The TSF shall provide [U.ROLE_GW_OPERATOR and TOE Management Center Device] the ability to initiate updates to TOE firmware/software and [*no other update mechanism*].

FPT_TUD_EXT.1.3 The TSF shall provide a means to authenticate firmware/software updates to the TOE using a [*digital signature mechanism*] prior to installing those updates.

FPT_APW_EXT.1 (EXTENDED) - PROTECTION OF ADMINISTRATOR PASSWORDS

FPT_APW_EXT.1.1 The TSF shall store passwords in non-plaintext form.

FPT_APW_EXT.1.2 The TSF shall prevent the reading of plaintext passwords.

7.1.7. Miscellaneous

FPT_RCV.1 – MANUAL RECOVERY

FPT_RCV.1.1 After [a service crash] the TSF shall enter a maintenance mode where the ability to return to a secure state is provided.

FPT_RCV.2 – AUTOMATED RECOVERY

FPT_RCV.2.1 When automated recovery from [switch on or reboot] is not possible, the TSF shall enter a maintenance mode where the ability to return to a secure state is provided.

DUAL USE CONTROLLED

FPT_RCV.2.2 For [switch on or reboot], the TSF shall ensure the return of the TOE to a secure state using automated procedures.

FPT_FLS.1 - FAIL WITH PRESERVATION OF SECURE STATE

FPT_FLS.1.1 The TSF shall preserve a secure state when the following types of failures occur: [self-test failure].

FPT_TST_EXT.1 (EXTENDED) - TSF TESTING

FPT_TST_EXT.1.1 The TSF shall run a suite of the following self-tests [*during initial start-up and at the request of the authorized user*] to demonstrate the correct operation of the TSF: [

- All cryptographic operations (all FCS_COP.1 requirements)
- Audit log integrity]

FPT_SDP_EXT.2 (EXTENDED) - STORED TSF DATA PROTECTION CAPABILITY AND ACTION

FPT_SDP_EXT.2.1 The TSF shall protect: [

- **SP and SA definitions**
- **Configuration parameters of the TOE**
- **Credentials**
- **Self-protection cryptographic keys**

stored in containers controlled by the TSF from [*disclosure*] and shall detect [*integrity errors*] on those data.

FPT_SDP_EXT.2.2 The TSF shall [generate an event and preserve a secure state (FPT_FLS.1)], upon detection of a data integrity error.

FDP_RIP.2 - FULL RESIDUAL INFORMATION PROTECTION

FDP_RIP.2.1 The TSF shall ensure that any previous information content of a resource is made unavailable upon the [*allocation and deallocation of the resource from*] all objects.

DUAL USE CONTROLLED

7.2. SECURITY ASSURANCE REQUIREMENTS

This security target claims an EAL4 security assurance level augmented by ALC_FLR.3.

Assurance requirements for this level are:

Assurance Class	Assurance components
ADV: Development	ADV_ARC.1 Security architecture description
	ADV_FSP.4 Complete functional specification
	ADV_TDS.3 Basic modular design
	ADV_IMP.1 Implementation representation of the TSF
AGD: Guidance documents	AGD_OPE.1 Operational user guidance
	AGD_PRE.1 Preparative procedures
ALC: Life-cycle support	ALC_CMC.4 Production support, acceptance procedures and automation
	ALC_CMS.4 Problem tracking CM coverage
	ALC_DEL.1 Delivery procedures
	ALC_DVS.1 Identification of security measures
	ALC_LCD.1 Developer defined life-cycle model
	ALC_TAT.1 Well-defined development tools
	ALC_FLR.3 Flaw remediation
ASE: Security Target evaluation	ASE_CCL.1 Conformance claims
	ASE_ECD.1 Extended components definition
	ASE_INT.1 ST introduction

DUAL USE CONTROLLED

Assurance Class	Assurance components
	ASE_OBJ.2 Security objectives
	ASE_REQ.2 Derived security requirements
	ASE_SPD.1 Security problem definition
	ASE_TSS.1 TOE summary specification
ATE: Tests	ATE_COV.2 Analysis of coverage
	ATE_DPT.1 Testing: basic design
	ATE_FUN.1 Functional testing
	ATE_IND.2 Independent testing - sample
AVA: Vulnerability assessment	AVA_VAN.3 Vulnerability analysis

Table 14: Assurance requirements for EAL4+

7.3. RATIONALE FOR THE SECURITY REQUIREMENTS

7.3.1. Security objectives for the TOE

DUAL USE CONTROLLED

	O.AUDIT	O.AUDIT PROTECTION	O.AUTHENTICATION FAILURE	O.BOOT CONTROL	O.CRYPTO PERIOD	O.CRYPTO REGULATION	O.DATA ERASURE	O.DISPLAY BANNER	O.I&A	O.LOCAL DATA PROTECTION	O.MANAGEMENT	O.POL DEFAULT	O.POL FILTERING	O.PROTECTED COMMUNICATIONS	O.RESIDUAL INFORMATION CLEAR	O.ROLES	O.CERTIFICATE INJECTION	O.SELF TEST	O.SESSON LOCK	O.SOFTWARE UPDATES	O.SUPERVISION	O.SUPERVISION IMPACT	O.TIME BASE	O.VIEW RULES	O.TOE REDUNDANCY
FAU_GEN.1	X																								
FAU_GEN.2	X																								
FAU_STG_EXT.1	X	X																							
FAU_STG_EXT.2/LocSpace	X																								
FAU_STG.3/LocSpace	X	X																							
FPT_STM_EXT.1																							X		
FCS_RBG_EXT.1						X																			
FCS_CKM.1						X																			
FCS_CKM.2						X																			
FCS_CKM.4						X	X			X															
FCS_CKM_EXT.5/certificate					X																				
FCS_CKM_EXT.5/ikeV2SA					X																				
FCS_CKM_EXT.5/ikeV2childSA					X																				
FCS_COP.1/DataEncryptionGCM						X									X										
FCS_COP.1/DataEncryptionCTR						X									X										
FCS_COP.1/DataEncryptionCBC						X														X					
FCS_COP.1/DataEncryptionXTS						X				X															

DUAL USE CONTROLLED

	O.TOE REDUNDANCY	O.VIEW RULES	O.TIME BASE	O.SUPERVISION IMPACT	O.SUPERVISION	O.SOFTWARE UPDATES	O.SESSON LOCK	O.SELF TEST	O.CERTIFICATE INJECTION	O.ROLES	O.RESIDUAL INFORMATION CLEAR	O.PROTECTED COMMUNICATIONS	O.POL FILTERING	O.POL DEFAULT	O.MANAGEMENT	O.LOCAL DATA PROTECTION	O.I&A	O.DISPLAY BANNER	O.DATA ERASURE	O.CRYPTO REGULATION	O.CRYPTO PERIOD	O.BOOT CONTROL	O.AUTHENTICATION FAILURE	O.AUDIT PROTECTION	O.AUDIT
FCS_COP.1/SignGenRSA																				X					
FCS_COP.1/SignGenECDSA					X							X							X						
FCS_COP.1/SignGenECSDSA												X							X						
FCS_COP.1/Hash256												X							X						
FCS_COP.1/Hash384												X							X						
FCS_COP.1/KeyedHash160	X																								
FCS_COP.1/KeyedHash256					X							X							X						
FCS_COP.1/KeyedHash384												X							X						
FCS_COP.1/DataDecryptionP12								X																	
FIA_X509_EXT.1											X														
FIA_X509_EXT.2											X														
FIA_X509_EXT.3											X														
FTP_ITC.1			X								X														
FDP_UCT.1			X								X														
FDP_UIT.1			X								X														
FTP_TRP.1/JOIN	X																								
FTP_TRP.1/ADMIN											X														

DUAL USE CONTROLLED

SECURITY TARGET FOR MISTRAL VS9
MISTRAL VS9 IPSEC GATEWAY SOFTWARE

	O.TOE REDUNDANCY	O.VIEW RULES	O.TIME BASE	O.SUPERVISION IMPACT	O.SUPERVISION	O.SOFTWARE UPDATES	O.SESSON LOCK	O.SELF TEST	O.CERTIFICATE INJECTION	O.ROLES	O.RESIDUAL INFORMATION CLEAR	O.PROTECTED COMMUNICATIONS	O.POL FILTERING	O.POL DEFAULT	O.MANAGEMENT	O.LOCAL DATA PROTECTION	O.I&A	O.DISPLAY BANNER	O.DATA ERASURE	O.CRYPTO REGULATION	O.CRYPTO PERIOD	O.BOOT CONTROL	O.AUTHENTICATION FAILURE	O.AUDIT PROTECTION	O.AUDIT
FCS_IPSEC_EXT.1												X		X									X		
FCS_TLSC_EXT.2												X													
FCS_TLSS_EXT.2												X													
FCO_CPC_EXT.1/JOIN	X																								
FCO_CPC_EXT.1/ADMIN												X													
FDP_ITC.2/VPN													X												
FDP_ETC.2/VPN												X													
FDP_IFC.1/VPN				X									X												
FDP_IFF.1/VPN				X									X	X											
FDP_ITC.2/CryptoInjection								X																	
FDP_IFC.1/CryptoInjection				X				X																	
FDP_IFF.1/CryptoInjection				X				X																	
FPT_TDC.1/CryptoInjection								X																	
FPT_TDC.1/VPN												X													
FMT_MSA.3				X					X			X													
FMT_SMR.2										X															
FIA_UID.2																	X								

DUAL USE CONTROLLED

Ce document est propriété du Groupe THALES et ne peut être communiqué à l'extérieur du Groupe qu'avec l'accord de THALES SIX GTS France. *This document is THALES Group's property and must not be communicated outside the Group without the agreement of THALES SIX GTS France.* © THALES 2019-2024 – Tous droits réservés - © THALES 2019-2024 – copyrights

SECURITY TARGET FOR MISTRAL VS9
MISTRAL VS9 IPSEC GATEWAY SOFTWARE

	O.TOE REDUNDANCY	O.VIEW RULES	O.TIME BASE	O.SUPERVISION IMPACT	O.SUPERVISION	O.SOFTWARE UPDATES	O.SESSON LOCK	O.SELF TEST	O.CERTIFICATE INJECTION	O.ROLES	O.RESIDUAL INFORMATION CLEAR	O.PROTECTED COMMUNICATIONS	O.POL FILTERING	O.POL DEFAULT	O.MANAGEMENT	O.LOCAL DATA PROTECTION	O.I&A	O.DISPLAY BANNER	O.DATA ERASURE	O.CRYPTO REGULATION	O.CRYPTO PERIOD	O.BOOT CONTROL	O.AUTHENTICATION FAILURE	O.AUDIT PROTECTION	O.AUDIT
FIA_UIA_EXT.1																	X								
FIA_UAU_EXT.2																	X								
FIA_UAU.6														X											
FIA_UAU.7																	X								
FIA_AFL.1																	X					X			
FIA_PMG_EXT.1																	X								
FDP_ACC.1									X								X								
FDP_ACF.1																	X								
FTA_SSL_EXT.1						X																			
FTA_SSL.3						X																			
FTA_SSL.4						X																			
FTA_TAB.1																	X								
FMT_SMF.1														X										X	
FMT_MOF.1/AutoUpdate														X											
FMT_MOF.1/Functions														X											
FMT_MTD.1						X								X										X	
FPT_SKP_EXT.1.1																								X	

DUAL USE CONTROLLED

Ce document est propriété du Groupe THALES et ne peut être communiqué à l'extérieur du Groupe qu'avec l'accord de THALES SIX GTS France. *This document is THALES Group's property and must not be communicated outside the Group without the agreement of THALES SIX GTS France.* © THALES 2019-2024 – Tous droits réservés - © THALES 2019-2024 – copyrights

	O.AUDIT	O.AUDIT PROTECTION	O.AUTHENTICATION FAILURE	O.BOOT CONTROL	O.CRYPTO PERIOD	O.CRYPTO REGULATION	O.DATA ERASURE	O.DISPLAY BANNER	O.I&A	O.LOCAL DATA PROTECTION	O.MANAGEMENT	O.POL DEFAULT	O.POL FILTERING	O.PROTECTED COMMUNICATIONS	O.RESIDUAL INFORMATION CLEAR	O.ROLES	O.CERTIFICATE INJECTION	O.SELF TEST	O.SESSON LOCK	O.SOFTWARE UPDATES	O.SUPERVISION	O.SUPERVISION IMPACT	O.TIME BASE	O.VIEW RULES	O.TOE REDUNDANCY
FPT_TUD_EXT.1											X								X						
FPT_APW_EXT.1									X																
FPT_RCV.1				X																					
FPT_RCV.2				X																					
FPT_FLS.1																		X							
FPT_TST_EXT.1																		X							
FPT_SDP_EXT.2										X											X				
FDP_RIP.2															X										

Table 15: Objectives coverage

O.AUDIT

This security objective is covered by the capability of the TSF to generate audit records data (**FAU_GEN.1**). **FAU_GEN.2** requires the TSF to associate each audit data with the identity of the user or the network device that caused the event.

FAU_STG_EXT.1 ensures the audit data to be recorded (by the TOE and by an external device). **FAU_STG.3/LocSpace** requires the TSF to generate a security event in order to inform a local user before the local space to store audit data is used up and **FAU_STG_EXT.2/LocSpace** requires numbering events.

O.AUDIT_PROTECTION

This security objective is covered by **FAU_STG_EXT.1** which requires the TSF to send all audit records data to an external device since the TSF does not locally stores audit data.

The external device is the management center, the link between the TOE and the external device is therefore a protected management communication channel (i.e. an IPsec and TLS VPN). **FPT_ITC.1**, **FCS_IPSEC_EXT.1**, **FDP_UCT.1** and **FDP_UIT.1** provide the appropriate requirements (as for O.PROTECTED_COMMUNICATIONS).

DUAL USE CONTROLLED

FAU_STG.3/LocSpace requires the TSF to generate a security event in order to inform a local user before the local space to store audit data is used up (in order to export the audit log)

O.AUTHENTICATION_FAILURE

This security objective is covered by **FIA_AFL.1** which defines the number of possible tries to authenticate to TOE behavior in case of authentication failure.

O.BOOT_CONTROL

This security objective is covered by **FPT_RCV.1** and **FPT_RCV.2** with **FCS_COP.1.1/SignGenRSA** which require the TSF started up without protection compromise and can recover without protection compromise after discontinuity of operations.

O.CRYPTO_PERIOD

This security objective is covered by all instances of **FCS_CKM_EXT.5** security requirements, which define certificate validity.

O.CRYPTO_REGULATION

This objective is covered by requirements concerning cryptographic keys and cryptographic operations: **FCS_RBG_EXT.1**, **FCS_CKM.1**, **FCS_CKM.2**, **FCS_CKM.4** and all instances of **FCS_COP.1**.

O.DATA_ERASURE

This security objective is covered by **FCS_CKM.4** which gives the method of erasure.

O.DISPLAY_BANNER

This security objective is covered by **FTA_TAB.1** which requires the banner display before the session establishment.

O.I&A

This security objective is covered by **FIA_UID.2** and **FIA_UIA_EXT.1**, which require identification of devices and authentication of users before granting access to security functions. **FPT_APW_EXT.1** supports FIA_UIA by requiring password protection.

Authentication of users is password based (**FIA_UAU_EXT.2**).

Brute force attacks are countered by requiring specific rules for users' passwords (**FIA_PMG_EXT.1** and **FIA_AFL.1**), and eavesdropping by requiring protected feedback (**FIA_UAU.7**).

O.LOCAL_DATA_PROTECTION

This security objective is covered by **FPT_SDP_EXT.2** which requires securing sensitive data in the TOE. Key destruction after use is covered with **FCS_CKM.4** and **FCS_COP.1/DataEncryptionXTS** for local data encryption.

O.MANAGEMENT

This security objective is covered by **FMT_SMF.1**. All instances of **FMT_MTD.1**, **FPT_TUD_EXT.1**, **FIA_UAU.6**, **FMT_MOF.1/AutoUpdate** and **FMT_MOF.1/Functions** provide details on management functionalities

O.POL_DEFAULT

This security objective is covered by the policies **FDP_IFF.1/VPN** and **FCS_IPSEC_EXT.1**, because it controls IP flows by providing default security policy and a TOE state to apply filtering.

DUAL USE CONTROLLED

O.POL_FILTERING

This security objective is covered by the VPN enforcement policy **FDP_IFC.1/VPN**, **FDP_IFF.1/VPN**, **FDP_ITC.2/VPN** and **FDP_ETC.2/VPN**, because it controls IP datagrams flows by enforcing them security rules and services.

FMT_MSA.3 supports **FDP_IFF.1** by providing default values.

O.PROTECTED_COMMUNICATIONS

This security objective is covered in one hand by the security requirements

- **FTP_ITC.1**, **FDP_UCT.1** **FDP_UIT.1** which require the TSF to provide a trusted communication channel between itself and a remote instance of the TOE that protect data from disclosure, modification, insertion and replay.
- **FTP_TRP.1/ADMIN**, **FDP_UCT.1** and **FDP_UIT.1** which require the TSF to provide a trusted communication path with **SS_MMC** that protect data from disclosure, modification, insertion and replay.

In another hand, the security objective is covered by:

- **FCS_IPSEC_EXT.1** which requires the trusted channel between TOE itself and a remote instance of the TOE to implement IPsec and IKE
- **FPT_TDC.1** which requires the consistency check for IKE parameter exchange
- **FCS_TLSC_EXT.2** and **FCS_TLSS_EXT.2** which requires the trusted channel between TOE itself and **SS_MMC** to implement TLS with authentication.
- **FCO_CPC_EXT.1/ADMIN** which requires the TOE registration before to be allowed to start communication with the other network elements.

Finally the security objective is covered by

- **authentication operation used by IPsec and TLS, that is: FIA_X509_EXT.2 enhanced with FIA_X509_EXT.1** which requires use of valid certificates for authentication and **FIA_X509_EXT.3** which requires certificates loaded on the TOE comes from TOE requests.
- all cryptographic operations used by IPsec and IKE, that is: **FCS_COP.1/DataEncryptionGCM** and **FCS_COP.1/DataEncryptionCTR**, **FCS_COP.1/SignGenECDSA**, **FCS_COP.1/SignGenECSDSA**, **FCS_COP.1/Hash256** and **FCS_COP.1/KeyedHash256**.
- all cryptographic operations used by TLS, that is: **FCS_COP.1/DataEncryptionGCM**, **FCS_COP.1/SignGenECDSA**, **FCS_COP.1/Hash384** and **FCS_COP.1/KeyedHash384**.

O.RESIDUAL_INFORMATION_CLEAR

This security objective is covered by **FDP_RIP.2** which ensures residual information protection

O.ROLES

This security objective is covered by **FMT_SMR.2** which defines roles for users and roles for devices the TSF shall maintain.

O.CERTIFICATE_INJECTION

This objective is covered by the security data injection policy (**FDP_IFC.1/CryptoInjection**, **FDP_IFF.1/CryptoInjection** and **FDP_ITC.2/CryptoInjection**) which controls certificates flows of security data injection and **FCS_COP.1/DataDecryptionP12** which deprotects the PKCS#12 container when used to import private keys.

DUAL USE CONTROLLED

FMT_MSA.3 supports FDP_IFF.1/CryptoInjection, providing default values.

FPT_TDC.1/CryptoInjection supports FDP_ITC.2/CryptoInjection, providing data consistency check.

O.SELF_TEST

This security objective is covered by **FPT_TST_EXT.1** which requires self-test capabilities. In case of self-test failure, the TSF shall preserve a secure state (**FPT_FLS.1**).

O.SESSION_LOCK

This security objective is covered by **FTA_SSL_EXT.1**, **FTA_SSL.3** and **FTA_SSL.4** which define session termination.

O.SOFTWARE_UPDATES

This security objective is covered by **FPT_TUD_EXT.1** and cryptography operation **FCS_COP.1.1/DataEncryptionCBC**, **FCS_COP.1.1/SignGenECDSA** for authentication and **FCS_COP.1.1/KeyedHash256** for integrity test.

O.SUPERVISION

This objective is covered by **FMT_MTD.1** to query relevant information on the TOE.

O.SUPERVISION_IMPACT

This objective is covered by all policies concerning TOE sensitive assets by restricting access to operations handling these assets: **FDP_IFC.1/VPN**, **FDP_IFF.1/VPN**, **FDP_IFC.1/CryptoInjection** and **FDP_IFF.1/CryptoInjection** and completed with **FPT_SDP_EXT.2** for data control in the containers.

FMT_MSA.3 supports FDP_IFF.1 by providing default values.

Furthermore, for the same reasons this objective is covered by all requirements concerning the TSF data management: **FMT_MTD.1**.

O.TIME_BASE

This objective is covered by the requirement **FPT_STM_EXT.1** which requires time reliability.

O.VIEW_RULES

This security objective is covered by the protection policy of TSF configuration and cryptographic keys (**FMT_SMF.1**, **FMT_MTD.1**, and **FPT_SKP_EXT.1**) by controlling their access to the action allowing review.

O.TOE_REDUNDANCY

This security objective is covered by the high-availability exchanges monitoring the cluster status (**FCO_CPC_EXT.1/JOIN**) transmitted through a dedicated logical channel (**FTP_TRP.1/JOIN**) protected in integrity and authenticity (**FCS_COP.1/KeyedHash160**).

DUAL USE CONTROLLED

7.3.2. Rationale for the security assurance requirements

The TOE evaluation is performed through the ANSSI "Qualification" process, claiming a "Standard" assurance level. This process requires at the minimum a CC EAL3 security assurance level augmented with ALC_FLR.3 and AVA_VAN.3.

This minimum level is entirely covered by the EAL4 augmented by ALC_FLR.3 claimed by this Security Target.

DUAL USE CONTROLLED

Ce document est propriété du Groupe THALES et ne peut être communiqué à l'extérieur du Groupe qu'avec l'accord de THALES SIX GTS France. *This document is THALES Group's property and must not be communicated outside the Group without the agreement of THALES SIX GTS France.* © THALES 2019-2024 – Tous droits réservés - © THALES 2019-2024 – copyrights

7.3.3. Dependencies

7.3.3.1. Dependencies for the Security Functional Requirements

SFR	CC dependencies	Satisfied dependencies
FAU_GEN.1	FPT_STM.1	FPT_STM_EXT.1
FAU_GEN.2	(FAU_GEN.1) and (FIA_UID.1)	FAU_GEN.1 FIA_UID.2 (hierarchical to FIA_UID.1)
FAU_STG_EXT.1	(FAU_GEN.1) and (FTP_ITC.1)	FAU_GEN.1 FTP_ITC.1
FAU_STG_EXT.2/LocSpace	(FAU_GEN.1) and (FAU_STG_EXT.1)	(FAU_GEN.1) and (FAU_STG_EXT.1)
FAU_STG.3/LocSpace	FAU_STG.1	FAU_STG_EXT.1
FPT_RCV.1	AGD_OPE.1 Operational user guidance	AGD_OPE.1 Operational user guidance
FPT_RCV.2	AGD_OPE.1 Operational user guidance	AGD_OPE.1 Operational user guidance
FPT_STM_EXT.1	No dependencies.	
FCS_RBG_EXT.1	No dependencies.	
FCS_CKM.1	(FCS_CKM.2 or FCS_COP.1) and FCS_CKM.4	FCS_CKM.2 FCS_COP.1 FCS_CKM.4
FCS_CKM.2	(FDP_ITC.1 or FDP_ITC.2 or FCS_CKM.1) and (FCS_CKM.4)	FCS_CKM.1 FCS_CKM.4
FCS_CKM.4	(FCS_CKM.1 or FDP_ITC.1 or FDP_ITC.2)	FCS_CKM.1
FCS_CKM_EXT.5/certificate	(FCS_CKM.1 or FDP_ITC.1 or FDP_ITC.2) and (FCS_CKM.4) and (FPT_STM_EXT.1)	FCS_CKM.1 FCS_CKM.4 FPT_STM_EXT.1
FCS_CKM_EXT.5/ikeV2SA	(FCS_CKM.1 or FDP_ITC.1 or FDP_ITC.2) and (FCS_CKM.4) and (FPT_STM_EXT.1)	FCS_CKM.1 FCS_CKM.4 FPT_STM_EXT.1
FCS_CKM_EXT.5/ikeV2childSA	(FCS_CKM.1 or FDP_ITC.1 or FDP_ITC.2) and (FCS_CKM.4) and (FPT_STM_EXT.1)	FCS_CKM.1 FCS_CKM.4 FPT_STM_EXT.1
FCS_COP.1/DataEncryptionGCM	(FCS_CKM.1 or FDP_ITC.1 or FDP_ITC.2) and (FCS_CKM.4)	FCS_CKM.1 FCS_CKM.4
FCS_COP.1/DataEncryptionCTR	(FCS_CKM.1 or FDP_ITC.1 or FDP_ITC.2) and (FCS_CKM.4)	FCS_CKM.1 FCS_CKM.4
FCS_COP.1/DataEncryptionCBC	(FCS_CKM.1 or FDP_ITC.1 or FDP_ITC.2) and (FCS_CKM.4)	FCS_CKM.1 FCS_CKM.4
FCS_COP.1/DataEncryptionXTS	(FCS_CKM.1 or FDP_ITC.1 or FDP_ITC.2) and (FCS_CKM.4)	FCS_CKM.1 FCS_CKM.4
FCS_COP.1/SignGenRSA	(FCS_CKM.1 or FDP_ITC.1 or FDP_ITC.2) and (FCS_CKM.4)	FCS_CKM.1 FCS_CKM.4
FCS_COP.1/SignGenECDSA	(FCS_CKM.1 or FDP_ITC.1 or FDP_ITC.2) and (FCS_CKM.4)	FCS_CKM.1 FCS_CKM.4
FCS_COP.1/SignGenECSDSA	(FCS_CKM.1 or FDP_ITC.1 or FDP_ITC.2) and (FCS_CKM.4)	FCS_CKM.1 FCS_CKM.4
FCS_COP.1/Hash256	(FCS_CKM.1 or FDP_ITC.1 or FDP_ITC.2) and (FCS_CKM.4)	FCS_CKM.1 FCS_CKM.4

DUAL USE CONTROLLED

SECURITY TARGET FOR MISTRAL VS9

MISTRAL VS9 IPSEC GATEWAY SOFTWARE

SFR	CC dependencies	Satisfied dependencies
FCS_COP.1/Hash384	(FCS_CKM.1 or FDP_ITC.1 or FDP_ITC.2) and (FCS_CKM.4)	FCS_CKM.1 FCS_CKM.4
FCS_COP.1/KeyedHash160	(FCS_CKM.1 or FDP_ITC.1 or FDP_ITC.2) and (FCS_CKM.4)	FCS_CKM.1 FCS_CKM.4
FCS_COP.1/KeyedHash256	(FCS_CKM.1 or FDP_ITC.1 or FDP_ITC.2) and (FCS_CKM.4)	FCS_CKM.1 FCS_CKM.4
FCS_COP.1/KeyedHash384	(FCS_CKM.1 or FDP_ITC.1 or FDP_ITC.2) and (FCS_CKM.4)	FCS_CKM.1 FCS_CKM.4
FCS_COP.1/DataDecryptionP12	(FCS_CKM.1 or FDP_ITC.1 or FDP_ITC.2) and (FCS_CKM.4)	FCS_CKM.1 FCS_CKM.4
FIA_X509_EXT.1	(FIA_X509_EXT.2)	FIA_X509_EXT.2
FIA_X509_EXT.2	(FIA_X509_EXT.1)	FIA_X509_EXT.1
FIA_X509_EXT.3	(FCS_CKM.1) and (FIA_X509_EXT.1)	FCS_CKM.1 FIA_X509_EXT.1
FTP_ITC.1	No dependencies.	
FDP_UCT.1	(FDP_ACC.1 or FDP_IFC.1) and (FTP_ITC.1 or FTP_TRP.1)	FDP_IFC.1/VPN FTP_ITC.1 FTP_TRP.1
FDP_UIT.1	(FDP_ACC.1 or FDP_IFC.1) and (FTP_ITC.1 or FTP_TRP.1)	FDP_IFC.1/VPN FTP_ITC.1 FTP_TRP.1
FTP_TRP.1/JOIN	No dependencies	
FTP_TRP.1/ADMIN	No dependencies	
FCS_IPSEC_EXT.1	(FCS_CKM.1) and (FCS_CKM.2) and ((FCS_COP.1/DataEncryptionGCM) or (FCS_COP.1/DataEncryptionCTR)) and (FCS_COP.1/SignGenECDSA) and (FCS_COP.1/SignGenECSDSA) and (FCS_COP.1/Hash256) and (FCS_COP.1/KeyedHash256) and (FCS_RBGE_EXT.1)	FCS_CKM.1 FCS_CKM.2 FCS_COP.1/DataEncryptionGCM FCS_COP.1/DataEncryptionCTR FCS_COP.1/ SignGenECDSA FCS_COP.1/ SignGenECSDSA FCS_COP.1/Hash256 FCS_COP.1/KeyedHash256 FCS_RBGE_EXT.1
FCS_TLSC_EXT.2	(FCS_CKM.1) and (FCS_CKM.2) and (FCS_COP.1/DataEncryptionGCM) and (FCS_COP.1/SignGenECDSA) and (FCS_COP.1/Hash384) and (FCS_COP.1/KeyedHash384) and (FCS_RBGE_EXT.1)	FCS_CKM.1 FCS_CKM.2 FCS_COP.1/DataEncryptionGCM FCS_COP.1/ SignGenECDSA FCS_COP.1/Hash384 FCS_COP.1/KeyedHash384 FCS_RBGE_EXT.1
FCS_TLSS_EXT.2	((FCS_CKM.1) and (FCS_CKM.2) and (FCS_COP.1/DataEncryptionGCM) and (FCS_COP.1/SignGenECDSA) and (FCS_COP.1/Hash384) and (FCS_COP.1/KeyedHash384) and (FCS_RBGE_EXT.1)	FCS_CKM.1 FCS_CKM.2 FCS_COP.1/DataEncryptionGCM FCS_COP.1/ SignGenECDSA FCS_COP.1/Hash384 FCS_COP.1/KeyedHash384 FCS_RBGE_EXT.1
FCO_CPC_EXT.1/JOIN	No dependencies	
FCO_CPC_EXT.1/ADMIN	No dependencies	

DUAL USE CONTROLLED

Ce document est propriété du Groupe THALES et ne peut être communiqué à l'extérieur du Groupe qu'avec l'accord de THALES SIX GTS France. *This document is THALES Group's property and must not be communicated outside the Group without the agreement of THALES SIX GTS France.* © THALES 2019-2024 – Tous droits réservés - © THALES 2019-2024 – copyrights

SECURITY TARGET FOR MISTRAL VS9

MISTRAL VS9 IPSEC GATEWAY SOFTWARE

SFR	CC dependencies	Satisfied dependencies
FDP_ITC.2/VPN	(FDP_ACC.1 or FDP_IFC.1) and (FTP_ITC.1 or FTP_TRP.1) and (FPT_TDC.1)	FDP_IFC.1/VPN FTP_TRP.1 FPT_TDC.1/VPN
FDP_ETC.2/VPN	(FDP_ACC.1 or FDP_IFC.1)	FDP_IFC.1/VPN
FDP_IFC.1/VPN	(FDP_IFF.1)	FDP_IFF.1/VPN
FDP_IFF.1/VPN	(FDP_IFC.1) and (FMT_MSA.3)	FDP_IFC.1/VPN FMT_MSA.3
FDP_ITC.2/CryptoInjection	(FDP_ACC.1 or FDP_IFC.1) and (FTP_ITC.1 or FTP_TRP.1) and (FPT_TDC.1)	FDP_IFC.1/CryptoInjection FTP_ITC.1 FPT_TDC.1/CryptoInjection
FDP_IFC.1/CryptoInjection	(FDP_IFF.1)	FDP_IFF.1/CryptoInjection
FDP_IFF.1/CryptoInjection	(FDP_IFC.1) and (FMT_MSA.3)	FDP_IFC.1/CryptoInjection FMT_MSA.3
FPT_TDC.1/CryptoInjection FPT_TDC.1/VPN	No dependencies.	
FMT_MSA.3	(FMT_MSA.1) and (FMT_SMR.1)	FMT_SMR.2 (hierarchical to SMR.1)
FMT_SMR.2	(FIA_UID.1)	FIA_UID.2 (hierarchical to FIA_UID.1)
FIA_UID.2	No dependencies.	
FIA_UIA_EXT.1	(FTA_TAB.1)	FTA_TAB.1
FIA_UAU_EXT.2	No dependencies.	
FIA_UAU.6	No dependencies.	
FIA_UAU.7	(FIA_UAU.1)	FIA_UIA_EXT.1
FIA_AFL.1	(FIA_UAU.1)	FIA_UIA_EXT.1
FIA_PMG_EXT.1	No dependencies.	
FDP_ACC.1	(FDP_ACF.1)	FDP_ACF.1
FDP_ACF.1	(FDP_ACC.1) and (FMT_MSA.3)	FDP_ACC.1 FMT_MSA.3
FTA_SSL_EXT.1	FIA_UIA_EXT.1	FIA_UIA_EXT.1
FTA_SSL.3	No dependencies.	
FTA_SSL.4	No dependencies.	
FTA_TAB.1	No dependencies.	
FMT_SMF.1	No dependencies.	
FMT_MOF.1/AutoUpdate	(FMT_SMF.1) and (FMT_SMR.1)	FMT_SMF.1 FMT_SMR.2
FMT_MOF.1/Functions	(FMT_SMF.1) and (FMT_SMR.1)	FMT_SMF.1 FMT_SMR.2
FMT_MTD.1	(FMT_SMF.1) and (FMT_SMR.1)	FMT_SMF.1 FMT_SMR.2
FPT_SKP_EXT.1	No dependencies.	
FPT_TUD_EXT.1	(FCS_COP.1/SignGenRSA) or (FCS_COP.1/Hash256)	FCS_COP.1/SignGenRSA FCS_COP.1/Hash256
FPT_APW_EXT.1	No dependencies.	
FPT_FLS.1	No dependencies.	

DUAL USE CONTROLLED

Ce document est propriété du Groupe THALES et ne peut être communiqué à l'extérieur du Groupe qu'avec l'accord de THALES SIX GTS France. *This document is THALES Group's property and must not be communicated outside the Group without the agreement of THALES SIX GTS France.* © THALES 2019-2024 – Tous droits réservés - © THALES 2019-2024 – copyrights

SFR	CC dependencies	Satisfied dependencies
FPT_TST_EXT.1	No dependencies.	
FPT_SDP_EXT.2	No dependencies.	
FDP_RIP.2	No dependencies.	

Table 16: SFR dependencies status

7.3.3.2. Rationale for the unsatisfied SFR dependencies

SFR	SFR unsatisfied dependencies
FMT_MSA.3	FMT_MSA.1 dependency is unsatisfied, because default settings values cannot be modified.
FMT_SMR.2	FIA_UID.1 dependency is unsatisfied because it has been replaced with FIA_UIA_EXT.1, which specifies the relevant Administrator identification (see [c_PP])
FIA_UAU.7	FIA_UAU.1 dependency is unsatisfied because it has been replaced with FIA_UIA_EXT.1, which specifies the relevant Administrator identification (see [c_PP])
FIA_AFL.1	FIA_UAU.1 dependency is unsatisfied because it has been replaced with FIA_UIA_EXT.1, which specifies the relevant Administrator identification (see [c_PP])

Table 17: Unsatisfied SFR dependencies

DUAL USE CONTROLLED

7.3.3.3. Dependencies for the Security Assurance Requirements

SAR	CC dependencies	Satisfied dependencies
ADV_ARC.1	(ADV_FSP.1) and (ADV_TDS.1)	ADV_FSP.4 ADV_TDS.3
ADV_FSP.4	(ADV_TDS.1)	ADV_TDS.3
ADV_TDS.3	(ADV_FSP.4)	ADV_FSP.4
ADV_IMP.1	(ADV_TDS.3) and (ALC_TAT.1)	ADV_TDS.3 ALC_TAT.1
AGD_OPE.1	(ADV_FSP.1)	ADV_FSP.4
AGD_PRE.1	No dependencies.	
ALC_CMC.4	(ALC_CMS.1) and (ALC_DVS.1) and (ALC_LCD.1)	ALC_CMS.4 ALC_DVS.1 ALC_LCD.1
ALC_CMS.4	No dependencies.	
ALC_DEL.1	No dependencies.	
ALC_DVS.1	No dependencies.	
ALC_FLR.3	No dependencies.	
ALC_LCD.1	No dependencies.	
ALC_TAT.1	(ADV_IMP.1)	ADV_IMP.1
ASE_CCL.1	(ASE_ECD.1) and (ASE_INT.1) and (ASE_REQ.1)	ASE_ECD.1 ASE_INT.1 ASE_REQ.2
ASE_ECD.1	No dependencies.	
ASE_INT.1	No dependencies.	
ASE_OBJ.2	(ASE_SPD.1)	ASE_SPD.1
ASE_REQ.2	(ASE_ECD.1) and (ASE_OBJ.2)	ASE_ECD.1 ASE_OBJ.2
ASE_SPD.1	No dependencies.	
ASE_TSS.1	(ADV_FSP.1) and (ASE_INT.1) and (ASE_REQ.1)	ADV_FSP.4 ASE_INT.1 ASE_REQ.2
ATE_COV.2	(ADV_FSP.2) and (ATE_FUN.1)	ADV_FSP.4 ATE_FUN.1
ATE_DPT.1	(ADV_ARC.1) and (ADV_TDS.2) and (ATE_FUN.1)	ADV_ARC.1 ADV_TDS.3 ATE_FUN.1
ATE_FUN.1	(ATE_COV.1)	ATE_COV.2
ATE_IND.2	(ADV_FSP.2) and (AGD_OPE.1) and (AGD_PRE.1) and (ATE_COV.1) and (ATE_FUN.1)	ADV_FSP.4 AGD_OPE.1 AGD_PRE.1 ATE_COV.2 ATE_FUN.1

DUAL USE CONTROLLED

SAR	CC dependencies	Satisfied dependencies
AVA_VAN.3	(ADV_ARC.1) and (ADV_FSP.4) and (ADV_IMP.1) and (ADV_TDS.3) and (AGD_OPE.1) and (AGD_PRE.1) and (ATE_DPT.1)	ADV_ARC.1 ADV_FSP.4 ADV_IMP.1 ADV_TDS.3 AGD_OPE.1 AGD_PRE.1 ATE_DPT.1

Table 18: SAR dependencies status

7.3.3.4. Rationale for the unsatisfied SAR dependencies

This security target does not present any unsatisfied SAR dependencies.

DUAL USE CONTROLLED

8. TOE SUMMARY SPECIFICATIONS

8.1. SECURITY FUNCTIONS

8.1.1. F.AUDIT AND EVENTS LOGGING

An **event** is the result of known/specified action in the Mistral system. There is a special event kind named **alarm**. An alarm is an event with a severity level equal or superior to **Alert** described below.

8.1.1.1. Events storage

Events are written by the TOE itself in local files on the TOE to allow the viewing of past actions history and detected problems. Stored events contain:

- Sub-System name generating the event
- Sequence number (incremented of one unit on each new event)
- Date and time
- Event Occurrence
- Severity level
- Type of event
- Optional parameters
- Authenticated role when event occur
- Event type description

No sensitive data are contained in the events.

When current sequence number reaches its maximum value, it is reset to its original value. Some events concerning network are aggregated in order to not fill too quickly the event log.

The TOE is able to store in a file a finite number of events. The TOE creates a backup of the log file when the maximum number of records is reached. Log file backup is managed with a rotation mechanism. The TOE raises an event before to delete the events. The TOE notifies in its log file the automatic backup of the current file and recent backup files deletion.

Alarms are logged and sent to Management Center Devices. They can be displayed to the Local Management Interface.

Audit logs, including event logs and technical logs, can be archived locally on external media; The TOE shall record this action in the event log.

8.1.1.2. Events & Alarms

The events and alarms generated by the TOE are:

- Notice
- Warning

DUAL USE CONTROLLED

- Error
- Alert
- Emergency

Alert and emergency events are considered as alarms.

Events notified by the TOE as a notice or a warning are:

- Start-up of the TOE;
- Administrative login and logout (automatic or manual);
- Security related configuration changes;
- Generating asymmetric cryptographic keys (in addition to the action itself a unique key name or key reference shall be logged);
- Passwords modification (name of related user account shall be logged);
- Log archive or deletion;
- VPN establishment (successful);
- Certificate or CRL injection/deletion (successful);
- Software Update (upload and installation);
- Configuration injection (initial value modification for example);
- Time change;
- Secure erasure (success);
- Change of role in cluster.

Events notified as an error are:

- TOE in failure state;
- Passwords modification error (name of related user account shall be logged);
- Unsuccessful login attempts;
- Certificate or CRL injection/deletion with error;
- Security related configuration changes error;
- VPN establishment error and link down (unsuccessful attempt to use a certificate, ...);
- Software Update upload failure.

Events notified as an alarm or an emergency are:

- Self-test error,
- Integrity error (ESP , log ...),
- Secure erasure (failure),
- Authentication failure (after several errors on local interface),

DUAL USE CONTROLLED

- Certificates end of life (imminent and expiration reached),
- Software Update installation failure,
- Fast event log deletion,
- and some network events considered as errors (Replay, spoofing, IP address conflict and fragmented packet received from untrusted network).

8.1.2. F.STORAGE AND PROTECTION FOR LOCAL DATA

8.1.2.1. Data definition

Data can be gathered in 2 groups:

- **Permanent data:** saved in the non-volatile memory of the gateway between two starts.
- **Volatile data:** not saved after the shutdown or the restart of the equipment. Permanent data are divided in the following groups:
 - **Factory data:** default Local Management Interface user profiles. Not erasable, those data are written in concerned data containers during secure erasure,
 - **Hardware data:** serial numbers and Ethernet addresses. Set once during the equipment manufacturing and not erasable after,
 - **Sensitives Network data:** parameters of all network interfaces,
 - **Security data for remote management:** security rules (Security Association / Security Policies), keys, certificates, IKE parameters and keys, management centers IP addresses and other useful parameters for remote management,
 - **Security data for user data flows:** security rules (Security Association / Security Policies),
 - **Events log file:** storage of events/alarms detected by the equipment.

8.1.2.2. Data protection

Containers are protected in confidentiality and integrity.

8.1.2.3. Data erasing

Erasing of plain-texted security data brings them confidentiality protection.

DUAL USE CONTROLLED

8.1.3. F.TRAFFIC KEYS AND CERTIFICATES MANAGEMENT

Keys and **X509 certificates** are used for network flows protection or authentication of counterpart equipment.

8.1.3.1. Keys description:

There are 2 key types in the Mistral system:

- **Negotiated keys:** dynamic negotiated keys by IKEv2. There are not saved between 2 starts.
- **Generated keys:** keys generated by cryptographic algorithms used to VPN keys establishment (IPsec and TLS).

8.1.3.2. Keys physical protection

Generated keys are **protected in the SS_IPSEC_GW** and don't go out from any interface.

8.1.3.3. Keys erasing

On secure erasing, keys in Mistral partition are cleared.

Generated keys and negotiated keys are cleared after use.

8.1.3.4. Certificates usage

The TOE certificates provided by CSS_PKI are injected in the TOE before to become operational device. They are used for IKE authentication with remote instance of TOE (IPSEC) and with SS_MMC (TLS).

The TOE checks certificates validity when they are imported, either loaded from USB media, either downloaded from the remote management link.

During traffic establishment, certificates are used to authenticate the TOE with SS_MMC (TLS) or another TOE instance (IPsec). The TOE checks if the certificate received is linked with a trusted CA (trusted anchor).

Each certificate validation process includes a verification of the certificate revocation status, based on OCSP protocol or CRL check, according to the configuration done by the administrator. When OCSP is configured but the OCSP request attempts fail, the TOE must check the CRL as a fallback solution.

8.1.4. F.USERS CONFIGURATION AND MONITORING

8.1.4.1. Local management

Mistral gateways are manageable with management centers and allowed stations through the network.

Some commands can be executed with the **Local Management Interface**.

Local Management Interface access is limited with the active user profile.

Local Management Interface is accessible locally. Users do not have their own account but use a single administrator profile with limited granted commands.

DUAL USE CONTROLLED

The TOE protects **U.ROLE_GW_OPERATOR** account with a password and freezes it for a moment when the number of authorized failures is reached.

After a successful authentication, users are allowed to access to **U.ROLE_GW_OPERATOR** commands as restart, stop, status query, self-tests and configure the equipment. **U.ROLE_GW_OPERATOR** is an administrator for the TOE.

The TOE provides to **U.ROLE_GW_OPERATOR** a means of changing the local administration password, with respect to the defined password policy.

The TOE provides to **U.ROLE_SYS_ADMIN** a means of changing the local administration password, with respect to the defined password policy.

User session termination: is done by the user, or automatically after a delay of inactivity.

Banner: at user session opening, a notice and consent warning message is displayed.

8.1.4.2. Remote management

The TOE allows remote connection using TLS tunnel with X.509 certificates for authentication.

Remote session termination is done automatically after the request has been received by TOE or after 1 minute of inactivity.

8.1.4.3. Configuration and monitoring

Local Management Interface lets configuration and monitoring of the Mistral gateway with restricted CLI commands. Parameters can be set individually or imported from a secured file containing all or part of the configuration following user profile:

The TOE shall authorize modification of data described in § 5.1.3.6 only to the authorized identified roles which are the local operator (**U.ROLE_GW_OPERATOR**) and the TOE management center device (**U.ROLE_SYS_ADMIN**). TOE shall receive a configuration file from management center device before starting user traffic handling.

8.1.4.4. Software update

In the Mistral system software, update can be performed through the remote management protocol or through the local management interface from an USB device.

The update consists in the download of a single file protected in authentication, integrity and confidentiality called firmware. No obsolete (anterior to the one currently deployed) version can be downloaded.

On firmware activation, after being checked by the current running software of the equipment, the new firmware is written in permanent memory.

DUAL USE CONTROLLED

8.1.4.5. IKE data injection

Certificates are injected in the equipment locally (**U.ROLE_GW_OPERATOR** rights needed) or by a TOE Management Center (**U.ROLE_SYS_ADMIN** rights needed).

Certificates used are X509 certificates provided by CSS_PKI and signed by certificate authority.

Negotiated keys are managed by the IKE service and are directly and only stored in RAM.

8.1.4.6. Time management

TOE has to rely on current time (event log ...). Time must have been configured on the TOE by **U.ROLE_GW_OPERATOR** before it starts to cipher/decipher. During all its lifetime, TOE allows **U.ROLE_GW_OPERATOR** and **U.ROLE_SYS_ADMIN** to change time locally.

The TOE has to hold date and time when it is turned off using a battery which guarantees this function during the whole life of the TOE.

8.1.5. F.FILTERING AND PROTECTION NETWORK DATA FLOWS

8.1.5.1. Traffic policy

All incoming and outgoing network flows are analyzed and have a predefined handling. Possible actions allowed in SP for frames to be sent through untrusted network are:

- **Discard**: the frame is destroyed. This is the default security policy (in case no VPN SP has been explicitly defined)
- **Protect**: the frame must be encrypted/decrypted depending on the mode defined in the SA.

If no rule corresponds during the analysis a **default discard** action is applied on the frame.

8.1.5.2. User network flow filtering

Each incoming and outgoing frame from cipher or plain zone is systematically analyzed and filtered. Filtering is based on **IPsec** selectors and **SA** (Security Association) / **SP** (Security Policy).

The TOE is a network gateway that isolates plain and ciphered network from ISO layer 2 messages.

The criteria of filter rules are:

- The receiving or destination interface of IP packets covered by the rule;
- The source of the information flows covered by the rule;
- The IP protocol(s), TCP services or types of ICMP messages of information flows covered by the rule;
- The destination of information flows covered by the rule;
- The DSCP tag covered by the rule.

Each filter rule must specify a control action and may logging action.

DUAL USE CONTROLLED

8.1.5.3. User network flow protection

When the filtering action is « protect », frames are encrypted (or decrypted) depending on the protection mode and keys specified in the SA: integrity, confidentiality encapsulated in tunnel mode using IKEv2 negotiated keys.

When frame protection is finished, the Commutation software component establishes the interface/outgoing zone to send the new packet.

The sensitive assets handled by uncontrolled component (used for VPN flow) must be ciphered first.

If the gateway receives an **ESP** frame on a cipher interface, it will first of all try to decrypt the frame with the SA identified by the SPI of the ESP header before filtering.

IKE and IPsec definition:

- Key exchange: EC-DH : BrainpoolP256r1 or secp256r1;
- Authentication modes: ECDSA on BrainpoolP256r1 or secp256r1 with SHA256 using X.509v3 certificates, or ECDSA on BrainpoolP256r1 or secp256r1 with SHA256 using X.509v3 certificates;
- Key derivation: PRF_HMAC_SHA2_256;
- IKE protocol confidentiality algorithm: AES-GCM16 and AES-CTR (AUTH_HMAC_SHA2_256_128) with 256-bits long key;
- IKE protocol integrity algorithm: HMAC-SHA- 256_128;
- IKE SA childless creation method.

No other algorithms or key length than described above are allowed.

8.1.6. F.SECURE BOOT

On TOE restart (switch on or any reboot), TOE shall control:

- Boot chain integrity;
- Secure boot certificates revocation;
- Software integrity and authenticity.

The TOE underlying platform shall ask and verify the BIOS password before allowing any modification of the BIOS configuration parameters.

8.1.7. F.FAILURE STATE

When one of the following errors occurs, the equipment enters in a failure state:

- Memory access error;
- Self-test failure;
- Failure of a service start;
- Writing memory error;
- Event recording error;
- Boot error.

DUAL USE CONTROLLED

8.1.8. F.SECURITY_ERASURE

The TOE allows U.ROLE_GW_OPERATOR to perform security erasure.

On security erasure, the TOE:

- Goes in ST_GW_FACTORY state;
- Keeps the current software version;
- Erases configuration data and data injected during installation (password, certificates) and keys generated;
- Keeps the event log.

The TOE allows U.ROLE_GW_OPERATOR to perform a secure audit logs erasure. Audit logs include event logs and technical logs.

8.1.9. F.SELF-TEST

A cryptographic self-test is automatically performed at the TOE start.

While the TOE is operational, a cryptographic self-test can be performed on user request.

A self-test consists on encryption/decryption of data by the cryptographic library and events log integrity check.

8.1.10. F.HIGH-AVAILABILITY

When it is deployed in a high-availability cluster, the TOE acts by default as the active node or as a passive node according to the configuration set by the administrator, based on a priority value.

When it is deployed in a high-availability cluster in passive mode, the TOE automatically detects the loss of the active node and immediately switches in active mode, according to its priority.

High-availability-specific network exchanges are protected in integrity and authenticity.

DUAL USE CONTROLLED

8.2. SFR AND SECURITY FUNCTION MAPPING

SFR	SFT
FAU_GEN.1	F.AUDIT_AND_EVENTS_LOGGING F.SECURE_ERASURE
FAU_GEN.2	F.AUDIT_AND_EVENTS_LOGGING
FAU_STG_EXT.1	F.AUDIT_AND_EVENTS_LOGGING
FAU_STG_EXT.2/LocSpace	F.AUDIT_AND_EVENTS_LOGGING
FAU_STG.3/LocSpace	F.AUDIT_AND_EVENTS_LOGGING
FPT_STM_EXT.1	F.USERS_CONFIGURATION_AND_MONITORING
FCS_RBG_EXT.1	F.FILTERING_AND_PROTECTION_NETWORK_DATA_FLOWS
FCS_CKM.1	F.TRAFFIC_KEYS_AND_CERTIFICATES_MANAGEMENT
FCS_CKM.2	F.TRAFFIC_KEYS_AND_CERTIFICATES_MANAGEMENT F.FILTERING_AND_PROTECTION_NETWORK_DATA_FLOWS
FCS_CKM.4	F.SECURITY_ERASURE F.TRAFFIC_KEYS_AND_CERTIFICATES_MANAGEMENT
FCS_CKM_EXT.5/certificate	F.TRAFFIC_KEYS_AND_CERTIFICATES_MANAGEMENT
FCS_CKM_EXT.5/ikeV2SA	F.TRAFFIC_KEYS_AND_CERTIFICATES_MANAGEMENT
FCS_CKM_EXT.5/ikeV2childSA	F.TRAFFIC_KEYS_AND_CERTIFICATES_MANAGEMENT
FCS_COP.1/DataEncryptionGCM	F.FILTERING_AND_PROTECTION_NETWORK_DATA_FLOWS
FCS_COP.1/DataEncryptionCTR	F.FILTERING_AND_PROTECTION_NETWORK_DATA_FLOWS
FCS_COP.1/DataEncryptionCBC	F.USERS_CONFIGURATION_AND_MONITORING
FCS_COP.1/DataEncryptionXTS	F.STORAGE_AND_PROTECTION_FOR_LOCAL_DATA
FCS_COP.1/SignGenRSA	F.USERS_CONFIGURATION_AND_MONITORING F.SECURE_BOOT
FCS_COP.1/SignGenECDSA	F.FILTERING_AND_PROTECTION_NETWORK_DATA_FLOWS

DUAL USE CONTROLLED

FCS_COP.1/SignGenECSDSA	F.FILTERING_AND_PROTECTION_NETWORK_DATA_FLOWS
FCS_COP.1/Hash256	F.FILTERING_AND_PROTECTION_NETWORK_DATA_FLOWS F.STORAGE_AND_PROTECTION_FOR_LOCAL_DATA
FCS_COP.1/KeyedHash160	F.HIGH-AVAILABILITY
FCS_COP.1/KeyedHash256	F.USERS_CONFIGURATION_AND_MONITORING F.STORAGE_AND_PROTECTION_FOR_LOCAL_DATA
FCS_COP.1/Hash384	F.USERS_CONFIGURATION_AND_MONITORING
FCS_COP.1/KeyedHash384	F.USERS_CONFIGURATION_AND_MONITORING
FCS_COP.1/DataDecryptionP12	F.TRAFFIC_KEYS_AND_CERTIFICATES_MANAGEMENT
FIA_X509_EXT.1	F.TRAFFIC_KEYS_AND_CERTIFICATES_MANAGEMENT F.FILTERING_AND_PROTECTION_NETWORK_DATA_FLOWS
FIA_X509_EXT.2	F.FILTERING_AND_PROTECTION_NETWORK_DATA_FLOWS
FIA_X509_EXT.3	F.TRAFFIC_KEYS_AND_CERTIFICATES_MANAGEMENT
FTP_ITC.1	F.FILTERING_AND_PROTECTION_NETWORK_DATA_FLOWS
FDP_UCT.1	F.FILTERING_AND_PROTECTION_NETWORK_DATA_FLOWS
FDP_UIT.1	F.FILTERING_AND_PROTECTION_NETWORK_DATA_FLOWS
FCS_IPSEC_EXT.1	F.TRAFFIC_KEYS_AND_CERTIFICATES_MANAGEMENT F.FILTERING_AND_PROTECTION_NETWORK_DATA_FLOWS
FTP_TRP.1/JOIN	F.HIGH-AVAILABILITY
FTP_TRP.1/ADMIN	F.USERS_CONFIGURATION_AND_MONITORING
FCS_TLSC_EXT.2	F.TRAFFIC_KEYS_AND_CERTIFICATES_MANAGEMENT F.USERS_CONFIGURATION_AND_MONITORING
FCS_TLSS_EXT.2	F.TRAFFIC_KEYS_AND_CERTIFICATES_MANAGEMENT F.USERS_CONFIGURATION_AND_MONITORING
FCO_CPC_EXT.1/JOIN	F.HIGH-AVAILABILITY
FCO_CPC_EXT.1/ADMIN	F.USERS_CONFIGURATION_AND_MONITORING

DUAL USE CONTROLLED

FDP_ITC.2/VPN	F.FILTERING_AND_PROTECTION_NETWORK_DATA_FLOWS
FDP_ETC.2/VPN	F.FILTERING_AND_PROTECTION_NETWORK_DATA_FLOWS
FDP_IFC.1/VPN	F.FILTERING_AND_PROTECTION_NETWORK_DATA_FLOWS
FDP_IFF.1/VPN	F.FILTERING_AND_PROTECTION_NETWORK_DATA_FLOWS
FDP_ITC.2/CryptoInjection	F.USERS_CONFIGURATION_AND_MONITORING F.TRAFFIC_KEYS_AND_CERTIFICATES_MANAGEMENT
FDP_IFC.1/CryptoInjection	F.USERS_CONFIGURATION_AND_MONITORING F.TRAFFIC_KEYS_AND_CERTIFICATES_MANAGEMENT
FDP_IFF.1/CryptoInjection	F.USERS_CONFIGURATION_AND_MONITORING F.TRAFFIC_KEYS_AND_CERTIFICATES_MANAGEMENT
FPT_TDC.1/CryptoInjection	F.USERS_CONFIGURATION_AND_MONITORING
FPT_TDC.1/VPN	F.FILTERING_AND_PROTECTION_NETWORK_DATA_FLOWS
FMT_MSA.3	F.USERS_CONFIGURATION_AND_MONITORING
FMT_SMR.2	F.USERS_CONFIGURATION_AND_MONITORING
FIA_UID.2	F.USERS_CONFIGURATION_AND_MONITORING
FIA_UIA_EXT.1	F.USERS_CONFIGURATION_AND_MONITORING
FIA_UAU_EXT.2	F.USERS_CONFIGURATION_AND_MONITORING
FIA_UAU.6	F.USERS_CONFIGURATION_AND_MONITORING
FIA_UAU.7	F.USERS_CONFIGURATION_AND_MONITORING
FIA_AFL.1	F.USERS_CONFIGURATION_AND_MONITORING
FIA_PMG_EXT.1	F.USERS_CONFIGURATION_AND_MONITORING
FDP_ACC.1	F.USERS_CONFIGURATION_AND_MONITORING F.SECURE_BOOT
FDP_ACF.1	F.USERS_CONFIGURATION_AND_MONITORING F.SECURE_BOOT

DUAL USE CONTROLLED

FTA_SSL_EXT.1	F.USERS_CONFIGURATION_AND_MONITORING
FTA_SSL.3	F.USERS_CONFIGURATION_AND_MONITORING
FTA_SSL.4	F.USERS_CONFIGURATION_AND_MONITORING
FTA_TAB.1	F.USERS_CONFIGURATION_AND_MONITORING
FMT_SMF.1	F.USERS_CONFIGURATION_AND_MONITORING
FMT_MOF.1/AutoUpdate	F.USERS_CONFIGURATION_AND_MONITORING
FMT_MOF.1/Functions	F.USERS_CONFIGURATION_AND_MONITORING
FMT_MTD.1	F.USERS_CONFIGURATION_AND_MONITORING
FPT_SKP_EXT.1	F.USERS_CONFIGURATION_AND_MONITORING
FPT_TUD_EXT.1	F.USERS_CONFIGURATION_AND_MONITORING
FPT_APW_EXT.1	F.STORAGE_AND_PROTECTION_FOR_LOCAL_DATA F.USERS_CONFIGURATION_AND_MONITORING
FPT_RCV.1	F.SECURE_BOOT F.FAILURE_STATE
FPT_RCV.2	F.SECURE_BOOT F.FAILURE_STATE
FPT_FLS.1	F.FAILURE_STATE
FPT_TST_EXT.1	F.SELF-TEST
FPT_SDP_EXT.2	F.STORAGE_AND_PROTECTION_FOR_LOCAL_DATA
FDP_RIP.2	F.STORAGE_AND_PROTECTION_FOR_LOCAL_DATA

Table 19: SFR and SFT mapping

DUAL USE CONTROLLED